

• ÍNDICE DE CONTENIDOS

ANTECEDENTES.....	1
PRIMERO:	1
SEGUNDO:	1
TERCERO:	2
CUARTO:.....	2
QUINTO:	5
SEXTO:	5
SEPTIMO:	5
OCTAVO:	5
NOVENO:	5
Previa: Reiteración de las alegaciones previamente presentadas.....	5
Primera: Existencia de prejudicialidad penal.....	6
Segunda: Sobre el supuesto de hecho.....	6
Tercera: Del rol de víctima de ORANGE . Sobre el Modus Operandi.....	8
Cuarta: De la inexistencia de falta de legitimación en el tratamiento de datos personales de ORANGE	9
Quinta: De la correcta implementación de la privacidad desde el diseño y por defecto.....	12
Sexto: Concurso de infracciones.....	15
Séptima: Sobre la inadmisibilidad de la responsabilidad objetiva.....	16
Octava: Acerca de las medidas adoptadas e implementadas por ORANGE	18
Novena: Falta de proporcionalidad de la sanción impuesta.....	20
DÉCIMO:.....	23
DÉCIMO PRIMERO:	23
DÉCIMO SEGUNDO:	23
Primera.- De la existencia de prejudicialidad penal.....	23
Segunda. Sobre el supuesto de hecho.....	24
Tercera. Sobre la actuación delictiva de los agentes.....	26
Cuarta. De la inexistencia de falta de legitimación en el tratamiento de datos personales de ORANGE	28

Quinto. De la correcta implementación de la privacidad desde el diseño y por defecto.....	29
Sexta. Sobre la existencia de un concurso de infracciones.....	33
Séptima. Sobre la inadmisibilidad de la responsabilidad objetiva.....	33
Octava. Sobre las medidas adoptadas e implementadas por ORANGE.....	34
HECHOS PROBADOS.....	37
PRIMERO:	38
SEGUNDO:	39
TERCERO:	39
CUARTO.....	39
QUINTO:	40
SEXTO:	40
SÉPTIMO:	40
OCTAVO:	41
NOVENO:	41
DÉCIMO:	42
DÉCIMO PRIMERO:.....	42
DÉCIMO SEGUNDO:	42
DÉCIMO TERCERO:	47
DECIMO CUARTO:.....	51
FUNDAMENTOS DE DERECHO.....	56
I Competencia.....	56
II Cuestiones previas.....	56
III Respuesta a las alegaciones al acuerdo de inicio.....	57
Primera: Existencia de prejudicialidad penal.....	57
Segunda: Sobre el supuesto de hecho.....	59
Tercera: Del rol de víctima de ORANGE . Sobre el Modus Operandi.....	64
Cuarta: De la inexistencia de falta de legitimación en el tratamiento de datos personales de ORANGE	68
Quinta: De la correcta implementación de la privacidad desde el diseño y por defecto.....	70
Sexto: Concurso de infracciones.....	76
Séptima: Sobre la inadmisibilidad de la responsabilidad objetiva.....	84
Octava: Acerca de las medidas adoptadas e implementadas por ORANGE	88

Novena: falta de proporcionalidad de la sanción impuesta.....	88
IV Respuesta a las alegaciones a la propuesta de resolución del procedimiento sancionador.....	96
Primero. De la existencia de prejudicialidad penal.....	96
Segunda. Sobre el supuesto de hecho.....	98
Tercera. Sobre la actuación delictiva de los agentes.....	103
Cuarta. De la inexistencia de falta de legitimación en el tratamiento de datos personales de ORANGE.....	104
Quinto. De la correcta implementación de la privacidad desde el diseño y por defecto.....	105
Sexta. Sobre la existencia de un concurso de infracciones.....	109
Séptima. Sobre la inadmisibilidad de la responsabilidad objetiva.....	110
Octava. Sobre las medidas adoptadas e implementadas por ORANGE.....	112
9. Sobre la falta de proporcionalidad de la sanción propuesta.....	115
V Obligación incumplida.....	117
VI Tipificación y calificación de la infracción.....	119
VII Sanción por la infracción del artículo 6.1 del RGPD.....	119
VIII Protección de datos desde el diseño y por defecto.....	120
IX Tipificación de la infracción del artículo 25.....	126
X Sanción por la infracción del artículo 25 del RGPD.....	126
XI Adopción de medidas.....	128

Expediente N.º: EXP202213023

RESOLUCIÓN DE PROCEDIMIENTO SANCIONADOR

Del procedimiento instruido por la Agencia Española de Protección de Datos y en base a los siguientes

ANTECEDENTES

PRIMERO: A.A.A. (en adelante, la parte reclamante) con fecha 23 de noviembre de 2022 interpuso reclamación ante la Agencia Española de Protección de Datos. La reclamación se dirige contra **ORANGE ESPAGNE, S.A.U.** con NIF **A82009812** (en adelante, **ORANGE**). Los motivos en que basa la reclamación son los siguientes:

La parte reclamante manifiesta que se ha realizado un duplicado de su tarjeta SIM sin comprobar adecuadamente su identidad, y sin contar con su DNI, suplantando su identidad. El duplicado se realizó en un establecimiento de la entidad el 15 de noviembre de 2022.

Señala la parte reclamante que como consecuencia del duplicado se ha sustraído dinero de sus cuentas bancarias por importe de 9.000 euros.

Documentación relevante aportada por la parte reclamante:

- Hoja de reclamación oficial de la Comunidad de Madrid.

SEGUNDO: De conformidad con el artículo 65.4 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante LOPDGDD), se dio traslado de dicha reclamación a **ORANGE**, para que procediese a su análisis e informase a esta Agencia en el plazo de un mes, de las acciones llevadas a cabo para adecuarse a los requisitos previstos en la normativa de protección de datos.

El traslado, que se practicó conforme a las normas establecidas en la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante, LPACAP), fue recogido en fecha 29/12/2022 como consta en el acuse de recibo que obra en el expediente.

Con fecha 31/01/2023 se recibe en esta Agencia escrito de respuesta indicando lo siguiente:

"Habiéndose, pues, constatado la irregularidad en la solicitud del duplicado, el equipo de Análisis de Riesgos confirmó que, dos agentes del Punto de Venta de la tienda de

ORANGE MADRID *DIRECCIÓN.1** habían actuado irregularmente, usando sus credenciales de los sistemas internos de esta mercantil para activar el duplicado de tarjeta SIM.

Así las cosas, se pudo comprobar que, en el momento de la contratación se siguió el protocolo establecido por esta mercantil pasando (...) [...]. Este sistema permite identificar que (...). No obstante, a pesar de que se siguieron las instrucciones indicadas a los distribuidores, debido a que fueron los agentes los que actuaron irregularmente, (...)."

Indicaban además que:

"[...] esta mercantil ha tomado las medidas legales oportunas que están en su mano, comunicando al distribuidor la necesidad de interponer una denuncia contra los agentes de los que son responsables.

Adicionalmente, en aras a evitar al máximo que el incidente expuesto pueda ocurrir de nuevo, desde la compañía se ha procedido a rastrear (...).

Asimismo, con fecha 28 de diciembre de 2022, y con anterioridad a la notificación del presente requerimiento, se dio traslado desde la Escuela de Comerciales a todo el canal de distribución a los Puntos de Venta una píldora formativa obligatoria con el fin de ayudar y concienciar a los equipos comerciales del riesgo de captar a comerciales para realizar duplicados físicamente desde los Puntos de Venta.

Por último, esta mercantil procedió a la devolución de los importes cobrados por cambio de SIM en la factura de enero de 2023."

TERCERO: Con fecha 3 de febrero de 2023, de conformidad con el artículo 65 de la LOPDGDD, se admitió a trámite la reclamación presentada por la parte reclamante.

CUARTO: La Subdirección General de Inspección de Datos procedió a la realización de actuaciones previas de investigación para el esclarecimiento de los hechos en cuestión, en virtud de las funciones asignadas a las autoridades de control en el artículo 57.1 y de los poderes otorgados en el artículo 58.1 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), y de conformidad con lo establecido en el Título VII, Capítulo I, Sección segunda, de la LOPDGDD, teniendo conocimiento de los siguientes extremos:

En las presentes actuaciones de inspección se ha requerido a **ORANGE** para que aporte una descripción detallada del Sistema de verificación de la identidad, la operativa que se sigue con este sistema e información detallada de las comprobaciones que realiza sobre los documentos de identidad. Se pedía confirmación de que este sistema (...).

ORANGE ha contestado a este respecto lo siguiente:

Ante la solicitud de un acto comercial en un punto de venta, el agente recoge el documento de identidad del solicitante (...).

Por regla general el sistema sí (...). No obstante, (...).

Fue esta circunstancia, en el caso que nos ocupa, la que permitió a los agentes (...) y realizar el duplicado de SIM de forma fraudulenta usurpando la identidad de la parte reclamante y no procediendo por tanto a realizar la pertinente (...), motivo por el cual consiguieron realizar la operación.

Se ha requerido también a **ORANGE** para que aporte copia del contrato suscrito con el distribuidor en cuestión, así como copia de todas las instrucciones de que disponía con relación a la (...) de los clientes en el marco de la realización de duplicados SIM. Se pedía, así mismo, copia de las instrucciones con relación a la utilización del (...).

Aportan copia de las instrucciones, publicadas según la documentación aportada en “Descubre **Orange**”, apartado “Residencial”, “Documentación necesaria para el alta y otros actos comerciales de un cliente V26” “Especial referencia al fraude en cambios de SIM no consentidos”, para el punto de venta se especifica *“la SIM de reemplazo jamás será entregada a una persona distinta del titular, ni aunque lleve la autorización firmada”*.

Indica asimismo que *“el documento del cliente siempre será validado en (...)” “sí en ese momento (...) se abrirá incidencia y se emplazará al cliente a que vuelva al día siguiente”*. Se indica lo mismo para la obtención de la SIM que para un cambio de SIM.

Aportan también pantallazo que muestra la herramienta utilizada en el punto de venta que para las tarjetas SIM incluye un botón de “Documentación”, que según se especifica invoca (...).

Manifiestan que, de forma excepcional, (...).

Aporta copia del contrato con la franquiciada en cuestión. En el Objeto del contrato consta entre otras actividades “Recambio tarjetas SIM”. Contiene un punto, el vigésimo segundo, de tratamiento de datos personales y el vigésimo tercero, de confidencialidad.

Sobre las razones por las que los agentes actuaron irregularmente los representantes de la parte reclamada manifiestan que se ha podido constatar que durante los primeros meses del 2023 se han incrementado los ataques en puntos de venta captando comerciales para realizar actos delictivos a cambio de grandes recompensas económicas (CAT, Comité Antifraude Telco). En el presente caso, se comunicó al distribuidor la necesidad de tomar medidas legales oportunas interponiendo denuncia contra los agentes de los que son responsables. El distribuidor la interpuso habiéndose abierto diligencias previas nº **XXX/20XX** en el juzgado de instrucción nº 53 de Madrid.

Sobre otras medidas tomadas para evitar que estos hechos se vuelvan a producir **ORANGE** indica que desde los equipos de prevención de fraude, seguridad y oficina del DPD se ha impulsado la difusión a todo el canal de distribución de una píldora formativa con el objetivo de concienciar a los trabajadores de la problemática existente y de la obligatoriedad de cumplir con todos los procedimientos y políticas de identificación de clientes.

Aportan la URL donde se encuentra publicada la píldora informativa, verificándose que contiene un apartado de contexto/antecedentes, donde se indica entre otras circunstancias el riesgo elevado del SIM *swapping* y la necesidad de cumplir rigurosamente todos los procedimientos y la política de identificación de clientes utilizando la herramienta de verificación de identidad.

En el apartado Acciones jurídicas se mencionan las actuaciones jurídicas y consecuencias que puede tener el incumplimiento de las pautas prescritas por la compañía, con sanciones disciplinarias para el empleado que haya llevado a cabo una conducta irregular, así como que las autoridades judiciales pueden considerar que el empleado que ha incumplido las pautas establecidas por la compañía es partícipe a título de colaborador necesario en la comisión de un ilícito penal, lo que puede acarrear penas de prisión y el resarcimiento económico del cliente que se ha visto perjudicado por la acción del SIM *swapping*.

En el apartado “Casos de uso” de la píldora informativa se especifica, entre otros casos, (...). Se accede a 13 casos de uso.

Por último, se ha requerido a **ORANGE** para que aporte los contactos mantenidos con la parte reclamante, verificándose que existe un contacto de fecha 16 de noviembre de 2022 en el que el operador registra la queja del cliente sobre el duplicado SIM, así como que consta realizado cambio de SIM con fecha el día anterior. Recomiendan al cliente cambiar la contraseña del área de clientes.

QUINTO: De acuerdo con el informe recogido de la herramienta AXESOR, la entidad **ORANGE ESPAGNE, S.A.U.** es una gran empresa con un volumen de ventas de (...) y 3.068 empleados.

SEXTO: Con fecha 28 de noviembre de 2023, la Directora de la Agencia Española de Protección de Datos acordó iniciar procedimiento sancionador a la parte reclamada, con arreglo a lo dispuesto en los artículos 63 y 64 de la LPACAP, por la presunta infracción del Artículo 6 del RGPD y Artículo 25 del RGPD, tipificada en el Artículo 83.4 del RGPD y Artículo 83.5 del RGPD.

Este acuerdo de inicio, que se notificó a **ORANGE** conforme a las normas establecidas en la LPACAP, fue recogido en fecha 28 de noviembre de 2023, como consta en el acuse de recibo que obra en el expediente.

SEPTIMO: Con fecha 30 de noviembre de 2023, **ORANGE** presenta un escrito a través del cual solicita la ampliación del plazo para aducir alegaciones y que se le facilite copia del expediente.

OCTAVO: Con fecha 4 de diciembre de 2023, el órgano instructor del procedimiento acuerda la ampliación de plazo instada hasta un máximo de 5 días, de acuerdo con lo dispuesto en el artículo 32.1 de la LPACAP, y que se le remita a **ORANGE** copia del expediente.

El citado acuerdo se notifica a **ORANGE** en fecha 11 de diciembre de 2023, como consta en el acuse de recibo que obra en el expediente.

NOVENO: Con fecha 21 de diciembre de 2023, se recibe en esta Agencia, en tiempo y forma, escrito de **ORANGE** en el que aduce alegaciones al acuerdo de inicio. En estas alegaciones, en síntesis, manifestaba:

Previa: reiteración de las alegaciones previamente presentadas.

ORANGE manifiesta su disconformidad con el contenido del acuerdo de inicio y se ratifica y da por reproducidas las alegaciones y argumentaciones presentadas en sus anteriores escritos, sin perjuicio de la facultad que tiene para incidir, en estas alegaciones presentadas, en los puntos que considere más relevantes y añada elementos para impugnar las fundamentaciones recogida en el acuerdo de inicio del presente expediente sancionador.

Primera: existencia de prejudicialidad penal.

ORANGE manifiesta que los hechos objeto del acuerdo de inicio son, a su vez la base de una investigación penal en la que figura como parte perjudicada, estando, por tanto, sujetos al principio de prejudicialidad penal previsto en el artículo 10 de la Ley Orgánica 6/1985, de 1 de julio, del Poder Judicial.

En consecuencia, manifiesta que debería resolverse el asunto en la vía penal, antes de realizarse un pronunciamiento en vía administrativa, y para ello, cita el artículo 22.1.g) de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas, para solicitar la suspensión de este procedimiento sancionador, según el cual, el transcurso del plazo máximo legal para resolver un procedimiento y notificar la resolución se podrá suspender cuando para la resolución del procedimiento sea indispensable la obtención de un pronunciamiento previo por parte de un órgano jurisdiccional.

ORANGE fundamenta la solicitud de suspensión en lo dispuesto en el artículo 77.4 de la citada Ley 39/2015, según el cual, en los procedimientos de carácter sancionador, los hechos declarados probados por resoluciones judiciales penales firmes vincularán a las Administraciones Públicas respecto de los procedimientos sancionadores que substancien.

Asimismo, pone de manifiesto que la prejudicialidad penal requiere una triple identidad de sujeto, hecho y fundamento, para que el principio de non bis in ídem incardinado en el artículo 25 de la Constitución pueda ser considerado válido y aplicable al caso concreto.

De este modo, **ORANGE** manifiesta que:

- en cuanto al sujeto, se constata la autoría de los hechos en ambos procedimientos por parte de los agentes comerciales.
- en cuanto al hecho, existe coincidencia al tratarse de la emisión fraudulenta de un duplicado de tarjeta SIM.

-en cuanto al fundamento, se estaría sancionando en dos ocasiones por la conducta ilegítima y fraudulenta de los agentes, contraria a los protocolos y procedimientos establecidos por **ORANGE**.

Por último, manifiesta que aporta, como documento 1 la denuncia interpuesta por el distribuidor contra los agentes implicados, y como documento 2 el escrito de personación de **ORANGE** en la causa penal como parte perjudicada.

Segunda: sobre el supuesto de hecho.

ORANGE hace un relato de los hechos, que se puede resumir de la siguiente manera:

-el día 15 de noviembre de 2022 la parte reclamante se dio cuenta de que no tenía línea en su teléfono móvil, acudiendo a un establecimiento de **ORANGE** para solventar la incidencia. En este momento, se constata que se ha producido, de manera fraudulenta, un duplicado de su tarjeta SIM, procediéndose a su desactivación, solventándose así la incidencia objeto de la reclamación.

-cuando se tuvo conocimiento de la incidencia, se dio traslado al Grupo de Análisis de Riesgos, confirmándose el duplicado de la tarjeta SIM, que fue activada por un agente comercial de la tienda de **ORANGE** el día 15 de diciembre de 2022. El equipo de análisis de riesgos concluyó que los dos agentes del punto de venta habían actuado de forma delictiva con intención fraudulenta, usando sus conocimientos y los sistemas internos para activar el duplicado.

-en el presente supuesto, (...).

El protocolo de **ORANGE** establece que, si bien se debe generar un aviso al Grupo de Análisis de Riesgos, se permite a los agentes comerciales para casos tasados continuar el proceso (...). Esto se permite en los casos de (...). Por eso, **ORANGE** considera que los agentes se aprovecharon de su conocimiento del sistema para cometer el acto delictivo.

-**ORANGE** quiere señalar que antes de haber recibido el primer requerimiento de información remitido por esta AEPD en este supuesto, ya había trasladado, a través del Grupo de Análisis de Riesgos y a través de la Escuela de Comerciales, una píldora de refuerzo obligatorio para todos los puntos de venta, en la que se concienciaba y se remitía información tendente a fomentar la colaboración por parte de los equipos comerciales.

-el 16 de enero de 2023 la mercantil TOWER PHONE, S.L., en la que se encuentra la empresa distribuidora a la que pertenece el punto de venta, ha interpuesto denuncia ante el Juzgado de Instrucción de Madrid contra los dos comerciales que participaron en el duplicado de la tarjeta SIM.

ORANGE quiere manifestar que la emisión de un duplicado de tarjeta SIM implica a emisión de una tarjeta SIM sin información personal, y que por sí sola no permite el acceso a información bancaria o financiera.

ORANGE hace esta manifestación porque entiende que esta AEPD utiliza en el acuerdo de inicio asociaciones erróneas para agravar el supuesto de hecho que nos ocupa, otorgando al duplicado de la tarjeta SIM la facultad de permitir la comisión de operaciones bancarias, omitiendo un paso previo, según el cual, los malhechores deberán obtener y poder utilizar las credenciales bancarias de la parte reclamante para poder identificarse y, en primer lugar, realizar la suplantación de identidad ante su entidad financiera.

Añade que esta AEPD no menciona el rol que desempeñan las entidades financieras en estos supuestos, ni consta que, pese al perjuicio económico a la parte reclamante, se hayan iniciado procedimientos sancionadores contra las mismas. Considera que esta AEPD no puede sostener la imputación de culpa a esta mercantil en meras manifestaciones ausentes de prueba, sobre las que, en cualquier caso, sería necesario evaluar la intervención y responsabilidad de las entidades afectadas.

Añade que la AEPD pretende sancionar los fraudes Sim Swapping sin atender ni analizar el concreto supuesto de hecho, el perjuicio asociado, ni las responsabilidades derivadas, sin tener en cuenta la diligencia desplegada por **ORANGE** en su actuación y en la adopción de medidas de seguridad.

En este sentido, quiere mencionar la sentencia de la Audiencia Nacional 6460/2022, de 23 de diciembre de 2022, que ha anulado, por no ser conforme a Derecho, la resolución PS/00070/2019, y en la que se recoge:

“La AEPD no examina dichas reclamaciones que se refieren a unos determinados hechos ni en los fundamentos de derecho hace una valoración de las pruebas practicadas en relación con las mismas, ni se conectan con el documento de privacidad, sino que se vale de las mismas para abrir una especie de causa general contra la política de privacidad”.

ORANGE quiere manifestar que, al igual que en este procedimiento, esta AEPD no alude al supuesto de hecho concreto, y omite valorar la documental aportada, estableciendo un discurso genérico para legitimar una infracción a la normativa de protección de datos. Añade que esta AEPD ha impuesto diversas sanciones a **ORANGE** por denuncias relacionadas con el Sim Swapping en las que se reproducen los mismos razonamientos jurídicos sin importar hechos o circunstancias concurrentes en cada caso. Añade que este proceder es contrario a lo que se recoge en la sentencia de la Audiencia Nacional citada, que incide en la necesidad de que la AEPD examine con rigor el cumplimiento de los principios del procedimiento administrativo sancionador en sus resoluciones.

Tercera: del rol de víctima de **ORANGE**. Sobre el Modus Operandi.

ORANGE hace un resumen de los antecedentes de fraudes con características similares al “Sim Swap”, señalando que en un primer momento las suplantaciones de identidad solicitaban duplicados de tarjetas SIM de forma presencial, mientras que en la actualidad se concentran en la solicitud de duplicados y activación de tarjetas SIM por canales no presenciales.

En el presente expediente sancionador el duplicado de la tarjeta SIM se realiza por dos comerciales del punto de venta de la compañía, que actuaban, consiguientemente, en nombre de **ORANGE**.

Por ello, **ORANGE** manifiesta que cuando son los agentes los que deciden cometer el delito, aprovechándose de los medios y sistemas de **ORANGE**, frustrando sus procedimientos y medidas de seguridad, el rol de **ORANGE** es el de perjudicada, ya que la comisión del delito se produce por sus agentes, y con ello la quiebra de sus obligaciones contractuales para con **ORANGE** y sus distribuidores. Por ello entiende que no resulta posible exigir a esta mercantil, la capacidad total de detección y frustración de tales actos delictivos.

En este punto, **ORANGE** quiere citar el Auto 35/2023, de la Sala Penal, Sección 3ª de la AN, de 30 de enero de 2023 que desestima un recurso de apelación formulado por el Ministerio Fiscal, confirmando el sobreseimiento y archivo de la pieza de investigación respecto de la responsabilidad de dos personas jurídicas. Así, en su Fundamento Jurídico 2º, con relación a los modelos de prevención de delitos y la responsabilidad asociada de la persona jurídica, especifica:

“SEGUNDO. – Rechazamos los motivos de recurso alegados por el Ministerio Fiscal, aceptando y dando por reproducidos los razonamientos del auto recurrido y la jurisprudencia citada sobre la responsabilidad penal de las personas jurídicas en el auto de 29.07.2021, al que en algunos aspectos se remite el de 02.06.2022. En el momento en que se produjeron las contrataciones con (...) a que se refiere este procedimiento, (...) contaba con un Modelo de Prevención de delitos que cumplía con los requisitos previstos en el artículo 31 bis CP. Ningún modelo es infalible, y si un delito se comete por alguno de los sujetos que contempla el precepto citado, no implica necesariamente que el modelo de prevención de delitos adoptado por la persona jurídica sea inadecuado, incumpla la normativa vigente o falle, pues bastaría con adoptar un modelo que cumpliera todas las normas para impedir la comisión de delitos, lo que no se ajusta a la realidad y precisamente por eso los modelos de prevención de delitos están sujetos a revisiones periódicas”

Con este fundamento, **ORANGE** quiere manifestar que los Tribunales vienen reconociendo que la comisión de un delito, incluso cuando se cometen en el seno de una persona jurídica, no determina de forma automática, culpabilidad o falta de diligencia.

Asimismo, manifiesta que **ORANGE** ha acreditado documentalmente la implantación de medidas concretas y adecuadas, así como un procedimiento de solicitud de duplicados de tarjetas SIM, por lo que no cabe presumir una actuación negligente.

Por ello quiere reiterar que **ORANGE** es víctima de un ataque criminal instrumentado a través de sus propios sistemas y desde uno de sus puntos de venta. Además, es la primera vez que se habría producido, siendo totalmente novedoso.

Cuarta: de la inexistencia de falta de legitimación en el tratamiento de datos personales de **ORANGE**.

ORANGE pone de manifiesto que, durante el proceso de duplicado de la tarjeta SIM que ha motivado la apertura de este procedimiento sancionador, **ORANGE** no facilitó ningún dato personal de la parte reclamante a ningún tercero, no produciéndose revelación alguna ni acceso no autorizado a sus datos personales.

Añade que en el expediente sancionador no consta ningún otro tratamiento de datos que pueda calificarse de ilícito, no habiendo relación entre los hechos que la AEPD identifica como probados y la calificación jurídica que se hace de los mismos.

Entiende que la comisión de los actos delictivos se hace por los agentes de forma individual, y en oposición a las obligaciones impuestas por **ORANGE**, sus procedimientos y protocolos, y por tanto, no se puede achacar, de forma automática, a una actuación de **ORANGE**. En este sentido, aportan como documento 3 y 4 el contrato firmado con la franquiciada, encargada del tratamiento, así como la adenda de la novación del mismo, para ejemplificar las obligaciones contractuales asumidas por los agentes.

Por otro lado, **ORANGE** pone de manifiesto que en el acuerdo de inicio se indica, en la página 6:

“Por otro lado, la emisión de un duplicado de tarjeta SIM supone el tratamiento de los datos personales de su titular, ya que se considerará persona física identificable toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador (artículo 4.1) del RGPD).

Por lo tanto, la tarjeta SIM identifica un número de teléfono y este número a su vez, identifica a su titular. En este sentido la Sentencia del TJUE en el asunto C-101/2001 (Lindqvist) de 6,11,2003, apartado 24, Rec, 2003 p.I-12971: El concepto de “datos personales” que emplea el artículo 3, apartado 1 de la Directiva 95/46 comprende, con arreglo a la definición que figura en el Artículo 2, letra a), de dicha Directiva, “toda información sobre una persona física identificada o identificable”. Este concepto incluye, sin duda, el nombre de una persona junto a su número de teléfono o a otra información relativa a sus condiciones de trabajo o sus aficiones.

En suma, tanto los datos que se tratan para emitir un duplicado de tarjeta SIM como la tarjeta SIM (Subscriber Identity Module) que identifica de forma inequívoca y unívoca al abonado en la red, son datos de carácter personal, debiendo su tratamiento estar sujeto a la normativa de protección de datos”.

A este respecto, hace referencia a la Sentencia del Tribunal General de la Unión Europea (Sala Octava ampliada) de 26 de abril de 2023, en el que se determina que no puede presuponerse la consideración como dato personal de un código alfanumérico, sino que compete a la autoridad de control justificar la capacidad de relacionar los datos personales con una persona concreta, no bastando con presuponerlo por el mero hecho de que potencialmente pudiera llegar a permitir una identificación.

En este sentido, en esta sentencia se recoge que corresponde a la autoridad de control *“determinar si la posibilidad de combinar la información que se había transmitido a (...) con la información adicional en poder de la (...) constituía un medio que (...) podía razonablemente utilizar para identificar a los autores de los comentarios”*. A lo que añade que: *“Por lo tanto, al no haber investigado el (...) si (...) disponía de medios legales y factibles en la práctica para poder acceder a la información adicional para volver a identificar a los autores de los comentarios, el (...) no podía concluir que la información transmitida a (...) constituía información sobre una persona física identificable, en el sentido del artículo 3, punto 1, del Reglamento 2018/1725.”*

ORANGE quiere manifestar que desde esta AEPD no se ha desplegado actividad probatoria ninguna en este sentido, sino que directamente presupone que los códigos contenidos en la tarjeta SIM permiten la identificación de su titular.

Añade que el hecho de que los códigos permitan diferenciar técnicamente a un usuario de la red de otros para la correcta gestión de las comunicaciones no implica que los intervinientes en el proceso tengan la posibilidad de asociar esa información con una persona concreta, y, teniendo en cuenta la sentencia del Tribunal General, no estaríamos ante un supuesto de tratamiento ilícito de datos personales.

En este punto, **ORANGE** cita la Sentencia del Tribunal Supremo de 18 de junio de 2020 (número de recurso 1074/2019, nº de Sentencia 815/2020) que expone, para el caso de un número de teléfono, que su consideración como dato personal es dudosa, en el siguiente sentido:

“Pues bien, en el caso que nos ocupa, aparte del número de teléfono de los denunciantes afectados, que si bien por sí sólo podría no ser considerado dato personal conforme la Sentencia de esta Sala de 17 de septiembre de 2008 (Rec. 353/2007), DIRECCION001 procede a registrar también la voz de los denunciantes a través de la oportuna grabación de la broma, susceptible de ser difundida”

De este modo, según esta sentencia, incluso en el caso del número de teléfono, debe justificarse su consideración como dato personal, no pudiendo presuponerse a los códigos, cuya capacidad para ser relacionados con el titular de la línea depende de la disposición o acceso a otros datos del mismo.

En este sentido, **ORANGE** entiende que los códigos (MSISDN e IMSI) no son una información directamente accesible, sino que implica la realización de actividades concretas con el dispositivo móvil, por lo que no cabría imputar un tratamiento de datos no legitimado por la mera tenencia de la tarjeta, y sin que pueda ser considerada, según lo recogido anteriormente, como un dato personal. Además, añade que, aun cuando se interpretase que la información técnica contenida en la tarjeta SIM pudiera considerarse un dato personal, no hay constancia de su conocimiento por parte de los autores del acto delictivo, por lo que no hay fundamento para concluir que ha existido un tratamiento ilícito de esos datos.

ORANGE pone de manifiesto que la afirmación recogida en el acuerdo de inicio *“En el presente caso, resulta acreditado que se ha producido un duplicado de la tarjeta SIM por parte de la parte reclamante a un tercero, sin su consentimiento, y sin contar con*

su DNI”, no reflejaría los hechos concretos, ya que, según manifiesta **ORANGE** no consta la intervención de ningún tercero, sino que son los propios agentes de **ORANGE** los que acceden, en virtud de los permisos que tienen concedidos, para el desempeño de sus obligaciones laborales, a la herramienta con normalidad, como usuarios autorizados, y conociendo la herramienta (...), hicieron un uso fraudulento y delictivo de la misma.

ORANGE manifiesta que no resulta posible la eliminación total del factor humano en la gestión de los procesos de **ORANGE**, pues en ocasiones es necesario validar documentos que pueden no estar automatizados. Considera además que adoptar medidas de control para los empleados o llevar un control exhaustivo de su actividad o sancionar la inobservancia de los protocolos establecidos no es compatible con la regulación laboral, y que no es posible exigir una efectividad absoluta de las medidas diseñadas para la prevención del fraude, o dicho en términos de análisis de riesgos, no cabe exigir la existencia de medidas eficaces que garanticen un “riesgo cero”, ya que esto implicaría materializar, de facto, la existencia de responsabilidad objetiva.

Asimismo, **ORANGE** manifiesta que no considera proporcional asumir que, por el mero hecho de realizarse un duplicado de la tarjeta SIM pueda conllevar “la producción de una sensible pérdida patrimonial” tal y como se señala en la página 6 del acuerdo de inicio. Entiende que los agentes de **ORANGE** no accedieron al teléfono móvil de la parte reclamante ni a la información que contiene, e insiste en que la tarjeta SIM no contiene los datos del terminal móvil ni de las aplicaciones instaladas, y para acceder a dichas aplicaciones, hay que conocer las credenciales bancarias. Por eso, entienden que el acuerdo de inicio no puede sostener su imputación con base en manifestaciones ausentes de prueba, que mencionan hechos que no tienen lugar en este supuesto. Manifiestan que esta afirmación no se deriva de ningún hecho probado, y quebranta el principio de tipicidad y la presunción de inocencia de **ORANGE**, al imputarle culpa sin prueba de cargo suficiente.

Por último, quiere manifestar que no es posible imputar a **ORANGE** la realización de un tratamiento de datos sin legitimación, teniendo el tratamiento realizado por **ORANGE** base en la relación contractual existente con la parte reclamante, tal y como se recoge en el Considerando 40 de la fundamentación. Por ello, entienden que no se produce un tratamiento ilegítimo de los datos de la parte reclamante, no siendo imputable por tanto una infracción del artículo 6.1 del RGPD.

Quinta: de la correcta implementación de la privacidad desde el diseño y por defecto.

ORANGE aporta los siguientes documentos en relación con esta cuestión:

-documento nº 5, relativo al “Privacy Management Dashboard” que se comparte anualmente con la compañía.

-documento nº 6, informe que contiene la opinión de auditoría correspondiente a la aplicación de principios de privacidad desde el diseño y por defecto por parte de **ORANGE**.

-documento nº 7, procedimiento de protección de datos desde el diseño y por defecto de la compañía.

Por otro lado, entiende que la fundamentación que se recoge en el acuerdo de inicio acerca de este incumplimiento es escasa, teniendo en cuenta la extensa reproducción normativa y los considerandos relativos a dicho principio y las Guías de la AEPD sobre esta materia.

Insiste en que esta Agencia no tiene en cuenta, en el acuerdo de inicio, que los agentes de la tienda son personas contratadas por **ORANGE** o por los distribuidores y franquicias, y que tienen como labor llevar a cabo procesos de contratación, y otros complementarios, diseñados por la compañía, y que en estos si se tiene en cuenta la privacidad y la seguridad de la información, incluyendo la intervención de los propios agentes.

Añade que los agentes tienen como labor ejecutar los procesos verificando que se realizan de manera correcta, según las instrucciones facilitadas por **ORANGE**, y que no hacerlo supondría un incumplimiento de las obligaciones contractuales, de las instrucciones y protocolos internos de la compañía.

ORANGE manifiesta que la automatización de medidas para apoyar esta labor con medios digitales la facilitan y complementan, pero no puede ser interpretado como un requisito indispensable, sino como un refuerzo. Además, entiende que hay que tener en cuenta la posibilidad legítima de **ORANGE** de delegar tareas de supervisión en usuarios designados para ello, sin que esto suponga un incumplimiento normativo, y que prohibir de forma generalizada la toma de decisiones por parte de los empleados sería contrario a lo que propone el RGPD.

ORANGE manifiesta que el hecho de que intervenga una persona en el proceso no tiene que implicar necesariamente que no existe seguridad, o que sea una incitación a los empleados para delinquir, o presumir que la generalidad de los trabajadores está más dispuesto a cometer delitos de fraude que a realizar sus funciones. Y añade que es la primera vez que ocurre.

Además, entiende que es contrario al criterio recogido en la Guía sobre tratamientos de control de presencia mediante sistemas biométricos, de 23 de noviembre de 2023, donde se afirma:

“No es obligatorio, ni recomendable, que la implementación de un tratamiento, se limite exclusivamente a la selección de recursos tecnológicos. En las opciones de implementar un tratamiento hay que considerar, entre otros, la utilización de recursos humanos, las garantías jurídicas y los procedimientos organizativos”

Por ello, entiende que, en el caso que ha motivado la apertura de este procedimiento sancionador, en el que, tras identificarse un error técnico que impide la realización de una gestión ordinaria, se habilitan (...) para llevar a cabo la operativa, medios que deben ser considerados como complementarios, de tal manera que el agente que interviene en la operación verifica (...).

ORANGE quiere señalar también que, en ocasiones son los propios clientes los que demandan agilidad en la realización de los trámites que solicitan, y es por ello, que se

habilitan medios de comprobación alternativos, que están sometidos previamente a los correspondientes análisis de riesgos.

ORANGE pone de manifiesto que la prevención del fraude está encomendada a un departamento específico de la compañía, que es quien evalúa los riesgos conforme a un protocolo y metodología específica, aportando para acreditarlo los siguientes documentos:

- documento 8, relativo a la Group Risk Management Policy
- documento 9, Política de Control y Gestión de Riesgos
- documento 10, que describe el funcionamiento del Comité de Riesgos Locales
- documento 11, que enumera la Política de Control Interno de **Orange**.
- documento 12, Fraudulent Use of Data- 3rd Parties, donde hay una presentación que se llevó al Comité de Riesgos Local, en la que se hace referencia expresa al análisis de la evolución de este riesgo.

Con ello, **ORANGE** quiere manifestar que es incorrecto afirmar que este tipo de riesgo no ha sido objeto de análisis, sino que ha ido incrementándose en fechas recientes, debido al caso que ha motivado la apertura de este procedimiento sancionador, y quiere poner de manifiesto que el riesgo se había calificado como bajo, y por ello no se necesitaba implementar medidas adicionales a las ya existentes, sin que ello suponga que actuaba de forma correctiva y no preventiva. Y como medidas preventivas adoptadas quiere señalar:

-medidas jurídicas: contrato con el franquiciado, incluyendo un compromiso de confidencialidad (documentos nº 3 y documento nº 4).

-medidas organizativas:

- comunicación de instrucciones tales como la píldora informativa proporcionada a los Agentes de **Orange**,

- control de acceso y registro de acciones ejecutadas por los usuarios, que requiere el uso de credenciales personales intransferibles, asignadas por **ORANGE**, y que permiten la identificación del agente y la monitorización de su actividad.

- protocolo de gestión de errores, (...).

ORANGE añade que, en este caso, las personas fueron despedidas y en la actualidad se encuentran encausadas penalmente, y que estas medidas son consecuencia de unas medidas disuasorias implementadas con anterioridad para mitigar el riesgo a la realización de este tipo de actuaciones.

Insiste en que no puede aceptarse que el hecho de permitir que sea el agente el que supervise la corrección de un proceso implique que no exista un control sobre el

proceso o que esta medida no sea conforme con el RGPD, y que esta afirmación supone que todo proceso realizado por una persona sin un control digital es inadecuado, algo que **ORANGE** entiende insostenible. Añade que el control digital es susceptible de ser incorrecto o fallar, resultando necesario un control humano.

ORANGE menciona en este punto el artículo 22 RGPD, relativo a decisiones individuales automatizadas, que recoge el derecho de todo a no ser objeto de una decisión basada únicamente en el tratamiento automatizado, así como el derecho a obtener intervención humana por parte del responsable, y entiende que la interpretación que se realiza por esta AEPD de que permitir la adopción de decisiones por parte de una persona supone un incumplimiento del RGPD, es contraria al espíritu de la norma, que pretende fomentar la intervención de las personas en los procesos para evitar sesgos, incorrecciones o errores derivados de los procesos plenamente automatizados.

De esta manera, entiende que contemplarse intervención humana antes determinados errores de la máquina sería conforme al RGPD y es además una buena práctica. Todo ello porque considera que nunca es completamente evitable que un usuario malintencionado pueda realizar una acción ilícita, pudiendo memorizar información personal de clientes para hacer un uso ilícito de los mismos.

ORANGE recuerda que, en este caso, se habría tratado de una acción dolosa, intencionada y con el ánimo de beneficiarse personal y económicamente, y que, con independencia de que, tras tener conocimiento del hecho se ha actualizado el riesgo asignado a este potencial fraude y de que se han adoptado las medidas convenientes para limitarlo, esta actuación requirió identificación voluntaria antes de la comisión y dejar constancia del hecho.

ORANGE manifiesta su disconformidad con el hecho de que se justifique la sanción de un millón de euros por el incumplimiento general del principio de privacidad por diseño y por defecto de la compañía, aunque no se hubieran analizado los riesgos a la gestión no automatizada de una solicitud. Añade que no es cierto que no se haya tenido en cuenta el riesgo referido, pero que ello no puede servir como base para afirmar que se está incumpliendo un principio general del RGPD. Considera que se trata de un precepto genérico y ambiguo y que no deja de ser un recurso para tratar de tipificar un hecho que, en puridad, no supondría el incumplimiento de una obligación concreta, y que el hecho de no haber considerado una amenaza no podría invalidar todo el sistema de cumplimiento normativo implantado por **ORANGE**.

Sexto: concurso de infracciones.

ORANGE entiende que en este expediente sancionador se dan las circunstancias para considerar que tiene lugar una concurrencia entre las dos infracciones imputadas, al imponerse con base en un único hecho acometido por los agentes de **ORANGE**.

De este modo, **ORANGE** entiende que en el acuerdo de inicio se hace referencia a un único hecho, sujeto y fundamento, que sería la adopción de medidas en el procedimiento de duplicado de la tarjeta SIM en los supuestos tasados de intervención manual, lo que constituiría un supuesto de concurso medial en la vía penal o una concurrencia de ofensas o delitos en vía administrativa, que aplica “siempre que la

aplicación de una disposición impida o subsuma la aplicabilidad de la otra”, y que hace que resulte contrario al ordenamiento jurídico sancionar dos veces al infractor por el mismo ilícito.

ORANGE entiende que, del acuerdo de inicio se extrae que, en relación con los hechos analizados, existe una conexión directa entre las vulneraciones de los dos artículos.

De esta manera, la infracción del artículo 6.1 RGPD, o la existencia de un supuesto tratamiento de datos ilícito fue necesaria e inevitable para que tuviera lugar una vulneración del principio de privacidad desde el diseño y por defecto, derivada de no existir medidas de seguridad suficientes. de este modo, si **ORANGE** hubiera tenido medidas que permitiesen evitar el duplicado de la tarjeta SIM no se habría podido concluir la infracción del principio de privacidad por diseño y por defecto del artículo 25 del RGPD.

En consecuencia, se estaría dando un concurso de infracciones, ya que la comisión de una implicaría necesariamente la comisión de la otra.

ORANGE cita la Sentencia de la Audiencia Nacional de 24 de abril de 2013, Rec. 69/2011 según la cual:

“Para enjuiciar esta según infracción deviene esencial, a juicio de la Sala, hacer referencia al concurso de infracciones cuya existencia se invoca igualmente en la demanda. A tal fin ha de traerse a colación lo dispuesto en el artículo 4.4 del Real Decreto 1398/1993, según el cual: en defecto de regulación específica establecida en la norma correspondiente, cuando de la comisión de una infracción derive necesariamente la comisión de otra u otras, se deberá imponer únicamente la sanción correspondiente a la infracción más grave cometida.

Precepto que ha sido interpretado por la STS de 8 de febrero de 1999 (Rec. 9/1996) en el sentido de que la aplicación del concurso medial exige una necesaria derivación de unas infracciones respecto de las demás y viceversa, por lo que es indispensable que las unas no puedan cometerse sin ejecutar las otras”

Entiende **ORANGE** que, en caso de apreciarse una infracción de los artículos 6.1 y 25 del RGPD se trataría de infracciones concurrentes, y que la sanción aplicable sería en todo caso la correspondiente al incumplimiento del artículo 6.1 RGPD, teniendo en cuenta lo dispuesto en el artículo 29.5 de la Ley 40/2015, de 1 de octubre, de Régimen Jurídico del Sector Público, según el cual:

“cuando de la comisión de una infracción derive necesariamente la comisión de otra u otras, se deberá imponer únicamente la sanción correspondiente a la infracción más grave cometida.”

Además, hace referencia a las Directrices 4/2022 sobre el cálculo de multas administrativas bajo el RGPD, donde se estipulan los criterios que debe seguir la autoridad administrativa para evaluar, de forma previa a la imposición de la sanción, la posible concurrencia de éstas.

Séptima: sobre la inadmisibilidad de la responsabilidad objetiva.

ORANGE pone de manifiesto que el acuerdo de inicio del presente expediente sancionador se basa en un análisis de resultado, al considerar que la emisión del duplicado de la tarjeta SIM conlleva automáticamente la consideración de que no se tomaron medidas adecuadas, surgiendo así automáticamente la responsabilidad directa por parte de **ORANGE**, estableciéndose una obligación de resultado.

ORANGE considera que esta AEPD limita la obligación al resultado, al señalar que la superación de las medidas de seguridad por los agentes de **ORANGE** conlleva la consideración automática de que las medidas eran insuficientes, y que este hecho supone adoptar un principio de responsabilidad objetiva vetado por nuestro ordenamiento jurídico en numerosas ocasiones por el Tribunal Constitucional.

ORANGE hace referencia al principio de responsabilidad del artículo 28 de la Ley 40/2015, de 1 de octubre, que rompe con la responsabilidad objetiva y anuda la responsabilidad a la concurrencia de dolo o culpa.

De esta manera, **ORANGE** hace referencia a la Sentencia del Tribunal Constitucional 76/1990, de 26 de abril, en la que se exigiría que la Administración, a la hora de sancionar, pruebe la intencionalidad en el sancionado. Y añade que, en esta sentencia, se vino a señalar que la posibilidad de imponer una sanción exige la concurrencia de culpabilidad en los grados de dolo y culpa o negligencia grave, no siendo suficiente la mera negligencia, al expresarse de esta manera:

“el mero error humano no puede dar lugar, por sí mismo (y sobre todo cuando se produce con carácter aislado), a la atribución de consecuencias sancionadoras; pues, de hacerse así, se incurriría en un sistema de responsabilidad objetiva vedado por nuestro orden constitucional”.

ORANGE manifiesta que esta interpretación extensiva de la potestad sancionadora también habría sido categorizada como no aceptable por el Tribunal de Justicia de la Unión Europea en algunas sentencias, citando:

-C-683/2021, referida a los requisitos materiales que deben cumplirse para imponer una multa administrativa en virtud del RGPD.

De este modo, **ORANGE** entiende que al no haberse acreditado la concurrencia de una actuación culpable, intencionada o negligente por parte de **ORANGE** no se puede identificar la conducta como una infracción de la normativa de protección de datos por el hecho de haber sido víctima de un acto delictivo, y por ello no procede la imposición de una sanción.

En relación con la responsabilidad objetiva, cita la Sentencia del Tribunal Supremo 5298/1994, de 9 de julio, la Sentencia de la Sala de lo Contencioso Administrativo de la Audiencia Nacional, Sección 1ª de 23 de diciembre de 2013, Rec. 341/2012; Sentencia de la Sala de lo Contencioso de la Audiencia Nacional, de 25 de febrero de 2010, Recurso 226/2009; Sentencia del Tribunal Supremo 543/2022, de 15 de febrero.

En relación con la Sentencia del Tribunal Supremo 543/2022, de 15 de febrero, en la que se recogía que

“la obligación de adoptar las medidas necesarias para garantizar la seguridad de los datos personales no puede considerarse como una obligación de resultado, que implique que producida una filtración de datos personales a un tercero exista responsabilidad con independencia de las medidas adoptadas y de la actividad desplegada por el responsable” y añade que “el compromiso que se adquiere es el de adoptar los medios técnicos y organizativos, así como desplegar una actividad diligente en su implantación y utilización que tienda a conseguir el resultado esperado con medios que razonablemente puedan calificarse de idóneos y suficientes para su consecución, por ello se las denomina obligaciones de diligencia o de comportamiento.”

ORANGE considera que mientras que en la obligación de resultado se responde ante un resultado lesivo por el fallo del sistema de seguridad, en la obligación de medios basta con establecer medidas técnicamente adecuadas e implantarlas y utilizarlas con la diligencia razonable. Y por ello, considera que este acuerdo de inicio no es ajustado a derecho, al imponer a **ORANGE** una obligación de resultado, que consistiría en establecer medidas infalibles, al imputar una infracción del artículo 6.1 y del artículo 25 del RGPD basándose en el hecho lesivo que se produce por la intervención fraudulenta de un tercero, sin atender a la diligencia utilizada y sin considerar el despliegue de medidas técnicamente adecuadas e implantadas.

Añade que no sería viable implantar medidas inquebrantables, puesto que cualquier medida tiene vulnerabilidades, ni es exigible por la normativa que resulte de aplicación, y que esta Agencia emprende una causa general contra el SIM Swapping, sancionando el mero hecho de que se produzcan, sin analizar el supuesto de hecho concreto, el perjuicio asociado, ni las responsabilidades derivadas, y concluyendo la vulneración de la normativa de protección de datos por el mero hecho de haber sido víctima de una actividad delictiva, y sin tener en cuenta la diligencia desplegada por **ORANGE** en su actuación y en la adopción de medidas de seguridad.

Octava: acerca de las medidas adoptadas e implementadas por **ORANGE**.

ORANGE pone de manifiesto que ha adoptado las siguientes medidas, tanto de forma previa como a posteriori, en relación con el procedimiento de emisión de duplicados de tarjeta SIM.

1. Medidas implementadas para prevenir la comisión de fraudes derivados de la suplantación de identidad.

a) El grupo de análisis y riesgos emite periódicamente un manual de instrucciones denominado “Documentación necesaria y formatos de entrega para actos comerciales con cliente v.26”, donde se incluyen las instrucciones a seguir para analizar cualquier acto comercial, incluido el duplicado de tarjetas SIM.

En relación con la solicitud de duplicado o activación de tarjeta SIM, se recogen las instrucciones que deben seguir los agentes de **ORANGE**, entre las que se incluye la exigencia de aportación de un documento de identidad.

Adjuntan como documento 14, unas impresiones de pantalla de la herramienta “descubre **ORANGE**” con la información recogida en el documento a estos efectos.

b) **ORANGE** comunica que se emiten comunicaciones adicionales que reiteran los protocolos de actuación en los procesos de duplicados de tarjeta SIM.

c) Campañas de información y concienciación dirigidas a clientes, para que se tengan en cuenta la relevancia de custodiar sus credenciales y documentos de identidad de forma segura.

d) otras medidas y modificaciones en sus procesos comerciales y de negocio:

- desde el 12 de agosto de 2022 (...).

- desde el 12 de agosto de 2022 la solicitud de duplicado de tarjeta SIM (...).

- desde abril de 2021 **ORANGE** ha limitado los canales para solicitar un duplicado de tarjeta SIM, (...).

e) **ORANGE** forma parte de la Asociación Española para la Digitalización y participa en el proyecto “identidad digital segura” que tiene por objeto, entre otras cosas, proteger frente al fraude y los ciberataques y la defensa de la privacidad de los datos.

ORANGE comercializa la aplicación de “servicio de SIM Swap” que permite verificar (...).

2. Medidas implementadas por **ORANGE** para prevenir la comisión de fraudes derivados de la suplantación de agentes y/o empleados de **ORANGE**.

a) implantación de un doble factor de identificación, con un proyecto piloto en fase de testeo con ciertos usuarios.

b) proyecto (...).

c) herramienta de control de tráfico, empleada como medida de seguridad en la prevención y detección del fraude, que permite la generación de alertas en caso de detección de contrataciones irregulares, y que en el caso de duplicados de tarjeta SIM actuaría de la siguiente manera:

- (...).

- (...).

3. Medidas adoptadas por **ORANGE** con relación al presente supuesto, no incardinado en los apartados anteriores.

a) investigación interna, que ha identificado las causas y mitigar la posibilidad de que se produzcan situaciones similares.

b) denuncia presentada por el distribuidor de **ORANGE** ante las Fuerzas y Cuerpos de Seguridad a los agentes responsables del Punto de Venta que acometieron el hecho delictivo, y en el que **ORANGE** se ha personado como parte perjudicada.

c) desde el 14 de diciembre de 2022, **ORANGE** ha procedido a suspender cautelarmente la opción que permite a los agentes de punto de venta, (...).

Con estas medidas, **ORANGE** considera que queda acreditado tanto la voluntad en la protección de los derechos de los particulares, como el empleo de un nivel de diligencia adecuado por parte de **ORANGE**, y que es actualizado y revisado periódicamente conforme al estado de la técnica, los costes de aplicación, la naturaleza, el alcance, el contexto y los fines del tratamiento.

Novena: falta de proporcionalidad de la sanción impuesta.

ORANGE manifiesta en este momento que ha demostrado haber actuado con la diligencia debida en la implementación de medidas en los procesos de duplicados de tarjetas SIM, y que en este supuesto los agentes actuaron de manera individual y dolosa rompiendo los estándares y protocolos de la compañía.

En todo caso, entiende que la sanción incluida en el acuerdo de inicio en desproporcionada atendiendo a las circunstancias y contenido de la supuesta infracción, que **ORANGE** niega.

ORANGE quiere manifestar su disconformidad en la interpretación que realiza esta Agencia en relación con los agravantes:

a) la naturaleza, gravedad y duración de la infracción (artículo 83.2.a) RGPD.

ORANGE manifiesta que este agravante se apoya en la posible comisión de operaciones bancarias fraudulentas.

Entiende que no es aceptable jurídicamente utilizar como argumento el uso de las cuentas bancarias, los perjuicios monetarios de las víctimas de los fraudes o el modo en que se llevan a cabo estas operaciones por las entidades financieras para justificar la sanción impuesta a **ORANGE**, en la medida en que las entidades bancarias son las únicas responsables de la seguridad de sus operaciones, tal y como afirma la Autoridad Bancaria Europea, en "Opinion on the implementation of the RTS on SCS anf CSC" puntos 37 y 38, y donde se determina que las credenciales de seguridad utilizadas para realizar la autenticación segura de los usuarios de los servicios de pago son responsabilidad de la entidad gestora de servicios de cuenta.

En relación con el agravante referido a la infracción del artículo 25 RGPD, entiende **ORANGE** que el acuerdo de inicio tiene en cuenta a todos los clientes de **ORANGE** en su totalidad, que viene cifrado en 21 millones de clientes. **ORANGE** quiere manifestar que no todos estos clientes son personas físicas, ni todos solicitan un duplicado de tarjeta SIM, y, por tanto, no pueden ser considerados como potencialmente afectados.

Para hacer esta manifestación cita a las directrices 04/2022 del CEPD y en la que, cuando se menciona a los "interesados" potencialmente afectados, se estaría refiriendo a personas físicas, y en el sentido de interesados implicados, o interesados

que, si bien no han percibido directamente el perjuicio o han sido afectados por sus efectos, se encuentran dentro del supuesto de hecho.

Por ello, **ORANGE** entiende que, en este supuesto de hecho, hay un único implicado que sería la persona que presentado la reclamación.

Además, entiende que las menciones del CEPD sobre interesados implicados no son aplicables al caso de SIM Swapping, provocados por una actuación dolosa y fraudulenta, y especialmente en un supuesto como este, en el que los agentes actuaron de manera dolosa contra los propios sistemas de **ORANGE**.

b) toda infracción anterior cometida por el responsable o encargado del tratamiento (artículo 83.2.e RGPD)

ORANGE manifiesta que la valoración de esta Agencia de las infracciones previas impuestas por la vulneración del artículo 6.1 RGPD no tienen nada que ver con el presente supuesto de hecho.

Además, en términos de tipificación, **ORANGE** tampoco ha tenido una resolución o procedimiento administrativo por la infracción del artículo 25 RGPD.

Por ello, entiende que esta Agencia no puede tener en consideración, como infracciones anteriores, cualquier tipo de infracción, sin hacer distinciones en los tipos y preceptos de la norma, tratando a todos los procedimientos administrativos (que en su mayor parte están recurridos y sin resolución firme en vía judicial) como si se tratara de antecedentes penales.

También quiere reiterar las particularidades que tiene el presente procedimiento sancionador, referido a la comisión de un acto delictivo por parte de los agentes de **ORANGE**, no teniendo lugar la puesta a disposición de datos a terceros no autorizados, ni teniendo lugar ninguna suplantación de identidad de la parte reclamante ante **ORANGE**.

Además, insiste en que se trata de un supuesto aislado, puntual e inédito, y que esta particularidad debe ser tenida en cuenta, y que no puede asimilarse a otros supuestos donde el fraude consistía en un ataque externo, con suplantación de identidad presencial o mediante una llamada o grabación.

c) la vinculación entre la actividad empresarial de la reclamada y el tratamiento de datos personales de clientes o de terceros (artículo 83.2.k RGPD en relación con el artículo 76.2.b) LOPDGDD.)

ORANGE manifiesta que este factor es ambiguo en su valoración para incluirlo como agravante, ya que dicha vinculación no supone una relación directa con la supuesta infracción.

ORANGE entiende que el artículo 83.2.k) exige que dicho agravante sea puesto en relación con el supuesto de hecho concreto y, por tanto, el tratamiento de datos no nace de una intención de la entidad, sino que tiene lugar la comisión de un delito

contra los propios sistemas de **ORANGE**, y que por ello **ORANGE** es parte perjudicada, y por esta razón no cabe interpretar este aspecto como agravante.

d) intencionalidad o negligencia en la infracción.

ORANGE manifiesta que esta Agencia no relaciona este agravante, ni señala su aplicación al presente supuesto de hecho.

De este modo, entiende que, según ha manifestado el TJUE cuando manifestaba que la imposición de sanciones coercitivas por la autoridad administrativa solo es admisible en los casos en los que se aprecie una conducta culpable por el responsable o encargado del tratamiento, la imposición de este agravante debe estar reservado a los casos en los que la intencionalidad o negligencia sea evidente o grave.

Por ello, en este caso, en el que el supuesto viene causado por un acto delictivo no imputable a **ORANGE**, entiende que no debería imputarse este agravante sin razonamiento alguno al respecto.

Por otro lado, **ORANGE** entiende que sí deberían haberse tenido en cuenta las siguientes atenuantes:

-la parte reclamada procedió a bloquear la línea en cuanto tuvo conocimiento de los hechos. (art. 83.2.c)

-no se han tratado categorías especiales de datos (art. 83.2.g)

-el grado de cooperación de **ORANGE** con la AEPD. De este modo, **ORANGE** quiere manifestar que ha quedado acreditado que se ha contestado en tiempo y forma a todos los requerimientos de información solicitados, con el fin de poner remedio a una supuesta infracción y mitigar sus posibles efectos adversos (art. 83.2.f)

-la adhesión a códigos de conducta en virtud del artículo 40 o mecanismos de certificación aprobados con arreglo al artículo 42 (art. 83.2.j)

ORANGE aporta como documento nº 15 un certificado emitido por AENOR, por el que se acredita que **ORANGE** tiene aprobado desde el 4 de septiembre de 2023 un sistema de cumplimiento normativo que cumple con los requisitos del artículo 31 bis del Código Penal, así como el resto de estándares de cumplimiento e materia de prevención de delitos, como la Circular 1/2016, de 22 de enero, de la Fiscalía General del Estado, destinado a la mitigación de cualquier riesgo de comisión de delitos en el marco de la actuación de **ORANGE**.

-el inexistente beneficio obtenido por **ORANGE** en el tratamiento de los datos que ocupa este procedimiento sancionador, añadiendo que, en todo caso, sería perjudicada, como ya se ha señalado, siendo parte perjudicada en el procedimiento penal en el que se denuncia la comisión del delito que nos ocupa (83.2.k)

Por último, **ORANGE** quiere dejar constancia y demostrar que las medidas vigentes en el momento de la presunta infracción cumplían con las más rigurosas normas, pautas, estándares y recomendaciones para poder hacer frente a los riesgos, y que eran

adecuadas e idóneas teniendo en cuenta el estado de la técnica, los costes de aplicación y la naturaleza, alcance, contexto, fines del tratamiento, y los riesgos para los derechos y libertades de las personas físicas.

Para finalizar solicita el archivo del presente procedimiento, y subsidiariamente, que se tenga en cuenta las circunstancias atenuantes y finalice el procedimiento con un apercibimiento, o que si considera que procede la imposición de una sanción, que modere o module la propuesta recogida en el acuerdo de inicio.

DÉCIMO: Con fecha 21 de junio de 2024 se formuló propuesta de resolución, proponiendo que por la Directora de la Agencia Española de Protección de Datos se sancione a **ORANGE ESPAGNE, S.A.U.**, con NIF **A82009812**,

-por una infracción del Artículo 6 del RGPD, tipificada en el artículo 83.5.a) de dicha norma, multa administrativa de cuantía 200.000 euros (doscientos mil euros).

- por una infracción del Artículo 25 del RGPD, tipificada en el artículo 83.4 de dicha norma, multa administrativa de cuantía 1.000.000 euros (un millón de euros).

Que por la Directora de la Agencia Española de Protección de Datos se ordene a **ORANGE ESPAGNE, S.A.U.**, con NIF **A82009812**, que en virtud del artículo 58.2.d) del RGPD, en el plazo de 6 meses, notifique a esta Agencia las medidas que ha adoptado para garantizar que la solicitud de duplicado se presenta por el titular de la línea, sea cual sea el procedimiento utilizado para su emisión.

Esta propuesta de resolución, que se notificó a **ORANGE** conforme a las normas establecidas en la LPACAP, fue recogido en fecha 25 de junio de 2023, como consta en el acuse de recibo que obra en el expediente.

DÉCIMO PRIMERO: Con fecha 26 de junio de 2024 tiene entrada en esta Agencia un escrito de **ORANGE** mediante el que solicita ampliación de plazo para presentar alegaciones a la propuesta de resolución, a lo que se accede en fecha 28 de junio de 2024.

DÉCIMO SEGUNDO: Con fecha 17 de julio de 2024 se recibe en esta Agencia, en tiempo y forma, escrito de **ORANGE** en el que aduce alegaciones a la propuesta de resolución. En estas alegaciones, en síntesis, manifestaba:

ORANGE se reitera en las alegaciones presentadas al acuerdo de inicio. además, quiere manifestar:

Primera. - De la existencia de prejudicialidad penal.

ORANGE manifiesta su disconformidad con lo expresado por esta AEPD en lo referente a esta cuestión. De este modo, manifiesta que el sujeto que ha cometido la infracción han sido los Agentes contratados por la distribuidora de la marca **ORANGE**.

Añade que esto es especialmente relevante, porque dependiendo de lo que se determine con respecto a la actuación de los agentes y el tipo delictivo que se les aplique se condicionará la potencial imputabilidad de responsabilidad a **ORANGE**.

Con respecto al hecho, manifiesta que es evidente la coincidencia.

Y con respecto al fundamento, manifiesta que existe una incompatibilidad entre la imposición de una multa administrativa a **ORANGE** derivada de una actuación delictiva de la que es víctima.

Añade que la AEPD pretende que **ORANGE** responda administrativamente de un ilícito penal cometido por Agentes de sus distribuidoras, por el mero hecho de que el delito se lleva a cabo manipulando dolosamente el funcionamiento de su sistema. De este modo, señala que la distribuidora es una empresa franquiciada, perteneciente al canal de distribución, ajena a **ORANGE**, que actúa como encargada del tratamiento y el ilícito cometido se realiza por personal laboral de dicha franquicia, en contra de las instrucciones documentadas por mi representada.

ORANGE añade que esta AEPD debe asumir que la conducta de los agentes es constitutiva de infracción penal

Segunda. Sobre el supuesto de hecho.

2.1. Sobre la consideración de la SIM como dato personal.

ORANGE manifiesta que esta Agencia interpreta que la tarjeta SIM no solo contiene, sino que es un dato personal en sí misma.

Asimismo, insiste en que no consta que se haya tratado información alguna que pudiera estar contenida en la tarjeta SIM.

Añade que un duplicado de tarjeta SIM implica la emisión de una tarjeta SIM vacía, que no permitiría per se el acceso a información bancaria o financiera.

Respecto al IMSI, se trataría de un código contenido dentro de la tarjeta SIM con una finalidad técnica, y que no está directamente accesible. Además, no consta evidencia de que este dato haya sido accedido por los Agentes en la comisión del delito.

A este respecto, **ORANGE** añade que, aunque pudiera considerarse que esta información hace potencialmente identificable al titular de la línea, la posibilidad de identificación por parte de terceros distintos de la operadora requeriría información adicional a la que no tienen acceso.

2.2. Sobre la realización de operaciones bancarias.

ORANGE considera que esta Agencia utiliza estas asociaciones para agravar el supuesto de hecho origen de este procedimiento sancionador, otorgando al duplicado de tarjeta SIM la facultad de permitir la comisión de operaciones bancarias, obviando un paso previo donde los criminales deberán obtener y utilizar las credenciales bancarias, para identificarse y realizar la suplantación de identidad ante la entidad financiera.

Insiste en que esta Agencia no entra a analizar la responsabilidad de las entidades bancarias afectadas por la suplantación de identidad.

Además, entiende **ORANGE** que, desde esta Agencia se realiza una transferencia de responsabilidad de una operación bancaria hacia **ORANGE**, calificando como idénticas las obligaciones de las operadoras y las de las entidades bancarias.

ORANGE en su escrito de alegaciones a la propuesta de resolución aporta manifestaciones en las que quiere mostrar su disconformidad con el hecho de que no se haya iniciado ninguna acción para que las entidades bancarias informen acerca del funcionamiento de sus sistemas.

Prosigue manifestando que cabe preguntarse por qué los bancos implementaron en el año 2019 un sistema de autenticación reforzado considerado como inseguro, contraviniendo el artículo 32 del RGPD y porque aún no se ha solicitado información al respecto.

Insiste en que esta Agencia realiza una transferencia de responsabilidad de una operación bancaria hacia **ORANGE**, calificando como idénticas las obligaciones de modo injustificado. Menciona en este punto pronunciamientos de la Autoridad Bancaria Europea, que harían referencia a que las entidades bancarias son las únicas responsables de la seguridad de sus operaciones.

Añade que no se puede responsabilizar a **ORANGE** de la configuración del envío de SMS como segundo factor de autenticación empleado por los responsables de otros servicios como son los operadores bancarios. En este sentido, menciona la Sentencia 142/2024, de 21 de marzo de 2024 de la Audiencia Provincial de Oviedo, en el que la víctima había clicado en un enlace remitido a través de un SMS, produciéndose un acceso no autorizado a su área de cliente, y realizándose una transferencia de 6.000 euros desde la cuenta bancaria, y en el que la Audiencia Provincial reiteraba la culpabilidad de la entidad bancaria.

2.3. Sobre la relación de los autores del hecho delictivo con **ORANGE**

ORANGE manifiesta que los agentes son empleados de un distribuidor de la marca **ORANGE**, que ostenta el rol de Encargado del Tratamiento según lo dispuesto en el artículo 28 del RGPD. Añade que es el encargado del tratamiento quien debe, al actuar por cuenta de **ORANGE**, disponer de los medios correspondientes que permitan detectar y prevenir actuaciones dolosas de sus empleados. En este punto se remiten a la legislación laboral, manifestando que, en virtud del artículo 20, apartados 2 y 3 del Estatuto de los Trabajadores, la potestad de control recae sobre el empresario del que depende el empleado, y por tanto, en este caso, dependería de la distribuidora de la marca **ORANGE**.

ORANGE hace referencia a que esta AEPD habría aludido a la posibilidad de que **ORANGE** pudiera establecer medidas de control sobre los empleados de su franquiciada.

ORANGE añade que, en virtud de lo dispuesto en el Estatuto de los Trabajadores, es la distribuidora la que debe establecer las medidas de control y no la propia **ORANGE**.

Y, por último, pone de manifiesto que no puede aducirse que se haya producido un incumplimiento del artículo 6 por parte de **ORANGE** ya que, la conducta dolosa corresponde a los empleados del tratamiento, quienes, contrariamente a lo dispuesto en el artículo 28 del RGPD no han seguido las instrucciones del responsable del tratamiento.

Por tanto, entiende que la responsabilidad en la comisión de la infracción del artículo 6 del RGPD debería recaer en el encargado del tratamiento.

Tercera. Sobre la actuación delictiva de los agentes.

ORANGE manifiesta que esta AEPD hace un análisis simplista de la problemática relacionada con el SIM SWAPPING, y que no se puede pretender que la existencia de un tipo de infracciones de esta categoría implique que pueda preverse y evitarse cualquiera de las formas en las que la delincuencia organizada pueda intentar llevar a cabo esta tipología de acciones.

ORANGE insiste en que la actividad delictiva evoluciona y ello obliga a adoptar medidas que no eran previsibles de forma previa.

De este modo, en el caso que ha motivado la apertura de este procedimiento sancionador, **ORANGE** manifiesta que se trata de una variante delictiva nueva, que implica que quien debe cumplir un rol de garante de la seguridad, no solo no cumple con su función de forma adecuada, sino que ataca de forma intencionada dicha seguridad, no tratándose de la amenaza previamente detectada.

ORANGE manifiesta que esta Agencia sanciona el mero hecho de que se produzca un supuesto de fraude SIM SWAPPING, sin atender ni analizar la tipología del fraude cometido en el concreto supuesto de hecho, el perjuicio ocasionado, ni las responsabilidades derivadas, sino que, independientemente de lo anterior, y sin tener en cuenta la diligencia desplegada por **ORANGE** en su actuación y continua adopción de medidas de seguridad, se concluye la existencia de una vulneración de la normativa de protección de datos, por el mero hecho de haber sido víctima de una actividad delictiva.

ORANGE quiere recordar que, como consecuencia de las medidas y procedimientos de seguridad diligente que ha implantado, los delincuentes han ido modificando sus técnicas criminales, lo que constituiría una prueba de que existe un procedimiento de solicitud de duplicados SIM de **ORANGE** que ha sido diseñado teniendo en cuenta la privacidad, y que conlleva un despliegue de medidas de seguridad adecuados.

Asimismo, añade que la aparición de estas prácticas ya se había puesto de manifiesto en el “Comité Antifraude Teleco” celebrado en el mes de marzo de 2023, unos meses después de que la comisión del presente supuesto de hecho, confirmándose que en los meses previos se detectaron ataques para captar a comerciales en puntos de venta.

Añade que como consecuencia de la posibilidad de que los Agentes de tienda sean corrompidos y puedan ejercer actividades delictivas como las que se han producido,

ha realizado una nueva evaluación del riesgo atribuido a esta amenaza, y aporta como Documento nº 1 dicha valoración.

Además, insiste en que no puede interpretarse que permitir a un agente de tienda tomar decisiones sobre algunas cuestiones operativas puede asimilarse al incumplimiento del RGPD. Manifiesta que, como ya se ha informado, se ha paralizado la intervención manual de los agentes, pero quiere señalar que se trata de una medida preventiva mientras determina las más idóneas para mitigar el riesgo asociado a esta amenaza, ya que esta medida impacta considerablemente y de forma negativa en la experiencia del usuario, no es sostenible económicamente y no es defendible jurídicamente.

Insiste en que la interpretación tan restrictiva en relación con la intervención de un empleado para tomar decisiones choca con la regulación del RGPD que, al contrario de lo pretendido por la AEPD, considera que el riesgo reside en la adopción de decisiones automatizadas sin intervención humana.

Añade que la finalidad de la intervención del agente es evitar que, en supuestos específicos y debidamente tasados, un potencial error del sistema impida al interesado el acceso a un servicio contratado, permitiéndose la validación del agente.

Sin embargo, **ORANGE** considera que esta AEPD categoriza la parametrización de un procedimiento manual para ciertas situaciones como una vulneración del artículo 25 del RGPD desde la óptica de la privacidad y en atención a las manifestaciones de esta Agencia para frenar la posibilidad de que se produzca una suplantación de identidad en duplicados de tarjeta SIM.

ORANGE insiste en que tiene diseñados procedimientos internos, teniendo en cuenta la privacidad, que sirven para determinar los medios del tratamiento y que se aplican de manera efectiva.

Entiende que lo que ha permitido la comisión del fraude SIM SWAPPING no ha sido la flexibilidad tasada y controlada del procedimiento por **ORANGE**, necesaria para supuestos tasados y bajo garantías adecuadas, sino la comisión deliberada de una acción ilícita y dolosa por parte de los agentes contratados por el encargado del tratamiento de **ORANGE**.

ORANGE menciona en este punto el Auto 35/2023 de la Sala de lo Penal Sección 3ª de la Audiencia Nacional, de 30 de enero de 2023, que desestima un recurso de apelación formulado por el Ministerio Fiscal, confirmando el sobreseimiento y archivo de la pieza de investigación respecto de la responsabilidad de dos personas jurídicas. En su fundamento Jurídico 2º, con relación a los modelos de prevención de delitos y responsabilidad asociada de la persona jurídica específica:

“SEGUNDO. – Rechazamos los motivos de recurso alegados por el Ministerio Fiscal, aceptando y dando por reproducidos los razonamientos del auto recurrido y la jurisprudencia citada sobre la responsabilidad penal de las personas jurídicas en el auto de 29.07.2021, al que en algunos aspectos se remite el de 02.06.2022.

En el momento en que se produjeron las contrataciones con (...) a que se refiere este procedimiento, (...) contaba con un Modelo de Prevención de delitos que cumplía con los requisitos previstos en el artículo 31 bis CP. Ningún modelo es infalible, y si un delito se comete por alguno de los sujetos que contempla el precepto citado, no implica necesariamente que el modelo de prevención de delitos adoptado por la persona jurídica sea inadecuado, incumpla la normativa vigente o falle, pues bastaría con adoptar un modelo que cumpliera todas las normas para impedir la comisión de delitos, lo que no se ajusta a la realidad y precisamente por eso los modelos de prevención de delitos están sujetos a revisiones periódicas”.

Con esto, **ORANGE** quiere manifestar que los Tribunales vienen reconociendo que cuando un delito se comete en el seno de una persona jurídica, no determina de forma automática, culpabilidad o una falta de diligencia de ésta. Y añade que ha acreditado documentalmente la implantación de medidas concretas y adecuadas, así como de un procedimiento securizado de duplicados de tarjeta SIM, entendiendo así que no se habría producido una actuación negligente por su parte.

Cuarta. De la inexistencia de falta de legitimación en el tratamiento de datos personales de ORANGE.

ORANGE quiere manifestar que los hechos se produjeron por empleados de uno de sus encargados de tratamiento.

Por ello, cuando en la propuesta de resolución se afirma *“En relación con esta cuestión, es necesario señala que no es objeto del presente procedimiento sancionador el proceder de los empleados de ORANGE, sino que más bien se trata de comprobar si la actuación de ORANGE cumple con la normativa de protección de datos personales”* **ORANGE** entiende que esta Agencia reconoce expresamente que pretende responsabilizar a **ORANGE** del proceder de estos agentes, sin importar que este proceder constituye un ilícito penal.

ORANGE entiende que este planteamiento es incoherente, en la medida en que se estaría obviando que una empresa actúa a través de personas, y lo que se está enjuiciando es precisamente si la actuación de una persona ajena a la organización, de forma contraria a las instrucciones de **ORANGE** y manifiestamente dirigida a provocarle un daño.

ORANGE entiende que la emisión de un duplicado fraudulento de manera dolosa por los Agentes no constituiría una acción imputable a la mercantil, en la medida en que los agentes empleados por el distribuidor de **ORANGE** buscaban cometer un delito. Entiende que esta actuación no es asignable a **ORANGE**, ya que supondría atribuirle una acción delictiva dirigida contra sí misma.

ORANGE se reafirma en que los hechos producidos en este supuesto son los que deben analizarse para identificar una posible vulneración de la normativa, y no potenciales infracciones. Añade que los hechos sobre los que se fundamenta esta posible vulneración de la normativa tienen que ser hechos probados y ciertos, y entiende que no es cierto que el duplicado de la tarjeta SIM lo hiciera un empleado de **ORANGE**, sino que lo hizo un empleado de una tercera empresa, ajena a **ORANGE**, que actuaba como encargado del tratamiento.

De este modo, no cabe atribuir a **ORANGE** una falta de legitimación en el tratamiento de datos personales por parte de **ORANGE**, porque lo que ocurrió, es que a través de sus sistemas **ORANGE** se limitó a realizar un proceso de tramitación de una solicitud de duplicado de tarjeta SIM, sin que tuviera capacidad de reconocer que el origen de dicha solicitud derivaba de una actuación ilícita de los agentes de la tienda, que solo deben iniciar el proceso a demanda de los clientes, y cuya función es precisamente velar por el cumplimiento del proceso en su integridad, conforma a las instrucciones recibidas y bajo las medidas de seguridad y garantía de verificación de identidad ordenadas por **ORANGE**.

Adicionalmente, en el presente caso, durante el proceso de duplicado los datos personales fueron insertados por los agentes, y no por **ORANGE**, desconociéndose el origen de estos. Insiste en que no es posible considerar a la tarjeta SIM como un dato personal, ni ha sido justificado por esta Agencia. Y que, en el caso de que pudiera mantenerse tal consideración, el tratamiento de datos no sería achacable a **ORANGE**, sino que se habría realizado por un delincuente que trabajaba para un encargado del tratamiento de **ORANGE**, actuando en contra de las instrucciones e intereses de **ORANGE**. Quiere recordar que los agentes no accedieron al teléfono móvil de la parte reclamante, ni a la información que pueda contener, en tanto en cuanto el teléfono móvil estuvo en posesión de la parte reclamante.

ORANGE insiste en que la tarjeta SIM no contiene los datos del teléfono móvil, y que un duplicado de la tarjeta SIM no permite a un tercero el acceso a las aplicaciones del titular.

Por tanto, no cabría afirmar que se haya producido un tratamiento ilegítimo de los datos de la parte reclamante por parte de **ORANGE**, por ausencia de dolo o culpa, y, por tanto, no habría infracción del artículo 6.1 del RGPD.

Quinto. De la correcta implementación de la privacidad desde el diseño y por defecto.

ORANGE quiere manifestar que, en base a las manifestaciones recogidas en la propuesta de resolución, sí se habría tenido en cuenta la privacidad desde el diseño, en función de la documentación remitida, el diseño de protocolos y el establecimiento de medidas en aras a garantizar el cumplimiento de los principios de protección de datos.

En este sentido, el proceso para la emisión de duplicados de tarjeta SIM lleva aparejados unos controles y medidas de seguridad destinadas a garantizar que las SIM sean emitidas a solicitud de los clientes y una vez verificada su identidad, habiéndose tenido en cuenta la protección de la privacidad de los interesados.

Sin embargo, **ORANGE** considera que esta Agencia trata de descalificar la prueba documental bajo la única premisa del resultado que se ha producido en un supuesto concreto, en la que media la comisión de un delito, para poner en duda la validez del sistema, infiriendo que el conjunto de las medidas implantadas no es conforme al principio de privacidad desde el diseño, como si su cumplimiento dependiese, exclusivamente, de que fuese perfecto e infalible, y haciendo observaciones subjetivas.

En este punto enumera lo que se ha mencionado en la propuesta de resolución con respecto a los documentos 5, 6 y 7.

Añade que **ORANGE** si dispone de políticas encaminadas a garantizar la aplicación de los principios de protección de datos en sus procesos de negocio, independientemente de que no se identifique en cada uno de ellos la referencia específica a las garantías en materia de privacidad, ya que, si bien abordan los riesgos asociados en esta materia, no es la única que se tiene en cuenta, del mismo modo que no se especifican en cada uno de ellos los riesgos penales analizados, o los riesgos económicos o los reputacionales.

Asimismo, manifiesta que no hay una contraposición entre los intereses de la compañía y la protección de datos personales, y que la privacidad desde el diseño está garantizada en todos los casos, no solo desde un punto de vista formal, sino como un propósito inherente a su actividad diaria.

En este sentido, habría proporcionado la información inicial que se facilita para cualquier proyecto en el que se traten datos personales en aras a comenzar a regular las distintas actividades siempre desde una perspectiva que vele por la privacidad y la protección de datos personales. Sin embargo, para cada caso particular se aplican las medidas que se consideren correspondientes, como puede ser la formación de personal encargado de controlar los procesos.

Además, quiere recordar que tanto las medidas técnicas y organizativas como las garantías previstas por el artículo 25 del RGPD no están tasadas, ni exigen la implantación de medidas concretas.

5.1. Sobre el análisis de riesgos para los derechos y libertades.

En este punto, **ORANGE** manifiesta que ya se aportó como documento nº 12, en las alegaciones al acuerdo de inicio, y que fue valorado por esta Agencia, en la propuesta de resolución.

Por ello, **ORANGE** manifiesta que no se puede negar desde esta Agencia que no se tuviera identificado el riesgo, si bien se presenta por el Comité de Riesgos agregando lo aportado por diversas áreas.

Además, insiste en que la consideración de dicho nivel de riesgo no se realizó en el año 2023, sino que también se hizo en los años 2021 y 2022, aportando para acreditarlo el Documento Anexo 1, relativo al comité de riesgos, que tuvo lugar en el año 2022, y donde se puede visualizar:

- el nivel de riesgos agregado para el riesgo “Fraudulent use of Data-3rd parties” era bajo.
- se proporciona una segunda diapositiva con la comparativa con el año anterior, donde ese riesgo ya fue evaluado concluyéndose que era bajo.

Añade que esta misma información para el año 2023 se aportó como documento nº 12, para resaltar que se trata del mismo análisis en años diferentes, y en todos se calificó como bajo.

Aportan como documento anexo 2 el Acta del comité de Riesgos Local del año 2022 para evidenciar que el riesgo era también calificado como bajo.

Desde el punto de vista del riesgo desde la óptica de los derechos y libertades de los interesados, aportan como Documento Anexo 3 el Análisis de Riesgos para los Derechos y libertades de los interesados del riesgo correspondiente al año 2022, cuando acontecieron los hechos, donde se identificaba el riesgo como bajo, y que, según manifiesta **ORANGE**, fue elevado al Comité de Riesgos

ORANGE insiste en que, en el marco de probabilidad de materialización del riesgo era improbable, porque no había constancia de materialización del mismo en **ORANGE**, con la apertura de este procedimiento sancionador el riesgo pasó a calificarse como medio, y en la actualidad se encuentra calificado como alto, y se trata con nuevas medidas para volver a reducir el riesgo.

Por ello quiere manifestar que es incorrecto afirmar que este tipo de riesgo no ha sido objeto de análisis por parte de **ORANGE**. Y la evolución de la consideración de este tipo de riesgo ha ido incrementándose en fechas recientes, debido a la detección del primer caso de este tipo que se correspondería con este procedimiento.

ORANGE quiere manifestar que esto no significa que actúe de manera correctiva y no preventiva, sino que el riesgo se había calificado como bajo, y, por lo tanto, no se había considerado necesario implantar medidas adicionales a las ya existentes, dado que su efectividad venía avalada por la inexistencia de contingencias relacionadas con las gestiones realizadas por los agentes en las que se hiciese un uso inadecuado de sus credenciales y permisos con fines ilícitos. Añade que este sigue siendo un incidente aislado.

Añade que se pueden identificar medidas preventivas que esta Agencia no tuvo en cuenta en la propuesta de resolución y que son:

-medidas jurídicas: contrato con el franquiciado que incluye un compromiso de confidencialidad.

-medidas organizativas.

-comunicación de instrucciones, como la píldora informativa proporcionada a los Agentes de **ORANGE**.

-Control de acceso y registro de acciones ejecutadas por los usuarios.

-protocolo de gestión de errores.

ORANGE insiste en que el riesgo estaba identificado, había sido evaluado y se habían implementado medidas proporcionales para su mitigación, partiendo de que el riesgo era bajo, en consonancia con las directrices del EDPB.

De este modo, en consonancia con el riesgo identificado, en relación con el duplicado de la tarjeta SIM se elaboró el procedimiento ya analizado en el presente procedimiento sancionador, y, en prevención de posibles circunstancias en las que el (...).

En el caso que nos ocupa, prosigue **ORANGE**, no se produjo un fallo en las medidas de seguridad, sino que el personal encargado de ejecutar el proceso decide atentar contra el mismo. Por tanto, insiste en que esta Agencia no puede equiparar la comisión de un delito por parte de agentes de la propia mercantil con una supuesta carencia de la implementación de la privacidad desde el diseño de esta compañía.

ORANGE insiste en que esta Agencia no tiene en cuenta esta situación en la propuesta de resolución.

Además, **ORANGE** añade que, en el caso de un duplicado de tarjeta SIM, existen dos riesgos contrapuestos:

- falsos positivos, situación en la que un tercero malicioso ha solicitado el duplicado de la tarjeta SIM

- falso negativo, un documento de identidad válido que es rechazado, y en la que el cliente pierde el acceso a su servicio telefónico móvil.

Por tanto, añade **ORANGE**, el análisis de riesgos en el que se ponderó establecer esta medida, no se fundamentaba únicamente en el negocio, como manifestaba esta Agencia, sino que ponderó los dos riesgos antes citados, decidiéndose esta medida desde la privacidad desde el diseño.

ORANGE hace referencia en este punto al EDPB que ha considerado, en sus directrices 5/2022 sobre el uso de tecnología de reconocimiento facial en el ámbito de aplicación de la ley, a la agilidad en la gestión como uno con impacto positivo para los propios interesados, debiendo ser tenido en consideración.

Manifiesta su disconformidad con la afirmación que se realiza en la propuesta referida a que no se había previsto el riesgo, porque ya se ha manifestado que sí se había catalogado como un riesgo bajo, y, además, había una comprobación visual y presencial por el propio agente, y además hay un control posterior por el Grupo de Análisis y Riesgos de la compañía para evaluar si se estaba haciendo un uso inadecuado de esta posibilidad.

ORANGE manifiesta que, por más controles que se establezcan, nunca es completamente evitable que un usuario malintencionado pueda realizar una acción ilícita con respecto a la información a la que tiene acceso.

ORANGE manifiesta su disconformidad con el hecho de que un suceso aislado pueda tener entidad suficiente para decretar sin más el incumplimiento general del principio de privacidad por diseño y por defecto de la compañía, y justificar la sanción. Manifiesta que se trata de un precepto genérico y ambiguo, que no supondría el incumplimiento de ninguna obligación concreta, e insiste en que no haber considerado

una amenaza no puede invalidar todo el sistema de cumplimiento normativo implantado.

Por último, quiere manifestar que, en relación con la “suspensión” del procedimiento para la emisión de duplicados de tarjeta SIM, ésta debe entenderse como un cambio en la configuración del proceso que se genera (...), y que se ha producido de manera cautelar hasta que concluya este procedimiento para que no condicionase el desarrollo de éste.

En este sentido, se está realizando una prueba de peritaje para evaluar la herramienta, que se aportará con posterioridad, cosa que no se ha producido.

Sexta. Sobre la existencia de un concurso de infracciones.

ORANGE manifiesta que las dos infracciones tienen como base la conducta delictiva de los agentes, lo cual constituye un supuesto de concurrencia de infracciones en vía administrativa.

En este sentido, **ORANGE** entiende que lo decisivo para determinar si efectivamente se ha producido este incumplimiento es la adecuación o no de las medidas implementadas. Manifiesta que, según lo argumentado por esta Agencia, se extraería que existe una conexión directa entre las vulneraciones de ambos artículos. Considera que, la infracción del artículo 6 del RGPD, esto es, la existencia de un (supuesto) tratamiento de datos ilícito fue necesaria e inevitable para que tuviera lugar una vulneración del principio de privacidad desde el diseño y por defecto, derivada de no existir (indicado en términos de defensa, supuestamente) medidas de seguridad suficientes.

Séptima. Sobre la inadmisibilidad de la responsabilidad objetiva.

ORANGE insiste en que la propuesta de resolución se basa exclusivamente en el resultado, sin tener en cuenta que el hecho se produce por la actuación delictiva y dolosa de los agentes de la distribuidora de **ORANGE**, que actuaba en calidad de encargado del tratamiento, corrompiendo el proceso y las medidas estipuladas por ésta.

ORANGE entiende que la actuación delictiva de los agentes ha determinado de manera automática que no se adoptaron medidas adecuadas, surgiendo automáticamente la responsabilidad directa de **ORANGE**.

Además, entiende que esta Agencia ha determinado que se ha producido una tipología genérica de fraude sin entrar a valorar las circunstancias específicas de este caso.

Entiende **ORANGE** que esta Agencia ha errado al tener en cuenta las siguientes consideraciones:

-en primer lugar, los delincuentes eran agentes comerciales de un punto de venta de un distribuidor, y no ciberdelincuentes. (pag 77 de la propuesta de resolución)

-en segundo lugar, esta Agencia no tienen en cuenta la evolución del fraude SIM SWAPPING, considerando que, ante la producción de un supuesto fraude, la entidad resulta responsable, con independencia de la actuación de los agentes del punto de venta.

Insiste en que tenían identificado el riesgo, pero estaba considerado como de bajo riesgo, puesto que no se había producido con anterioridad.

ORANGE considera que, respecto a la normativa de servicios de pagos, se estaría calificando como idénticas las obligaciones tanto para las operadoras como para las entidades bancarias de un modo injustificado, ya que **ORANGE** no puede responder de las deficiencias y decisiones tomadas por los bancos.

ORANGE manifiesta que, según esta Agencia, los riesgos deben basarse en aquello que es razonable y técnicamente posible, y considera que, en este caso, **ORANGE** había depositado su confianza en sus distribuidores. Considera además que la intervención humana resulta inevitable.

Añade que esta Agencia pretende que **ORANGE** prevea todas y cada una de las amenazas que puedan tener lugar, esperando un resultado en que las medidas sean infectibles, pasando por alto amenazas que difícilmente pueden ser previstas, como sería este caso.

Es por ello por lo que entiende que esta Agencia establecería una obligación de resultado, al señalar que la comisión de un acto delictivo en el entorno de **ORANGE** conlleva automáticamente su responsabilidad, con independencia del dolo empleado por el autor, y el nivel de diligencia empleado por **ORANGE**.

ORANGE manifiesta que esta Agencia no ha entrado a valorar la jurisprudencia expuesta con relación a la inadmisión de la responsabilidad objetiva en el ámbito del procedimiento administrativo sancionador.

Por ello, entiende que, al no haberse acreditado la concurrencia de una actuación culpable, intencionada o negligente por parte de **ORANGE**, no procede determinar que ha cometido una infracción de la normativa de protección de datos.

Octava. Sobre las medidas adoptadas e implementadas por ORANGE.

ORANGE considera que ya ha enumerado las medidas que había desplegado, tanto de manera previa, como a posteriori, y procede a enumerarlas nuevamente, para que, desde esta Agencia se pueda apreciar la constante evaluación y análisis de riesgos, así como las medidas aplicadas, que se fueron modificando a medida que se han ido identificando distintas tipologías de fraude SIM SWAPPING:

1. medidas implementadas por **ORANGE** para prevenir la comisión de fraudes derivados de la suplantación de identidad de su cliente.

-documentación ya aportada que se pone a disposición de los agentes y demás personal con capacidad para llevar a cabo actuaciones en **ORANGE**.

-comunicaciones adicionales que reiteran los protocolos de actuación para la emisión de duplicados de tarjeta SIM.

-(...).

-**ORANGE** forma parte de la Asociación Española para la Digitalización y participa en el proyecto “Identidad Digital Segura”, que tiene por objeto, entre otros, proteger frente al fraude y los ciberataques y la defensa de la privacidad de los datos.

-"servicio de SIM Swap" (...).

2. Medidas implementadas por **ORANGE** para prevenir la comisión de fraudes derivados de la suplantación de agentes y/o empleados de **ORANGE**.

-implantación de un doble factor de identificación, que se encontraría en fase de testeo con ciertos usuarios.

-proyecto (...).

-herramientas de control de tráfico, que es utilizada por el Grupo de Análisis de Riesgos de **ORANGE**, y que puede generar alertas en caso de posibles detecciones de contrataciones irregulares, y que funciona de la siguiente manera en el caso de duplicados de tarjeta SIM:

- (...).

-(...).

3. medidas adoptadas con relación al presente supuesto, no recogidas en los apartados anteriores.

-se ha modificado el riesgo asociado a este tipo de supuestos, ostentando un impacto mayor en los protocolos y actuaciones de la compañía.

-se ha suspendido cautelarmente (...) que tiene lugar en los supuestos como el caso que ha motivado la apertura de este procedimiento sancionador, para poder determinar las medidas adecuadas para mitigar los riesgos identificados.

En cualquier caso, **ORANGE** quiere manifestar que lleva a cabo un constante control y revisión de los riesgos existentes en materia de duplicados de tarjeta SIM, que los protocolos se actualizan y que se adoptan medidas acordes a los riesgos identificados, sin que ello permita imponer a las mismas la garantía o exigencia de infalibilidad.

ORANGE manifiesta que esta Agencia no ha revisado este desglose que, entiende que es imprescindible para comprender la amenaza y poder prevenir y mitigar su comisión.

Añade que esta Agencia ha archivado con anterioridad procedimientos relacionados con el SIM Swapping, enumerando alguno de estos procedimientos.

Por ello, **ORANGE** considera que habría quedado acreditado tanto su voluntad de protección de los derechos de los particulares, como el empleo de un nivel de diligencia adecuado, con el que la existencia de un riesgo cero es actualizado y revisado periódicamente conforme al estado de la técnica, los costes de aplicación, la

naturaleza, el alcance, el contexto y los fines del tratamiento, no siendo posible la identificación de una vulneración del artículo 25 del RGPD.

Novena. Sobre la falta de proporcionalidad de la sanción propuesta.

ORANGE manifiesta haber actuado con la diligencia debida en la implementación de medidas en los procesos de duplicados de tarjeta SIM, pero, para el caso de que esta Agencia considere que existe dicho incumplimiento, entiende que la sanción es desproporcionada, atendiendo a las circunstancias y contenido de la infracción, en la medida en que ha sido cometida de manera dolosa por agentes de la distribuidora.

En este sentido, entiende que los siguientes agravantes utilizados por esta Agencia, se ha realizado sin que concurran las circunstancias para su consideración:

-Naturaleza, gravedad y duración de la infracción (art. 83.2.a) RGPD)

ORANGE entiende que este agravante se apoya en la posible comisión de operaciones bancarias fraudulentas, no resultando aceptable que se utilice como argumento para justificar la sanción el uso de las cuentas bancarias, los perjuicios monetarios que han sufrido las víctimas de fraude, o el modo en que se llevan a cabo estas operaciones por las entidades bancarias.

Además, en relación con la imposición del agravante en la infracción del artículo 25 se tiene en consideración a la totalidad de los clientes de **ORANGE**.

ORANGE entiende que no se puede tener en consideración supuestos de hecho no analizados ni documentados, sin que se pueda extrapolar esta comisión de un delito a todos los procesos de duplicados de tarjeta SIM de esta mercantil.

Asimismo, considera que no se puede calificar como agravante la “alarma social” generada para este tipo de prácticas, al tratarse de una actividad delictiva de grupos organizados que captan empleados de empresas de telecomunicaciones.

-toda infracción cometida por el responsable o encargado del tratamiento (art. 83.2.e) RGPD)

ORANGE reitera su disconformidad con el hecho de que se utilice este agravante, ya que los hechos que motivaron dichos procedimientos no tienen nada que ver con el presente supuesto de hecho.

-la vinculación entre la actividad empresarial de la reclamada y el tratamiento de datos personales de clientes o de terceros (art. 83.2.k del RGPD en relación con el artículo 76.2.b) de la LOPDGDD)

ORANGE entiende que, por su actividad, el tratamiento de datos personales es necesario, pero que, según el artículo 83.2.k) este agravante se tendría que aplicar teniendo en cuenta el caso concreto. Así, en ningún caso ha sido voluntad de **ORANGE** que ocurriera este caso, y reitera que la operadora también se ha visto perjudicada. Por eso, entiende que no es posible considerar la aplicación de este agravante.

-intencionalidad o negligencia en la infracción.

ORANGE manifiesta su disconformidad con lo dispuesto en la propuesta en relación con este agravante, en la medida en que se trata de un supuesto inédito causado por la comisión de un hecho delictivo no imputable a **ORANGE**.

Asimismo, considera que esta Agencia no ha tenido en cuenta las siguientes circunstancias atenuantes:

-**ORANGE** procedió a bloquear la línea cuando tuvo conocimiento de los hechos. (art. 83.2.c) RGPD).

Entiende que no se le puede atribuir a **ORANGE** la responsabilidad por las pérdidas económicas que sufrió la parte reclamante.

-no se han tratado categorías especiales de datos (art. 83.2.g)

- el grado de cooperación de **ORANGE** con esta Agencia. (art. 83.2.f)

-la adhesión a códigos de conducta en virtud del artículo 40 o mecanismos de certificación aprobados con arreglo al artículo 42 (art. 83.2.j)

-el inexistente beneficio obtenido por **ORANGE**. (art. 83.2.k), manifestando que, en todo caso, ha resultado perjudicada.

Por último, **ORANGE** quiere dejar constancia y demostrar que las medidas vigentes en el momento de la infracción cumplían con las normas, pautas, estándares y recomendaciones para poder hacer frente a los riesgos, que eran adecuados e idóneos teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como los riesgos para los derechos y libertades de las personas físicas.

Además, quiere trasladar a la Agencia la aceptación de cualquier tipo de propuesta o recomendación en lo relativo al cumplimiento de la normativa.

Por todo ello, solicita el archivo del presente procedimiento, y subsidiariamente que dirija un apercibimiento, y en última instancia que modere o module la propuesta de sanción prevista.

De las actuaciones practicadas en el presente procedimiento y de la documentación obrante en el expediente, han quedado acreditados los siguientes:

HECHOS PROBADOS

PRIMERO: Consta que, en fecha 15 de diciembre de 2022 se realizó un duplicado de la tarjeta SIM titularidad de la parte reclamante, sin que lo hubiera solicitado, en el establecimiento titularidad de “TOWER PHONE, S.L.,” ubicado en la calle *****DIRECCIÓN.1** de Madrid, que actúa como franquicia de **ORANGE**, según consta en el contrato de franquicia de fecha 1 de abril de 2022.

De este modo, en el contrato de franquicia de fecha 1 de abril de 2022 aportado por **ORANGE** con la entidad TOWER PHONE S.L.U., se puede observar:

“*Antecedentes:*

I. Que forma parte de la actividad y objeto social de ORANGE la prestación y comercialización de diversos servicios de telecomunicaciones, comunicaciones electrónicas y para la sociedad de la información.

II. Que ORANGE ESPAGNE S.L.U., en desarrollo de su objeto social comercializa sus servicios y ha implantado su red comercial en el tráfico mercantil bajo las marcas y demás signos distintivos que le son propios o cuyos usos de marca está legitimado a ceder, estando interesada en designar franquiciados, (...)”

(...)

IV. (...).

V. (...).

(...).

Asimismo, en el objeto del contrato se puede observar:

“(...).

(...).”

SEGUNDO: **ORANGE** es la responsable de los tratamientos de datos referidos en el presente procedimiento, toda vez que conforme a la definición del artículo 4.7 del RGPD es quién determina la finalidad y medios de los tratamientos realizados._

En la cláusula Vigésimosegunda, relativa al tratamiento de datos personales, se aprecia:

“En virtud del presente contrato, el FRANQUICIADO en su condición de encargado de tratamiento, llevará a cabo el tratamiento de datos personales necesario para la correcta prestación de los servicios objeto de este contrato.”

TERCERO: Consta que, para solicitar el duplicado de la tarjeta SIM, **ORANGE** tiene implementado un sistema automático de validación del documento de identidad, pero que, en algunos casos (...) de la persona que solicita el duplicado de dicha tarjeta SIM, (...). _

CUARTO: **ORANGE** ha afirmado que, en el momento de la contratación del duplicado de tarjeta SIM de la parte reclamante, *“se siguió el protocolo establecido por esta mercantil pasando un documento de identidad por el sistema de verificación (...)”*.

“(...)”.

En cuanto a la cuestión relativa a si el sistema de (...) comprueba la correspondencia de número de documento y nombre del titular del documento con los datos del solicitante del trámite, (...).

Por ello, por regla general, el sistema (...) sí valida el nombre del titular del documento de identidad con la información del solicitante del trámite, (...).”

QUINTO: (...).

SEXTO: **ORANGE** ha reconocido que el duplicado de la tarjeta SIM de la parte reclamante se había producido por una irregularidad de agentes que trabajaban en la tienda en la que se produjo el duplicado de la tarjeta SIM, (...).

SÉPTIMO: **ORANGE** ha manifestado, en su escrito de fecha 30 de marzo de 2023, que ha dado a sus empleados las siguientes instrucciones acerca de cómo proceder con la utilización del sistema de validación del DNI, y son las siguientes:

- es de obligado cumplimiento no realizar un cambio o duplicado de tarjeta SIM a una persona distinta del titular (o administrador o autorizado de la empresa que conste en sistemas). La persona que vaya a realizar un duplicado deberá aportar un documento válido de identidad (conforme a protocolo), el cual siempre será validado. (...)

- si en el momento de la solicitud no funcionara el sistema, el agente deberá abrir una incidencia y emplazar al cliente a que vuelva al día siguiente.

- el agente que gestione una solicitud de duplicado deberá solicitar la documentación de identidad, (...).

- en los casos en los que el documento de identidad (...).”

OCTAVO: **ORANGE** ha manifestado en su escrito de alegaciones de fecha 21 de diciembre de 2023, que tiene implementadas las siguientes medidas en los supuestos de solicitud de duplicados de tarjeta SIM: _

- Desde el 12 de agosto de 2022 (...).

- Desde el 12 de agosto de 2022 (...).

- Desde abril de 2021, **ORANGE** ha ido limitando los canales desde los cuales se puede solicitar un duplicado de tarjeta SIM (...).

NOVENO: **ORANGE** ha manifestado en su escrito de contestación al traslado de la reclamación, de fecha 30 de enero de 2023, así como en su escrito de contestación al requerimiento, de fecha 30 de marzo de 2023, y de alegaciones al acuerdo de inicio del presente expediente sancionador, de fecha 21 de diciembre de 2023, que habría adoptado las siguientes medidas para prevenir la comisión de fraudes derivados de la suplantación de agentes y/o empleados de **ORANGE**:

- con fecha 28 de diciembre de 2022, y con anterioridad a la notificación del presente requerimiento, se habría dado traslado desde la Escuela de Comerciales a todo el canal de distribución a los puntos de venta una píldora formativa obligatoria con el fin de ayudar y concienciar a los equipos comerciales del riesgo de captar a comerciales para realizar duplicados físicamente desde los puntos de venta.”

-- Se habría impulsado la difusión a todo el canal de distribución de una píldora formativa con el objetivo de concienciar a los trabajadores de la problemática existente y de la obligatoriedad de cumplir con todos los procedimientos y políticas de identificación de clientes.

-Se habría puesto en marcha la implantación de un doble factor de identificación, cuyo proyecto piloto ya se encuentra implantado, estando en fase de testeo.

-se habría puesto en marcha un proyecto (...).

-se habría puesto en marcha una herramienta del Grupo de Análisis de Riesgos, que permite que se generen alertas en caso de posible detección de contrataciones irregulares, y que en el caso de duplicados de tarjeta SIM actuarían de la siguiente manera:

(...).

(...).

- Desde el 14 de diciembre de 2022, según manifiesta **ORANGE** en su escrito de alegaciones al acuerdo de inicio del presente expediente sancionador, habría procedido a la suspensión cautelar de la opción que permite a los agentes de punto de venta, (...), sin poder así atender ningún tipo de excepción.

DÉCIMO: En relación con el supuesto que ha motivado este expediente sancionador, **ORANGE** ha manifestado, en su escrito de alegaciones al presente expediente sancionador de fecha 21 de diciembre de 2023, que habría realizado las siguientes actuaciones:

-Se ha interpuesto una denuncia contra los agentes responsables.

-Los agentes implicados fueron dados de baja del establecimiento.

DÉCIMO PRIMERO: Consta que, en la denuncia presentada por la entidad TOWER PHONE, S.L., en fecha 12 de enero de 2023, se define el concepto de SIM SWAPPING de la siguiente manera:

“El SIM Swapping es un ciberataque que consiste en suplantar la identidad de una persona ante su compañía de servicios telefónicos y pedir un duplicado de la tarjeta SIM de su teléfono móvil para con ello, acudir a su banca online y operar con la misma, recibiendo los SMS con el código de confirmación de operaciones bancarias en esa nueva SIM, procediendo a desviar el dinero de la cuenta corriente de la persona suplantada hacia otra propiedad de los delincuentes.

La víctima, tal y como sucede en el presente supuesto, solo se entera de la situación cuando deja de tener cobertura en su teléfono móvil y por mucho que reinicia el dispositivo o intenta buscar cobertura no lo consigue ya que, al entrar en funcionamiento la nueva SIM duplicada que los ciberdelincuentes piden a la compañía de servicios telefónicos, la SIM que está dentro del teléfono de la víctima deja de funcionar.”

DÉCIMO SEGUNDO: Consta que en la denuncia presentada por TOWER PHONE S.L., se recoge que “se interpone denuncia contra **B.B.B.** con NIE: (...) por posible delito de:

(...)

Asimismo, consta que al hablar del concepto de SIM Swapping se recoge:

*“En primer lugar, es importante explicar en qué consiste los hechos aquí denunciados (SIM Swapping) llevados a cabo por el denunciado **C.C.C.** en, al menos, los días 14, 17 y 21 de diciembre de 2022 en su centro de trabajo, el punto de venta Orange ubicado en el (...) de Madrid (*****DIRECCIÓN.2**)”*

(...)

En el apartado cuarto de la denuncia, relativo a los Hechos denunciados recoge:

“En fechas recientes, mi representada ha tenido conocimiento de los hechos que pasamos a detallar a continuación, los cuales, han sido debidamente verificados y contrastados con los respectivos departamentos internos de la empresa, por medio de la emisión de informe y achacados al denunciado.

Se adjunta Informe Investigación interno con sus documentos adjuntos elaborado y suscrito por el Responsable de tienda situada en *****DIRECCIÓN.1** Madrid, propiedad de Tower Phone, S.L., (...). Dichos anexos del informe de investigación interna son los siguientes:

Anexo 1: documentación justificativa horario laboral de **B.B.B.** en fecha 6 de octubre de 2022 (primera suplantación).

Anexo 2: documentación justificativa horario laboral de **B.B.B.** en fecha 7 de octubre de 2022 (segunda suplantación).

Anexo 3: documentación justificativa horario laboral de **B.B.B.** en fecha 13 de octubre de 2022 (tercera suplantación)

Anexo 4: documentación justificativa horario laboral de **B.B.B.** en fecha 3 de noviembre de 2022 (cuarta suplantación)

Anexo 5: documentación justificativa horario laboral de **B.B.B.** en fecha 15 de noviembre de 2022 (quinta suplantación)

EN PRIMER LUGAR, mi representado tuvo conocimiento de los hechos aquí denunciados por primera vez en fecha 20 de octubre de 2022, cuando acude a la tienda ORANGE sita en *****DIRECCIÓN.1** de Madrid (...) alertando que hace unos días vino a la tienda y que el mismo día le llamaron supuestamente de ORANGE. La consulta en la tienda se trataba de una factura impagada, y la llamada correspondía con la visita a la tienda y la factura impagada para cobrársela por tarjeta bancaria. Tras varios intentos fallidos con su tarjeta se puso en contacto con la clienta un chico (...) y le comentó que al ser paisanos era una estafa, que no hiciese caso, y que esas informaciones de clientes las recibían a través de las tiendas. Ya desde el primer momento, la clienta acusó directamente a **B.B.B.** (...) a lo cual se manda un correo a la supervisora para que tuvieran constancia de estos fraudes. (...)

(...)

EN SEGUNDO LUGAR, en fecha 16 de noviembre de 2022, llaman al responsable de la tienda de ORANGE (situado en la *****DIRECCIÓN.1**), desde la tienda de ORANGE de *****LOCALIDAD.1**, Madrid, indicando que el pasado día 15 de noviembre de 2022 a las 20:45 horas se había realizado un duplicado de tarjeta a la clienta **A.A.A.** utilizando el código del punto de venta correspondiente a la tienda ORANGE sita en *****DIRECCIÓN.1** de Madrid.

Ante dichos hechos, el responsable de la tienda ORANGE de *****DIRECCIÓN.1** pregunta al personal de tienda si habían realizado un cambio de tarjeta SIM el día anterior ya que en nuestro sistema de facturación no aparecía como facturado y se comprobó que la tarjeta SIM que se había utilizado estaba en el stock de la tienda. El personal comentó que no lo habían realizado y no tenían constancia. Al tener cámaras en la tienda se revisa el video del día de los hechos (15 de noviembre de 2023) donde se observa que a la hora donde se realizaba el duplicado de tarjeta se encuentran trabajando (...) y **B.B.B.** está en el ordenador de la caja al parecer hablando por teléfono con un auricular.

(...)

Dada la gravedad de los hechos, se remite ese mismo día toda la información a la supervisora de ORANGE y se manda un correo informativo de lo sucedido.

(...)

Posteriormente, en fecha 18 de noviembre, se responde el mismo por parte de la compañía telefónica ORANGE donde se le informa a esta parte de que para dicho trámite se ha utilizado documentación y firma de otra persona (...). Igualmente, se confirma a esta parte que dicha persona acudió a realizar un duplicado de tarjeta el día anterior al del fraude con el trabajador **B.B.B.** en la tienda ORANGE sita *****DIRECCIÓN.1**, y está facturado correctamente.

(...)

Cabe destacar que, al realizar el duplicado de tarjeta, se anula la que actualmente consta en el sistema y se sustituye por una nueva invalidando en mismo momento la tarjeta anterior normalmente se realizan cuando la tarjeta actual por ejemplo no funciona, el cliente ha perdido el teléfono móvil o se lo han robado. EL PROTOCOLO QUE SE TIENE QUE SEGUIR PARA HACER UN DUPLICADO es con el cliente presencial en la tienda y con su documento original y en vigor ya que debemos escanear el documento para su validación y asegurarnos que es el titular de la línea el que realiza el cambio de la tarjeta SIM.

(...)

EN TERCER LUGAR y como consecuencia del fraude anteriormente detallado, esta parte solicita a ORANGE toda la información disponible para poder proceder a suspender o retirar de forma laboral al sospechoso **B.B.B.** de la tienda, y para ello esta parte necesitaba que su departamento de Ciberseguridad asegurara cuantos duplicados desde la tienda de *****DIRECCIÓN.1** se han realizado siendo Fraudes, horario de tales y la IP que realizó ese duplicado. Esta IP es especialmente relevante ya que nos asegura que se realizó desde la tienda, y no desde otro ordenador externo o pc autorizado.

Esta parte, recibió confirmación por parte de ORANGE donde se informaba de los siguientes duplicados, todos ellos realizados con la IP (...) correspondiente a los ordenadores de la Tienda Orange *****DIRECCIÓN.1**:

1. FRAUDE DUPLICADO TARJETA SIM (SIM SWAPPING) EN FECHA 06-10-2022, 20:42 HORAS EN EL PUNTO DE VENTA TIENDA ORANGE *****DIRECCIÓN.1**, MADRID.

En fecha 6 de octubre de 2022 a las 20:42 horas, se produjo un duplicado de la tarjeta SIM (...), número de IMSI (...) y perteneciente al número de móvil (...) propiedad de cliente de ORANGE (...) con DNI (...). Según la geolocalización de los IMEIS de los terminales utilizados para el duplicado de la SIM, la suplantación se produjo en la tienda ORANGE *****DIRECCIÓN.1** de Madrid propiedad de mi representada. Para acreditar dicha geolocalización, esta parte va a oficiar a la comercializadora ORANGE para que aporte dicho informe.

Una vez se ha corroborado que el duplicado se llevó a cabo en la tienda ORANGE *****DIRECCIÓN.1** de Madrid propiedad de mi representada, los cuadrantes horarios que se han adjuntado en el informe de investigación interna (Anexo 1) muestran que en la franja horaria (06/10/2022) a las 20:42 horas) que se produjo el duplicado el único trabajador que estaba trabajando en dicha tienda era el denunciado. De esta manera, se puede confirmar al 100% que **B.B.B.** estaba en su correspondiente centro de trabajo (punto de venta) en las fechas y horas en que se produjeron dicho duplicado.

(...)

2. FRAUDE DUPLICADO TARJETA SIM (SIM SWAPPING) EN FECHA 07-10-2022, 20:36 HORAS EN EL PUNTO DE VENTA TIENDA ORANGE ***DIRECCIÓN.1, MADRID.

En fecha 7 de octubre de 2022 a las 20:36 horas, se produjo un duplicado de la tarjeta con número de SIM (...), número de IMSI (...) y perteneciente al número de móvil (...) propiedad del cliente de ORANGE (...) con DNI (...). Según la geolocalización de los IMEIS de los terminales utilizados para el duplicado de la tarjeta SIM, la suplantación se produjo en la tienda ORANGE ***DIRECCIÓN.1 de Madrid propiedad de mi representada. Para acreditar dicha geolocalización, esta parte va a oficiar a la comercializadora ORANGE para que aporte dicho informe.

Una vez se ha corroborado que el duplicado se llevó a cabo en la tienda ORANGE ***DIRECCIÓN.1 de Madrid propiedad de mi representada, los cuadrantes horarios que se han adjuntado en el informe de investigación interna (Anexo 2) muestran que en la franja horaria (07/10/2022) a las 20:36 horas que se produjo el duplicado el único trabajador que estaba trabajando en dicha tienda era el denunciado. De esta manera, se puede confirmar al 100% que **B.B.B.** estaba en su correspondiente centro de trabajo (punto de venta) en las fechas y horas en que se produjeron dicho duplicado. (...)

3. FRAUDE DUPLICADO TARJETA SIM (SIM SWAPPING) EN FECHA 13-10-2022 18:43 HORAS EN EL PUNTO DE VENTA TIENDA ORANGE ***DIRECCIÓN.1 MADRID.

En fecha 13 de octubre de 2022 a las 18:43 horas, se produjo un duplicado de la tarjeta con número SIM (...), número de IMSI (...), y perteneciente al número de móvil (...), propiedad del cliente (...) con DNI (...). Según la localización de los IMEIS de los terminales utilizados para el duplicado de la SIM, la suplantación se produjo en la tienda ORANGE ***DIRECCIÓN.1 de Madrid propiedad de mi representada. Para acreditar dicha geolocalización, esta parte va a oficiar a la comercializadora ORANGE para que aporte dicho informe.

Una vez se ha corroborado que el duplicado se llevó a cabo en la tienda Orange ***DIRECCIÓN.1 de Madrid propiedad de mi representada, los cuadrantes horarios que se han adjuntado en el informe de investigación interna (Anexo 3) muestran que en la franja horaria (13/10/2022) a las 18:43 horas que se produjo el duplicado el único trabajador que estaba trabajando en dicha tienda era el denunciado. De esta manera, se puede confirmar al 100% que **B.B.B.** estaba en su correspondiente centro de trabajo (punto de venta) en las fechas y horas en que se produjeron dicho duplicado.

(...)

4. FRAUDE DUPLICADO TARJETA SIM (SIM SWAPPING) EN FECHA 03-11-22 20:16 HORAS EN EL PUNTO DE VENTA TIENDA ORANGE ***DIRECCIÓN.1, MADRID.

En fecha 3 de noviembre de 2022 a las 20:16 horas, se produjo un duplicado de la tarjeta con número SIM (...), número de IMSI (...) y perteneciente al número de móvil (...), propiedad del cliente de ORANGE (...) con DNI (...). Según la geolocalización de los IMEIS de los terminales utilizados para el duplicado de la SIM, la suplantación se

produjo en la tienda Orange *****DIRECCIÓN.1** de Madrid propiedad de mi representada. Para acreditar dicha geolocalización, esta parte va a oficiar a la comercializadora Orange para que aporte dicho informe. Cabe destacar que dicho fraude fue alertado por Orange a mi representado en fecha 21 de noviembre de 2022. (...)

Una vez se ha corroborado que el duplicado se llevó a cabo en la tienda Orange *****DIRECCIÓN.1** de Madrid propiedad de mi representada, los cuadrantes horarios que se han adjuntado en el informe de investigación interna (Anexo 4) muestran que en la franja horaria (03/11/2022) a las 20:16 horas que se produjo el duplicado el único trabajador que estaba trabajando en dicha tienda era el denunciado. De esta manera, se puede confirmar al 100% que **B.B.B.** estaba en su correspondiente centro de trabajo (punto de venta) en las fechas y horas en que se produjeron dicho duplicado.

(...)

5. FRAUDE DUPLICADO TARJETA SIM (SIM SWAPPING) EN FECHA 15-11-2022, 20:16 HORAS EN EL PUNTO DE VENTA TIENDA ORANGE *****DIRECCIÓN.1**, MADRID.

En fecha 15 de noviembre de 2022 a las 20:46 horas, se produjo un duplicado de la tarjeta con Número SIM (...), Número de IMSI: (...) y perteneciente al número de móvil (...), propiedad del cliente de Orange (...) con DNI: (...). Según la geolocalización de los IMEIS de los terminales utilizados para el duplicado de la SIM, la suplantación se produjo en la tienda Orange *****DIRECCIÓN.1** de Madrid propiedad de mi representada. Para acreditar dicha geolocalización, esta parte va a oficiar a la comercializadora Orange para que aporte dicho informe.

Una vez se ha corroborado que el duplicado se llevó a cabo en la tienda Orange *****DIRECCIÓN.1** de Madrid propiedad de mi representada, los cuadrantes horarios que se han adjuntado en el informe de investigación interna (Anexo 5) muestran que en la franja horaria (15/11/2022) a las 20:46 horas que se produjo el duplicado el único trabajador que estaba trabajando en dicha tienda era el denunciado. De esta manera, se puede confirmar al 100% que **B.B.B.** estaba en su correspondiente centro de trabajo (punto de venta) en las fechas y horas en que se produjeron dicho duplicado.

(...)

“SEXTO,- Los hechos narrados pueden ser constitutivos de un:

- POSIBLE DELITO DE ESTAFA CON MEDIOS ELECTRÓNICOS. (248.2 CP)
- Y/O POSIBLE DELITO DE HURTO (234 CP) Y/O POSIBLE APROPIACION INDEBIDA (235 CP Y SIGUIENTES)
- Y/O POSIBLE SUPLANTACIÓN DE IDENTIDAD CON USURPACIÓN DEL ESTADO CIVIL (401 CP).
- Y/O POSIBLE DELITO DE INTRUSIÓN INFORMÁTICA E INTERCEPTACIÓN DE TRANSMISIONES DE DATOS INFORMÁTICOS (197 BIS CP)”

(...)

DÉCIMO TERCERO: **ORANGE** ha presentado en su escrito de alegaciones al acuerdo de inicio del presente expediente sancionador, de fecha 21 de diciembre de 2023, un “INFORME RGPD. OPINION DE AUDITORÍA. APLICACIÓN DE PRINCIPIOS DE PRIVACIDAD DESDE EL DISEÑO Y POR DEFECTO”, fechado el día 18 de diciembre de 2023, y en las conclusiones se puede observar:

“(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).

(…).”

DECIMO CUARTO: **ORANGE** ha presentado en su escrito de alegaciones al acuerdo de inicio del presente expediente sancionador, un documento titulado “Procedimiento. Protección de Datos desde el diseño y por defecto”, con una versión inicial de fecha 04/04/2018, y, en su versión 2.0 de fecha 18 de noviembre de 2019, se puede observar en el apartado 4:

“4. Protección de Datos desde el Diseño

En cumplimiento con lo manifestado en la Guía de Privacidad desde el diseño publicada por la AEPD, **ORANGE** tiene la obligación de adoptar estrategias de diseño de privacidad orientadas a aplicar las medidas técnicas y organizativas que resulten apropiadas desde la primera fase de desarrollo de un sistema de información o de un nuevo proyecto o servicio que implique tratamiento de datos, y durante toda la ejecución del mismo, así como verificar y gestionar el control sobre la recogida, uso y divulgación de los datos personales tratados desde la primera fase de tratamiento de datos personales.

(...):

-(...).

-(...).

-(...).

- (...).

(...).

(...).

(...).

(...).

5. Protección de datos por defecto.

(...).

(...):

-(...).

-(...).

-(...).

-(...).

(...).

(...).

6. Implementación de medidas apropiadas

(...).

(...).

(...).

(...).

(...):

- (...).

- (...).

- (...).

- (...).

- (...).

- (...).

(...).

7. Verificación de cumplimiento

(...):

- (...).

- (...).

- (...).

- (...).

- (...).

FUNDAMENTOS DE DERECHO

I

Competencia

De acuerdo con los poderes que el artículo 58.2 del RGPD, otorga a cada autoridad de control y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante, LOPDGDD), es competente para iniciar y resolver este procedimiento la Directora de la Agencia Española de Protección de Datos.

Asimismo, el artículo 63.2 de la LOPDGDD determina que: *"Los procedimientos tramitados por la Agencia Española de Protección de Datos se regirán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos."*

II

Cuestiones previas

En el presente caso, de acuerdo con lo establecido en el artículo 4.1 y 4.2 del RGPD, consta la realización de un tratamiento de datos personales, toda vez que **ORANGE** realiza la recogida y conservación de, entre otros, los siguientes datos personales de personas físicas: nombre y apellido, fecha de nacimiento, correo electrónico, y datos bancarios, entre otros tratamientos.

ORANGE realiza esta actividad en su condición de responsable del tratamiento, dado que es quien determina los fines y medios de tal actividad, en virtud del artículo 4.7 del RGPD.

Con carácter previo resulta preciso señalar que el artículo 4.1 del RGPD define: «datos personales» como *"toda información sobre una persona física identificada o identificable («el interesado»); se considerará persona física identificable toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador, como por ejemplo un nombre, un número de identificación, datos de localización, un identificador en línea o uno o varios elementos propios de la identidad física, fisiológica, genética, psíquica, económica, cultural o social de dicha persona;"*

A este respecto, conviene aclarar que, dentro del terminal móvil, va insertada la tarjeta SIM. Es una tarjeta inteligente, en formato físico y de reducidas dimensiones, que contiene un chip en el que se almacena la clave de servicio del suscriptor o abonado usada para identificarse ante la red, esto es, el número de línea telefónica móvil del cliente MSISDN (Mobile Station Integrated Services Digital Network -Estación Móvil de la Red Digital de Servicios Integrados-), así como el número de identificación personal del abonado IMSI (International Mobile Subscriber Identity -Identidad Internacional del Abonado móvil-) pero también puede proporcionar otro tipo de datos como la información sobre el listado telefónico o el de llamadas y mensajes.

Por otro lado, la emisión de un duplicado de tarjeta SIM supone el tratamiento de los datos personales de su titular ya que se considerará persona física identificable toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador, como puede ser el número de teléfono (artículo 4.1) del RGPD).

Por lo tanto, la tarjeta SIM identifica un número de teléfono y este número a su vez, identifica a su titular. En este sentido la Sentencia del TJUE en el asunto C-101/2001(Lindqvist) de 6.11.2003, apartado 24, Rec. 2003 p. I-12971: *«El concepto de "datos personales" que emplea el artículo 3, apartado 1, de la Directiva 95/46 comprende, con arreglo a la definición que figura en el artículo 2, letra a), de dicha Directiva "toda información sobre una persona física identificada o identificable". Este concepto incluye, sin duda, el nombre de una persona junto a su número de teléfono o a otra información relativa a sus condiciones de trabajo o a sus aficiones»*.

En suma, tanto los datos que se tratan para emitir un duplicado de tarjeta SIM como la tarjeta SIM (Subscriber Identity Module) que identifica de forma inequívoca y unívoca al abonado en la red, son datos de carácter personal, debiendo su tratamiento estar sujeto a la normativa de protección de datos.

Por su parte, el artículo 6 RGPD regula la licitud del tratamiento.

Asimismo, el artículo 25 RGPD regula la protección de los datos desde el diseño y por defecto.

III

Respuesta a las alegaciones al acuerdo de inicio

En respuesta a las alegaciones presentadas por la entidad reclamada al acuerdo de inicio se debe señalar lo siguiente:

Primera: Existencia de prejudicialidad penal.

ORANGE realiza esta manifestación en la medida en que se ha interpuesto demanda contra los agentes que actuaron de manera delictiva realizando el duplicado de la tarjeta SIM, y que, al ser estos hechos la base de una investigación penal en la que figura como parte perjudicada, estaría sujeto al principio de prejudicialidad penal previsto en el artículo 10 de la Ley Orgánica 6/1985, del Poder Judicial.

En consecuencia, considera que debería resolverse el asunto en la vía penal, antes de realizarse un pronunciamiento en la vía administrativa, procediendo la suspensión de este procedimiento sancionador, de conformidad con lo dispuesto en el artículo 22.1.g) de la Ley 39/2015, del Procedimiento Administrativo Común de las Administraciones Públicas, en la medida en que, según el artículo 77.4 de la citada Ley 39/2015, en los procedimientos de carácter sancionador, los hechos declarados probados por resoluciones judiciales penales firmes vincularán a las Administraciones Públicas respecto de los procedimientos sancionadores que substancien. De este modo, **ORANGE** entiende que en este caso se daba la triple identidad de sujeto, hecho y fundamento:

En cuando al sujeto, se habría constatado la autoría de los hechos en ambos procedimientos por parte de los agentes comerciales.

En cuando al hecho, existiría coincidencia al tratarse de la emisión fraudulenta de un duplicado de tarjeta SIM.

En cuanto al fundamento, se estaría sancionando en dos ocasiones por la conducta ilegítima y fraudulenta de los agentes, contraria a los protocolos y procedimientos establecidos por **ORANGE**.

En relación con esta cuestión, esta Agencia considera necesario señalar que, en el presente expediente sancionador, sin embargo, no existe la triple identidad necesaria para aplicar el artículo 77.4 de la Ley 39/2015 de sujeto, hecho y fundamento entre la infracción administrativa que se valora y la posible o posibles infracciones penales que se pudieran derivar de la demanda planteada ante el órgano jurisdiccional que menciona **ORANGE**, en la medida en que el sujeto infractor no es el mismo.

De este modo, **ORANGE** es el sujeto responsable en el presente procedimiento sancionador, mientras que el responsable penal sería el empleado que procedió al duplicado de la tarjeta SIM, tal y como se recoge en la demanda presentada por **ORANGE** en su escrito de alegaciones.

En este sentido es muy esclarecedora la Sentencia de la Audiencia Nacional de 27/04/2012 (rec. 78/2010), en cuyo Fundamento Jurídico segundo el Tribunal se pronuncia en los siguientes términos frente al alegato de la recurrente de que la AEPD ha infringido el artículo 7 del R.D. 1398/1993 (norma que estuvo vigente hasta la entrada en vigor de la LPACAP):

“En este sentido el Art. 7 del Real Decreto 1398/1993, de 4 de agosto, del procedimiento para el ejercicio de la potestad sancionadora, únicamente prevé la suspensión del procedimiento administrativo cuando se verifique la existencia efectiva y real de un procedimiento penal, si se estima que concurre identidad de sujeto, hecho y fundamento de derecho entre la infracción administrativa y la infracción penal que pudiera corresponder.

No obstante, y para la concurrencia de una prejudicialidad penal, se requiere que ésta condicione directamente la decisión que haya de tomarse o que sea imprescindible para resolver, presupuestos que no concurren en el caso examinado, en el que existe una separación entre los hechos por los que se sanciona en la resolución ahora recurrida y los que la recurrente invoca como posibles ilícitos penales. Así, y aun de haberse iniciado, en el presente supuesto, y por los hechos ahora controvertidos, también actuaciones penales frente a la empresa distribuidora, lo cierto es que tanto la conducta sancionadora como el bien jurídico protegido son distintos en una y otra vía (contencioso-administrativa y penal). En el ámbito penal, el bien jurídico protegido es una posible falsedad documental y estafa, y en el ámbito administrativo, en cambio, la facultad de disposición de sus datos personales por parte de su titular, por lo que tal objeción de la demandada ha de ser rechazada”.

Por tanto, la cuestión planteada por **ORANGE** no puede prosperar y debe ser rechazada.

Segunda: Sobre el supuesto de hecho.

ORANGE pone de manifiesto que la emisión de un duplicado de tarjeta SIM implica la emisión de una tarjeta SIM sin información personal, y que por sí sola no permite el acceso a información bancaria o financiera.

Con relación a esta cuestión, y como ya se incluía en el acuerdo de inicio del presente expediente sancionador, la tarjeta SIM es una tarjeta que va insertada dentro del terminal móvil. Se trata de una tarjeta inteligente, en formato físico y de reducidas dimensiones, que contiene un chip en el que se almacena la clave de servicio del suscriptor o abonado usada para identificarse ante la red, esto es, el número de línea telefónica móvil del cliente MSISDN (Mobile Station Integrated Services Digital Network -Estación Móvil de la Red Digital de Servicios Integrados-), así como el número de identificación personal del abonado IMSI (International Mobile Subscriber Identity -Identidad Internacional del Abonado móvil-) pero también puede proporcionar otro tipo de datos como la información sobre el listado telefónico o el de llamadas y mensajes.

Además, la emisión de un duplicado de tarjeta SIM supone el tratamiento de los datos personales de su titular ya que se considerará persona física identificable toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador (artículo 4.1) del RGPD).

Por lo tanto, la tarjeta SIM identifica un número de teléfono y este número a su vez, identifica a su titular. En este sentido la Sentencia del TJUE en el asunto C-101/2001(Lindqvist) de 6.11.2003, apartado 24, Rec. 2003 p. I-12971: *«El concepto de "datos personales" que emplea el artículo 3, apartado 1, de la Directiva 95/46 comprende, con arreglo a la definición que figura en el artículo 2, letra a), de dicha Directiva "toda información sobre una persona física identificada o identificable". Este concepto incluye, sin duda, el nombre de una persona junto a su número de teléfono o a otra información relativa a sus condiciones de trabajo o a sus aficiones»*.

En suma, tanto los datos que se tratan para emitir un duplicado de tarjeta SIM como la tarjeta SIM (Subscriber Identity Module) que identifica de forma inequívoca y unívoca al abonado en la red, son datos de carácter personal, debiendo su tratamiento estar sujeto a la normativa de protección de datos.

En este sentido se pronuncia la Sentencia de la Audiencia Nacional de 8 de febrero de 2024, cuando afirma:

“Tenemos que partir, que la emisión de un duplicado de tarjeta SIM supone el tratamiento de los datos personales de su titular ya que, a tenor del artículo 4.1 del RGPD, se considera persona física identificable toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador. Pues bien, dentro del terminal móvil, va insertada la tarjeta SIM. Es una tarjeta inteligente en formato físico y de reducidas dimensiones, que contiene un chip en el que se almacena la clave de servicio del suscriptor o abonado usada para identificarse ante la red, esto es, el número de línea móvil del cliente MSISDN (Mobile Station Integrated Services Digital Network-Estación Móvil de la Red Digital de Servicios Integrados-) así como el número de identificación personal del abonado IMSI (International Mobile Subscriber Identity-Identidad Internacional del Abonado móvil-), pero también puede

proporcionar otro tipo de datos como la información sobre el listado telefónico o el de llamadas y mensajes.

Y como se resalta en la resolución recurrida, desde el año 2007, en España, de conformidad con la Disposición Adicional Única de la Ley 25/2007, de 18 de octubre, de conservación de datos relativos a las comunicaciones electrónicas y a las redes públicas de comunicaciones, se exige que los titulares de todas las tarjetas SIM, ya sean de prepago o de contrato, estén debidamente identificados y registrados. Por lo que a hora de obtener un duplicado de la tarjeta SIM, la persona que lo solicite haya de identificarse igualmente y que su identidad coincida con la del titular.”

Asimismo, la Sentencia de la Audiencia Nacional de fecha 9 de febrero de 2023, también recoge lo siguiente:

“Pues bien, la tarjeta Sim es una tarjeta inteligente que se inserta dentro del terminal móvil, que contiene un chip en el que se almacena la clave del servicio de suscriptor o abonado usado para identificarse ante la red.

Así, señala la Fiscalía General del Estado, en informe de julio de 2016, citado por la resolución recurrida: “según los estándares europeos relativos a sistemas de telecomunicaciones celulares digitales, establecidos por el Instituto Europeo de Estándares de Telecomunicaciones (ETSI), un dispositivo de comunicaciones móviles celulares plenamente operativo, denominado en lenguaje coloquial “Teléfono Móvil” se compone materialmente de dos elementos esenciales. En primer lugar, el terminal (...). En segundo lugar, el módulo de identificación de usuario, más conocido como “tarjeta SIM” (Subscriber Identity Module). Esta tarjeta SIM es intercambiable entre los diferentes terminales móviles existentes en el mercado y contiene su chip digital la información necesaria para identificar y autenticar al abonado, incluido en International Mobile Subscriber Identity (IMSI), el cual identifica de forma inequívoca al abonado en la red celular. Sin un IMSI válido los servicios de telefonía no serán accesibles, salvo en el caso de llamada de emergencia.”

Por tanto, el IMSI es el código de identificación en la red de comunicaciones celulares y es fundamental para identificar al abonado, y como está almacenado en la tarjeta SIM, quien tenga dicha tarjeta (el suplantador) tiene el IMSI almacenado. Además, en cuanto el suplantador introduzca la SIM en un terminal y lo encienda, el IMSI va a ser accedido e intercambiado con la red.

Así las cosas, en la medida en que el IMSI instalado en la tarjeta SIM permite singularizar a un individuo y por tanto identificarle, ha de ser considerado como dato personal, según el artículo 4 del RGPD, que conceptúa como tal “toda información sobre una persona física identificada o identificable (el interesado); se considerará persona física identificable toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador, como por ejemplo un nombre, un número de identificación, datos de localización, un identificador en línea o uno o varios elementos propios de la identidad física, fisiológica, genética, psíquica, económica, cultural o social de dicha persona.”

Es decir, la expedición inadecuada de la tarjeta SIM del teléfono móvil de una persona a un tercero que suplanta su identidad permite a dicho tercero acceder a la

información confidencial almacenada en dicha tarjeta y a la línea del legítimo titular de la tarjeta SIM existiendo una clara pérdida de confidencialidad pues los datos son transmitidos a un tercero ilegítimamente.

Téngase en cuenta que en España desde 2007, en virtud de la Disposición Única de la Ley 25/2007, de 18 de octubre, se exige que los titulares de todas las tarjetas SIM estén debidamente identificados y registrados. Esto es importante por cuanto la identificación del abonado será imprescindible para dar de alta la tarjeta SIM, lo que conllevará que a la hora de obtener un duplicado de ésta la persona que lo solicite haya de identificarse y que su identidad coincida con la del titular.

En suma, tanto los datos personales (nombre, apellidos y DNI) que se tratan para emitir un duplicado de la tarjeta SIM, como la propia tarjeta SIM que identifica de forma inequívoca al abonado en la red, son datos de carácter personal...”

En este sentido, con relación al hecho de otorgar al duplicado de la tarjeta SIM la facultad de permitir la comisión de operaciones bancarias, hay que señalar que la propia **ORANGE**, al presentar la denuncia contra el agente que realizó el duplicado de la tarjeta SIM que ha motivado la apertura del presente expediente sancionador ha definido el concepto de SIM SWAPPING de la siguiente manera:

“El SIM Swapping es un ciberataque que consiste en suplantar la identidad de una persona ante su compañía de servicios telefónicos y pedir un duplicado de la tarjeta SIM de su teléfono móvil para con ello, acudir a su banca online y operar con la misma, recibiendo los SMS con el código de confirmación de operaciones bancarias en esa nueva SIM, procediendo a desviar el dinero de la cuenta corriente de la persona suplantada hacia otra propiedad de los delincuentes.

La víctima, tal y como sucede en el presente supuesto, solo se entera de la situación cuando deja de tener cobertura en su teléfono móvil y por mucho que reinicia el dispositivo o intenta buscar cobertura no lo consigue ya que, al entrar en funcionamiento la nueva SIM duplicada que los ciberdelincuentes piden a la compañía de servicios telefónicos, la SIM que está en el teléfono de la víctima deja de funcionar.”

En este sentido, la propia **ORANGE** confirma el concepto de SIM Swapping, y que tiene como objetivo poder acudir a la banca online, recibiendo los SMS con el código de confirmación de operaciones bancarias en la nueva SIM, y proceder a desviar el dinero de la cuenta corriente de la persona suplantada hacia otra de propiedad de los delincuentes. Por tanto, en este aspecto no hay ninguna duda del concepto de SIM Swapping y de las razones por las cuales se solicitan los duplicados de las tarjetas SIM.

Además, en el presente supuesto, en relación con la infracción del artículo 6 del RGPD, lo que se está analizando es la realización de un duplicado de tarjeta SIM propiedad de la parte reclamante y sin su consentimiento, en una tienda propiedad de **ORANGE**.

En cuanto a la infracción del artículo 25 del RGPD, **ORANGE** para el establecimiento de las medidas apropiadas al riesgo ha de evaluar los posibles riesgos para los derechos y libertades de las personas, entre los que se encuentra que los clientes

sufran el conocido ataque SIM Swapping mediante la obtención fraudulenta de un duplicado de su tarjeta SIM, que conlleva la consiguiente pérdida de control sobre sus propios datos personales y unas posibles pérdidas financieras. Todo ello con independencia de la responsabilidad en que puedan incurrir las entidades financieras si actuaron con falta de diligencia.

Por otro lado, **ORANGE** también hace referencia a que, en el acuerdo de inicio, se hacen asociaciones erróneas para agravar el supuesto de hecho al otorgar al duplicado de la tarjeta SIM la facultad de permitir la comisión de operaciones bancarias, omitiendo el paso previo según el cual los malhechores deberán obtener y poder utilizar las credenciales bancarias de la parte reclamante para poder identificarse y realizar la suplantación de identidad ante la entidad financiera.

Añade que esta AEPD no menciona el rol que desempeñan las entidades financieras en estos supuestos, y no consta que se hayan iniciado procedimientos sancionadores contra las mismas.

Respecto de la responsabilidad de las entidades financieras, cabe señalar que la Directiva PSD2, se aplica a los servicios de pago prestados dentro de la Unión (artículo 2), y no a **ORANGE**, pero también es cierto que la expedición de un duplicado de tarjeta SIM a favor de un tercero que no es el titular de la línea, proporciona a los suplantadores el control de la línea telefónica, y por lo tanto, de los SMS dirigidos al teléfono vinculado a la tarjeta SIM inicial y de esta manera a poder acceder a conocer el código de autenticación de la transacción.

Conforme al artículo 4.30 de la Directiva, la “autenticación reforzada” se basa en la utilización de dos o más elementos categorizados como conocimiento (algo que solo conoce el usuario), posesión (algo que solo posee el usuario) e inherencia (algo que es el usuario). Estos elementos o factores son independientes entre sí y, por tanto, la vulneración de uno no compromete la fiabilidad de los demás.

El fundamento es muy sencillo: cuantos más elementos se tengan para verificar la identidad del usuario, más segura es la transacción.

En estos casos, el suplantador, en primer lugar, deberá introducir el usuario y contraseña o password en la aplicación o en el sitio web del proveedor de servicio de pagos o de banca online. En segundo lugar, para completar la transacción o gestión electrónica que desee realizar, el suplantador recibirá, normalmente a través de un SMS, un código alfanumérico de verificación en el teléfono móvil vinculado a ese perfil. Dicho código tiene una validez temporal limitada y es de un solo uso, es decir, únicamente se genera para esa transacción concreta y durante un tiempo limitado. Una vez introducido el código de verificación, se realizaría y completaría la transacción. Se presupone que solo el usuario tiene el dispositivo móvil en su poder (sería el “algo que tiene”), por lo que al recibir en dicho teléfono móvil el código de verificación a través del SMS, su identidad quedaría doblemente autenticada. Por tanto, a los suplantadores no les bastaría para poder cometer el fraude con conocer el usuario y contraseña con los que se identifique la víctima, sino que será necesario que intercepten dicho código de confirmación. En consecuencia, para poder efectuar una transferencia, transacción o compra no consentida, es decir, para llevar a cabo la estafa informática, el ciberdelincuente deberá acceder ilegítimamente a los códigos de

verificación asociados a cada una de esas operaciones remitidos por la entidad bancaria a través de SMS y la manera más habitual de hacerlo es a través de la obtención de un duplicado de la tarjeta SIM.

Por lo tanto, es necesario ejecutar dos acciones completamente diferentes pero complementarias entre sí.

En primer lugar, se han de obtener los datos de acceso a la banca online o proveedor de pago titularidad de la persona a defraudar, si nos centramos en la búsqueda del enriquecimiento patrimonial.

Y, en segundo lugar, se habrá de obtener el duplicado de la tarjeta SIM titularidad de la persona a defraudar con la finalidad de hacerse con los SMS de confirmación que el cliente recibirá en su terminal móvil como autenticación de doble factor.

Pues bien, en la última de estas acciones -obtención del duplicado-, es donde se han centrado los hechos objeto de este procedimiento y no en los acontecidos en la primera fase, que como resulta obvio quedan al margen de la responsabilidad que se imputa a **ORANGE** en el presente procedimiento.

Por otro lado, **ORANGE** manifiesta que la AEPD pretende sancionar los fraudes SIM SWAPPING sin atender ni analizar el concreto supuesto de hecho, el perjuicio asociado, ni las responsabilidades derivadas, sin tener en cuenta la diligencia desplegada por **ORANGE** en su actuación y en la adopción de medidas de seguridad. Añade que la AEPD omite valorar la documental aportada, estableciendo un discurso genérico para legitimar una infracción a la normativa de protección de datos.

Sin embargo, en relación con esta cuestión, es necesario hacer referencia al momento procedimental en el que **ORANGE** presenta estas alegaciones. En este sentido, de conformidad con lo dispuesto en el artículo 64 de la Ley 39/2015, del Procedimiento Administrativo Común de las Administraciones Públicas, referido al “Acuerdo de iniciación en los procedimientos de naturaleza sancionadora”, en el apartado 2 establece:

“2. El acuerdo de iniciación deberá contener al menos:

a) Identificación de la persona o personas presuntamente responsables.

b) Los hechos que motivan la incoación del procedimiento, su posible calificación y las sanciones que pudieran corresponder, sin perjuicio de lo que resulte de la instrucción.

c) Identificación del instructor y, en su caso, secretario del procedimiento y norma que le atribuya tal competencia, con expresa indicación del régimen de recusación de los mismos.

d) Órgano competente para la resolución del procedimiento y norma que le atribuya tal competencia, indicando la posibilidad de que el presunto responsable pueda reconocer voluntariamente su responsabilidad, con los efectos previstos en el artículo 85.

e) Medidas de carácter provisional que se hayan acordado por el órgano competente para iniciar el procedimiento sancionador, sin perjuicio de las que se puedan adoptar durante el mismo de conformidad con el artículo 56.

f) Indicación del derecho a formular alegaciones y a la audiencia en el procedimiento y de los plazos para su ejercicio, así como indicación de que, en caso de no efectuar alegaciones en el plazo previsto sobre el contenido del acuerdo de iniciación, éste podrá ser considerado propuesta de resolución cuando contenga un pronunciamiento preciso acerca de la responsabilidad imputada."

Por tanto, el acuerdo de iniciación del presente procedimiento sancionador contiene todos los pronunciamientos que la normativa aplicable requiere.

Sin perjuicio de lo anterior, la alegación planteada por **ORANGE** tampoco puede ser tenida en cuenta, en la medida en que, el supuesto de hecho sí se contempla y valora a la hora de graduar la sanción asociada a las infracciones de los artículos 6 y 25 del RGPD, en el apartado a) del artículo 83 del RGPD.

En lo que se refiere a la diligencia de **ORANGE**, hay que tener en cuenta que este aspecto se ha valorado como agravante en la infracción del artículo 25 del RGPD, por lo que si se ha analizado. En relación con las medidas adoptadas con posterioridad hay que señalar que se valoran positivamente, pero no determinan que no se haya producido la infracción del artículo 25 del RGPD.

Por último, tampoco se puede tener en cuenta la afirmación realizada por **ORANGE** en relación con que esta Agencia utiliza un discurso genérico, o que no se valore la documental presentada, tal y como se puede observar en el presente documento y en el elevado número de hechos probados.

Tercera: Del rol de víctima de **ORANGE**. Sobre el Modus Operandi.

ORANGE, con esta alegación, pone de manifiesto que se trata de la emisión de un duplicado de tarjeta SIM realizada de manera diferente a otros supuestos, en la medida en que se había realizado por dos comerciales del punto de venta de la compañía, que actuaban, consiguientemente, en nombre de **ORANGE**.

Antes de continuar con el resto de la argumentación presentada por **ORANGE**, desde esta AEPD se quiere hacer constar que la denuncia presentada ante el Juzgado de Instrucción se dirige contra **B.B.B.**, por posible delito de:

-posible delito de estafa con medios electrónicos (238.2 CP)

-y/o posible delito de hurto (234 CP) y/o posible apropiación indebida (235 CP y siguientes)

-y/o posible suplantación de identidad con usurpación del estado civil (401 CP)

-y/o posible delito de intrusión informática e interceptación de transmisiones de datos informático (197 bis CP)

- cualquier otro que se apreciara de la instrucción de la presente causa.

En los hechos de la denuncia presentada se pone de manifiesto que el denunciado empezó a trabajar en el centro de trabajo ubicado en *****DIRECCIÓN.1** de Madrid, el pasado 12 de julio de 2021. El denunciado estuvo trabajando hasta el día 11 de diciembre de 2022.

Además, en el Hecho cuarto de la denuncia, en el que se habla de los hechos denunciados, consta hasta 5 suplantaciones realizadas por el empleado de **ORANGE** de la *****DIRECCIÓN.1** de Madrid.

Por otra parte, en el Hecho tercero de la denuncia se habla del concepto de SIM SWAPPING de la siguiente manera:

*“En primer lugar, es importante explicar en qué consiste los hechos aquí denunciados (SIM Swapping) llevados a cabo por el denunciado **C.C.C.** en, al menos, los días 14, 17 y 21 de noviembre de 2022 en su centro de trabajo, el punto de venta **ORANGE** ubicado en el (...) *****DIRECCIÓN.2**.”*

Por lo tanto, aunque en sus alegaciones **ORANGE** habla de dos trabajadores de la misma tienda, se observa claramente que han sido dos trabajadores de dos tiendas diferentes los que se han podido ver involucrados en un caso como el que denunciaba la parte reclamante. Además, si tenemos en cuenta el contenido de la denuncia, en la tienda **ORANGE** ubicada en la *****DIRECCIÓN.1**, se vieron afectados 5 particulares, mientras que, en la tienda ubicada en el (...) *****DIRECCIÓN.2**, se vieron afectados 3 personas.

Una vez hecha esta matización, en el sentido de que no eran dos trabajadores de una misma tienda los que actuaron de manera errónea, sino que se trataba de trabajadores que prestaban sus servicios en dos tiendas diferentes, y que, del contenido de la denuncia presentada por **ORANGE** ante el Juzgado de instrucción se deduce claramente que afectaron al menos a 8 personas, deben decaer las manifestaciones de **ORANGE** relativas a que no es posible exigirle la capacidad total de detección y frustración de tales actos delictivos.

En este sentido, la actuación que ha determinado que se haya producido un hecho como el que se ha denunciado viene dado por el hecho de que el procedimiento que **ORANGE** tenía implantado para realizar un duplicado de tarjeta SIM, (...).

Así lo explica **ORANGE** en su escrito de alegaciones al acuerdo de inicio, de fecha 21 de diciembre de 2023, presentado ante esta Agencia, de tal manera que, según expresa **ORANGE**, “en el caso que nos ocupa, los agentes de **ORANGE** utilizaron (...), motivo por el cual, al introducirlo en el sistema de (...). Así pues, para este tipo de errores de lectura de documentación, el Protocolo de **ORANGE** establece que, si bien se debe generar un aviso al Grupo de Análisis de Riesgos, se permite a los agentes comerciales para casos tasados (...). Ello se debe a la necesaria apertura de dicha

manualidad dentro de un sistema absolutamente automatizado que ha de permitir el acto comercial (...).”.

Es por ello que en el presente procedimiento sancionador se ha imputado la infracción del artículo 25 del RGPD, pues según reza, el responsable del tratamiento, teniendo en cuenta el estado de la técnica, el coste de la aplicación y la naturaleza, ámbito, contexto y fines del tratamiento, así como los riesgos de diversa probabilidad y gravedad que entraña el tratamiento para los derechos y libertades de las personas físicas, debe aplicar, tanto en el momento de determinar los medios de tratamiento como en el momento del propio tratamiento, medidas técnicas y organizativas apropiadas, a fin de cumplir los requisitos del presente Reglamento y proteger los derechos de los interesados.

Este artículo impone una obligación de diseño de procedimientos internos en el momento de determinar los medios de tratamiento y de aplicar esos procedimientos en el momento del tratamiento, para garantizar de forma efectiva el cumplimiento de los requisitos de protección de datos.

ORANGE, al comunicar el procedimiento que tiene implantado para la expedición de duplicados de tarjeta SIM, ha informado que hay supuestos en los que se puede proceder a (...).

El principio de protección de datos desde el diseño impone que, desde los estadios más iniciales de planificación de un tratamiento debe de ser considerado este principio: el responsable del tratamiento desde el momento en que se diseña y planifica un eventual tratamiento de datos personales deberá determinar todos los elementos que conforman el tratamiento, a los efectos de aplicar de forma efectiva los principios de protección de datos, integrando las garantías necesarias en el tratamiento con la finalidad última de, cumpliendo con las previsiones del RGPD, proteger los derechos de los interesados.

Con el sistema que tenía implantado **ORANGE**, según se recoge en su escrito de alegaciones al acuerdo de inicio del presente expediente sancionador, de fecha 21 de diciembre de 2023, los agentes pudieron utilizar (...) que pueden derivarse de la entrega de una tarjeta SIM válida a un tercero sin consentimiento de su titular. Así, según aduce **ORANGE**, al introducir los agentes (...). Para este tipo de errores, según manifiestan, el Protocolo de **ORANGE** establece que, si bien se debe generar un aviso al Grupo de Análisis de Riesgos, se permite a los agentes comerciales para casos (...). Según sigue manifestando **ORANGE**, ello se debe a la necesaria apertura de dicha manualidad dentro de un sistema absolutamente automatizado que ha de permitir (...). Así las cosas, **ORANGE** articuló un protocolo que tenía como principal objetivo la realización del acto comercial, pero que no contemplaba el riesgo de la emisión y entrega de una tarjeta SIM a persona distinta de su titular. El aviso al Grupo de Análisis de Riesgos resulta manifiestamente ineficaz, toda vez que no logró que se detectara la suplantación, al menos, en los casos que conoce esta Agencia a través del presente procedimiento.

Por tanto, desde el diseño del tratamiento ya no existían medidas del artículo 25 del RGPD para verificar que la información introducida no era errónea, y comprobar que la

solicitud de duplicado de tarjeta se estaba realizando por el titular de la línea al que, asimismo, se le realizaba la entrega.

Esto supone que **ORANGE** no habría identificado y analizado de forma adecuada los riesgos que un proceso manual de duplicados de tarjeta SIM entraña para los derechos y libertades de las personas físicas, ni previsto ni aplicado desde el diseño las medidas técnicas y organizativas apropiadas, para aplicar de forma efectiva los principios de protección de datos, que exige el artículo 25 RGPD.

El derecho fundamental a la protección de datos también incluye que los responsables del tratamiento integren la protección de datos en el diseño del tratamiento de datos personales, desde su inicio y durante todo el ciclo de tratamiento, estableciendo para ello las políticas adecuadas para el cumplimiento de este principio y la protección de los derechos de las personas, y eso es precisamente lo que no hizo **ORANGE** y lo que se está cuestionando en este procedimiento sancionador, ya que el mecanismo que tenía implantado **ORANGE** no había previsto siquiera la obligación de emitir duplicados de tarjeta SIM introduciendo (...), tal y como reconoce **ORANGE** en su escrito de alegaciones.

En cualquier caso, a pesar de las manifestaciones de **ORANGE** del hecho de que los agentes se aprovecharon de sus conocimientos del sistema para cometer un acto delictivo, en su escrito de alegaciones manifiestan que “desde el 14 de diciembre de 2022, **ORANGE** ha procedido a la suspensión cautelar de la opción que permite a los agentes de punto de venta, (...)” Es decir, que a pesar de todo lo manifestado y la defensa que se realiza del sistema que tenía implantado, ha decidido suspender el sistema que permite la emisión de un duplicado de tarjeta SIM (...).

Por todo lo expuesto, no puede ser tenida en cuenta esta alegación de **ORANGE**.

Cuarta: De la inexistencia de falta de legitimación en el tratamiento de datos personales de **ORANGE**.

ORANGE manifiesta que, durante el proceso de duplicado de la tarjeta SIM que ha motivado la apertura de este procedimiento sancionador, no se habría facilitado ningún dato personal de la parte reclamante a ningún tercero, entendiéndose que la comisión de los actos delictivos por parte de los agentes se realiza de manera individual, y en oposición a las obligaciones impuestas por **ORANGE**, no pudiéndose achacar de manera individual a una actuación de **ORANGE**.

En relación con esta cuestión, es necesario señalar que no es objeto del presente procedimiento sancionador el proceder de los empleados de **ORANGE**, sino que más bien se trata de comprobar si la actuación de **ORANGE** cumple con la normativa de protección de datos personales. Si bien, el presente procedimiento tiene origen en una actuación fraudulenta de unos empleados de **ORANGE**, no es menos cierto que actuaban por cuenta de **ORANGE** y que fue **ORANGE** quien ha facilitado un duplicado de una tarjeta SIM, (que, como ya se ha explicado con anterioridad en este procedimiento, en un dato personal en sí) a una persona distinta del titular de la línea, lo cual constituye un tratamiento de datos personales en los términos del artículo 4 del RGPD, sin contar con legitimación para ello, lo cual infringiría el artículo 6 del RGPD, tal y como se explica en el Fundamento de Derecho IV del presente documento.

Además, las medidas técnicas y organizativas que **ORANGE** tenía implantadas no resultaban adecuadas ni eficaces para asegurar los derechos y libertades de los interesados, razón por la que se infringiría también el art. 25 del RGPD, tal y como se explica en el Fundamento de Derecho VII del presente documento.

Por otro lado, **ORANGE** vuelve a manifestar su disconformidad con el hecho de que se considere a la tarjeta SIM como un dato personal, y para ello, cita la Sentencia del Tribunal General de la Unión Europea, (Sala Octava ampliada) de 26 de abril de 2023, en el que se determinaba que la consideración como dato personal de un código alfanumérico no puede presuponerse, sino que compete a la autoridad de control justificar la capacidad de relacionar los datos personales con una persona concreta, no bastando con presuponerlo por el mero hecho de que potencialmente pueda llegar a permitir una identificación.

ORANGE insiste en que esta Agencia no ha desplegado actividad probatoria y que directamente presupone que los códigos contenidos en la tarjeta SIM permiten identificar al titular.

Esta cuestión ha sido resuelta en el apartado segundo de la contestación a estas alegaciones, cuando se ha manifestado lo siguiente:

Con relación a esta cuestión, y como ya se incluía en el acuerdo de inicio del presente expediente sancionador, la tarjeta SIM es una tarjeta que va insertada dentro del terminal móvil. Se trata de una tarjeta inteligente, en formato físico y de reducidas dimensiones, que contiene un chip en el que se almacena la clave de servicio del suscriptor o abonado usada para identificarse ante la red, esto es, el número de línea telefónica móvil del cliente MSISDN (Mobile Station Integrated Services Digital Network -Estación Móvil de la Red Digital de Servicios Integrados-), así como el número de identificación personal del abonado IMSI (International Mobile Subscriber Identity -Identidad Internacional del Abonado móvil-) pero también puede proporcionar otro tipo de datos como la información sobre el listado telefónico o el de llamadas y mensajes.

Además, la emisión de un duplicado de tarjeta SIM supone el tratamiento de los datos personales de su titular ya que se considerará persona física identificable toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador (artículo 4.1) del RGPD).

Por lo tanto, la tarjeta SIM identifica un número de teléfono y este número a su vez, identifica a su titular, como recientemente ha sido reconocido por la Audiencia Nacional, en sentencia, 13 de mayo de 2024, (R 0002336/2021) al declarar que *“(…) hemos de partir de que la emisión de un duplicado de tarjeta SIM supone el tratamiento de los datos personales de su titular ya que, a tenor del art. 4.1 del RGPD, se considera persona física identificable toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador. Identificador que constituye la tarjeta SIM, insertada dentro del terminal móvil, en cuanto tarjeta inteligente, en formato físico y de reducidas dimensiones, que contiene un chip en el que se almacena la clave de servicio del suscriptor o abonado usada para identificarse ante la red, esto es, el número de línea telefónica móvil del cliente*

MSISDN (Mobile Station Integrated Services Digital Network - Estación Móvil de la Red Digital de Servicios Integrados-), así como el número de identificación personal del abonado IMSI (International Mobile Subscriber Identity - Identidad Internacional del Abonado móvil-), y que también puede proporcionar otro tipo de datos como la información sobre el listado telefónico o el de llamadas y mensajes.

Ya desde el año 2007, en España, de conformidad con la Disposición Adicional Única de la Ley 25/2007, de 18 de octubre, de conservación de datos relativos a las comunicaciones electrónicas y a las redes públicas de comunicaciones, se exige que los titulares de todas las tarjetas SIM, ya sean de prepago o de contrato, estén debidamente identificados y registrados. Por lo que a hora de obtener un duplicado de la tarjeta SIM, la persona que lo solicite haya de identificarse igualmente y que su identidad coincida con la del titular”.

En este sentido la Sentencia del TJUE en el asunto C -101/2001(Lindqvist) de 6.11.2003, apartado 24, Rec. 2003 p. I-12971: «El concepto de "datos personales" que emplea el artículo 3, apartado 1, de la Directiva 95/46 comprende, con arreglo a la definición que figura en el artículo 2, letra a), de dicha Directiva "toda información sobre una persona física identificada o identificable". Este concepto incluye, sin duda, el nombre de una persona junto a su número de teléfono o a otra información relativa a sus condiciones de trabajo o a sus aficiones».

En suma, tanto los datos que se tratan para emitir un duplicado de tarjeta SIM como la tarjeta SIM (Subscriber Identity Module) que identifica de forma inequívoca y unívoca al abonado en la red, son datos de carácter personal, debiendo su tratamiento estar sujeto a la normativa de protección de datos.

Además, y como también se indica en el apartado segundo de la contestación a estas alegaciones, también así se ha manifestado la Audiencia Nacional en otras varias sentencias, como en la sentencia de 8 de febrero de 2024, y en la de 9 de febrero de 2023.

Por todo ello, hay que poner de manifiesto que es irrelevante el hecho de que el duplicado de la tarjeta SIM se realizara por un empleado de **ORANGE**, ya que, con la emisión del duplicado de la tarjeta, se actúa por cuenta de **ORANGE** que es la responsable del tratamiento de los datos personales de sus clientes.

De este modo, y hasta donde esta Agencia conoce, **ORANGE** no habría establecido medidas técnicas ni organizativas apropiadas para que se emitieran los duplicados de la tarjeta SIM sólo a las personas titulares de las mismas o a terceros con la autorización de éstas.

Quinta: De la correcta implementación de la privacidad desde el diseño y por defecto.

ORANGE manifiesta su disconformidad con el hecho de que se impute la infracción del artículo 25 del RGPD en este expediente sancionador, y añade que, en los procesos de contratación y otros procesos complementarios diseñados por la compañía, sí habrían sido diseñados teniendo en cuenta la privacidad y la seguridad de la información, incluyendo la intervención de los propios agentes.

Según **ORANGE** la labor de estos agentes es precisamente la de ejecutar los procesos verificando que se realizan de forma correcta, y conforme a las instrucciones de **ORANGE**, y añade que la automatización de medidas para apoyar esta labor con medios digitales debe ser considerada como un refuerzo adicional para el desempeño de las funciones.

ORANGE va más allá señalando la existencia de una “posibilidad legítima de la empresa de delegar tareas de supervisión en los usuarios designados para ello, sin que quepa asimilar este hecho a ningún incumplimiento normativo”.

Sobre estas alegaciones, hay que indicar, en primer lugar, que hay que tener en cuenta que el artículo 25 del RGPD se encuadra dentro de las obligaciones generales que el Capítulo IV del RGPD establece al responsable del tratamiento, imponiendo una obligación de diseño en el momento de determinar los medios de tratamiento, los cuales deben garantizar de forma efectiva el cumplimiento de los principios de protección de datos.

El RGPD exige a los responsables establecer las medidas técnicas y organizativas necesarias a lo largo de todo el ciclo de vida del tratamiento, tanto desde el momento inicial en que se lleva a cabo la definición del tratamiento y se determinan los medios como durante su puesta en marcha y funcionamiento habitual.

La protección de datos desde el diseño tiene por objetivo aplicar los principios de protección de datos en los procesos de diseño de los sistemas y procedimientos de la organización sobre los que se apoya el tratamiento de los datos, con un fin eminentemente preventivo y orientado tanto a evitar posibles daños a las personas físicas como, de manera colateral, los perjuicios que para la organización podría suponer la modificación o el rediseño de los sistemas en los que se llevan a cabo los tratamientos, una vez desarrollados e implantados, como consecuencia de la identificación de errores de diseño que pudieran suponer daños o perjuicios a los interesados y a sus derechos y libertades.

En este orden de ideas, el considerando 78 del RGPD dispone:

La protección de los derechos y libertades de las personas físicas con respecto al tratamiento de datos personales exige la adopción de medidas técnicas y organizativas apropiadas con el fin de garantizar el cumplimiento de los requisitos del presente Reglamento. A fin de poder demostrar la conformidad con el presente Reglamento, el responsable del tratamiento debe adoptar políticas internas y aplicar medidas que cumplan en particular los principios de protección de datos desde el diseño y por defecto. Dichas medidas podrían consistir, entre otras, en reducir al máximo el tratamiento de datos personales, seudonimizar lo antes posible los datos personales, dar transparencia a las funciones y el tratamiento de datos personales, permitiendo a los interesados supervisar el tratamiento de datos y al responsable del tratamiento crear y mejorar elementos de seguridad. Al desarrollar, diseñar, seleccionar y usar aplicaciones, servicios y productos que están basados en el tratamiento de datos personales o que tratan datos personales para cumplir su función, ha de alentarse a los productores de los productos, servicios y aplicaciones a que tengan en cuenta el derecho a la protección de datos cuando desarrollan y

diseñen estos productos, servicios y aplicaciones, y que se aseguren, con la debida atención al estado de la técnica, de que los responsables y los encargados del tratamiento están en condiciones de cumplir sus obligaciones en materia de protección de datos. Los principios de la protección de datos desde el diseño y por defecto también deben tenerse en cuenta en el contexto de los contratos públicos.

En concreto, a la luz del considerando 78 del RGPD, el principio de protección de datos desde el diseño es la clave a seguir por el responsable del tratamiento para demostrar el cumplimiento con el RGPD, ya que el responsable del tratamiento debe adoptar políticas internas y aplicar medidas que cumplan en particular los principios de protección de datos desde el diseño y por defecto.

El principio de privacidad desde el diseño es una muestra del paso de la reactividad a la proactividad y manifestación directa del enfoque de riesgos que impone el RGPD. Parte de la responsabilidad proactiva, impone que, desde los estadios más iniciales de planificación de un tratamiento debe ser considerado este principio: el responsable del tratamiento desde el momento en que se diseña y planifica un eventual tratamiento de datos personales deberá determinar todos los elementos que conforman el tratamiento, a los efectos de aplicar de forma efectiva los principios de protección de datos, integrando las garantías necesarias en el tratamiento con la finalidad última de, cumpliendo con las previsiones del RGPD, proteger los derechos de los interesados.

Así, y respecto de los riesgos que pueden estar presentes en el tratamiento, el responsable del tratamiento llevará a cabo un ejercicio de análisis y detección de los riesgos durante todo el ciclo de tratamiento de los datos, con la finalidad primera y última de proteger los derechos y libertades de los interesados, y no sólo cuando efectivamente se produce el tratamiento. Así se expresa en las Directrices 4/2019 del CEPD relativas al artículo 25 Protección de datos desde el diseño y por defecto adoptadas el 20 de octubre de 2020.

En las citadas Directrices se indica al respecto que:

“35. El «momento de determinar los medios de tratamiento» hace referencia al período de tiempo en que el responsable está decidiendo de qué forma llevará a cabo el tratamiento y cómo se producirá este, así como los mecanismos que se utilizarán para llevar a cabo dicho tratamiento. En el proceso de adopción de tales decisiones, el responsable del tratamiento debe evaluar las medidas y garantías adecuadas para aplicar de forma efectiva los principios y derechos de los interesados en el tratamiento, y tener en cuenta elementos como los riesgos, el estado de la técnica y el coste de aplicación, así como la naturaleza, el ámbito, el contexto y los fines. Esto incluye el momento de la adquisición y la implementación del software y hardware y los servicios de tratamiento de datos.

36. Tomar en consideración la PDDD desde un principio es crucial para la correcta aplicación de los principios y para la protección de los derechos de los interesados. Además, desde el punto de vista de la rentabilidad, también interesa a los responsables del tratamiento tomar la PDDD en consideración cuanto antes, ya que más tarde podría resultar difícil y costoso introducir cambios en planes ya formulados y operaciones de tratamiento ya diseñadas”

Asimismo, las citadas Directrices 4/2019 del CEPD disponen que “61. Para hacer efectiva la PDDD, los responsables del tratamiento han de aplicar los principios de transparencia, licitud, lealtad, limitación de la finalidad, minimización de datos, exactitud, limitación del plazo de conservación, integridad y confidencialidad, y responsabilidad proactiva. Estos principios están recogidos en el artículo 5 y el considerando 39 del RGPD”.

La Guía de Privacidad desde el Diseño de la AEPD afirma que “La privacidad desde el diseño (en adelante, PbD) implica utilizar un enfoque orientado a la gestión del riesgo y de responsabilidad proactiva para establecer estrategias que incorporen la protección de la privacidad a lo largo de todo el ciclo de vida del objeto (ya sea este un sistema, un producto hardware o software, un servicio o un proceso). Por ciclo de vida del objeto se entiende todas las etapas por las que atraviesa este, desde su concepción hasta su retirada, pasando por las fases de desarrollo, puesta en producción, operación, mantenimiento y retirada”.

La Guía dispone que “La privacidad debe formar parte integral e indisoluble de los sistemas, aplicaciones, productos y servicios, así como de las prácticas de negocio y procesos de la organización. No es una capa adicional o módulo que se añade a algo preexistente, sino que debe estar integrada en el conjunto de requisitos no funcionales desde el mismo momento en el que se concibe y diseña (...) La privacidad nace en el diseño, antes de que el sistema esté en funcionamiento y debe garantizarse a lo largo de todo el ciclo de vida de los datos”.

Por tanto, las medidas a las que hace referencia el artículo 25 del RGPD pretenden que la empresa tenga integrada dentro de la misma la protección de datos de carácter personal, incluso antes de iniciarse materialmente el tratamiento de los datos personales.

De esta forma, se apuesta porque la protección de datos de carácter personal sea tenida en consideración desde un primer momento, desde la toma de decisiones o del momento de la planificación.

ORANGE, en su escrito de alegaciones al acuerdo de inicio del presente procedimiento sancionador, pone de manifiesto que cumple con las previsiones del artículo 25. Para ello, ha manifestado que es la oficina del Delegado de Protección de Datos de la compañía quien interviene para permitir el lanzamiento de proyectos, productos y servicios que puedan impactar en el tratamiento de datos personales de los clientes y usuarios de **ORANGE**, y así vendría recogido en los siguientes documentos, que aporta junto a su escrito de alegaciones al acuerdo de inicio del presente procedimiento sancionador:

- Documento 5 relativo al “Privacy Management Dashboard”, que, según manifiesta **ORANGE**, anualmente se comparte con la compañía.

Este documento que aporta **ORANGE** es un formulario en inglés, referido al año 2023, y en el que hay que ir completando campos relativos al tratamiento de datos personales que se procesen en la compañía.

-Documento 6, que es un informe que contiene la opinión de la auditoría correspondiente a la aplicación de los principios de privacidad desde el diseño y por defecto. Es un informe en que el que se extraen unas conclusiones en las que no se concreta ningún tipo de actuación, sino que desde **ORANGE** se tiene en cuenta *“la aplicación del Principio de PbDg con el objeto de intentar anticiparse de forma proactiva a los eventos que puedan afectar a la privacidad evitando, en la medida de lo posible, su materialización y, por tanto, el impacto sobre los derechos y libertades de los afectados en materia de protección de datos.”*

-Documento 7, que viene titulado como el “Procedimiento de Protección de Datos desde el diseño y por defecto”. En este documento se observa que se pretende la aplicación de este principio, pero no viene materializado en procesos concretos, sino que únicamente se manifiesta que será tenido en cuenta.

De esta documentación se concluye que, en estos documentos se hace una referencia genérica a la posibilidad de la existencia de riesgos, pero no se identifican de manera concreta, y no se prevén actuaciones en concreto con respecto a la posibilidad de que se produzcan. No se trata de documentos de los que, tras una evaluación de los riesgos que implica la entrega de un duplicado de la tarjeta SIM a un tercero no autorizado, se derive la aplicación de unos determinados procedimientos, desde el inicio del tratamiento, que contemplen medidas concretas eficaces para su mitigación.

No se debe olvidar que el RGPD pretende lograr la protección de los derechos de los interesados, y, por lo tanto, el foco debe dirigirse a la identificación y evaluación de los riesgos en los derechos y libertades de los interesados, con la posterior adopción de las medidas técnicas y organizativas de todo tipo destinadas a evitar su materialización.

De este modo, si el enfoque de la empresa no está orientado a los riesgos para los derechos y libertades de los interesados, como ocurre en el presente caso, no solo no se va a procurar una protección eficaz a los interesados, sino que supone un incumplimiento del artículo 25 del RGPD.

En sus alegaciones al acuerdo de inicio del presente procedimiento sancionador, **ORANGE** manifiesta que la actuación que ha motivado la apertura de este procedimiento sancionador viene motivada por la actuación dolosa de un agente que ha provocado un error en el sistema para permitir la realización de un acto comercial haciendo un mal uso de sus permisos. Añade **ORANGE** que este fraude estaba considerado como de bajo riesgo.

También pone de manifiesto que, a la hora de explicar que este proceso que, *“no debe perderse en ningún momento de vista que ORANGE es una empresa de telecomunicaciones que da servicios a sus clientes, y que estos demandan agilidad en la realización de los tramites y gestiones que solicitan. La demora en estas gestiones es percibida de forma negativa, lo que obliga a que los protocolos establecidos sean compatibles con una experiencia de usuario adecuada y, por tanto, disponer de diferentes opciones para atender las necesidades de los clientes.”*

Con esta afirmación se está primando la celeridad en el proceso de atención a los clientes a las garantías de los derechos de los particulares.

ORANGE también ha manifestado que la implementación y supervisión de las medidas de seguridad técnica está encomendada al departamento de sistemas, en el caso de la detección del fraude, aunque la detección de su posibilidad venga identificada por la oficina del DPO o cualquier otra área, mientras que la gestión está coordinada desde el departamento específico de la compañía especializado en la prevención del fraude, que es quien evalúa los riesgos conforme a un protocolo y metodología específica, aportando para acreditarlo los siguientes documentos, que son:

1. Documento 8, relativo a la “group Risk Management Policy”.

Este documento es un documento aportado en inglés, en el que se hace referencia de manera teórica a lo que se considera un riesgo

2. Documento 9 que contiene la Política de Control y Gestión de Riesgos.

Este documento está redactado en español y en la introducción se recoge que es un modelo de Control y Gestión de Riesgos de **ORANGE** España, que se enmarca dentro de la metodología desarrollada por el grupo **ORANGE**, pero el documento está redactado de manera teórica, de tal manera que no se hace mención alguna de forma concreta a la posibilidad de que un empleado pudiera (...).

3. Documento 10 que describe el funcionamiento del Comité de Riesgos Locales

4. Documento 11 que enumera la Política de Control Interno de **ORANGE**.

De estos documentos se concluye que se trata de una documentación en la que se hace referencia a la posibilidad de la existencia de riesgos, pero no se identifican de manera concreta, y no se prevén actuaciones en concreto con respecto a la posibilidad de que se produzcan situaciones como las que se han producido en el presente expediente sancionador, en la medida en que no se hace mención alguna de forma concreta a la posibilidad de que un empleado pudiera (...).

No se debe olvidar que el RGPD pretende lograr la protección de los derechos de los interesados, y, por lo tanto, el foco debe dirigirse a la identificación y evaluación de los riesgos en los derechos y libertades de los interesados, con la posterior adopción de las medidas técnicas y organizativas de todo tipo destinadas a evitar su materialización.

De este modo, si el enfoque de la empresa no está orientado a los riesgos para los derechos y libertades de los interesados, sino que está dirigido a los riesgos para la propia empresa, no solo no se va a procurar una protección eficaz a los interesados, sino que supone un incumplimiento del artículo 25 del RGPD.

ORANGE también ha manifestado su disconformidad con el hecho de que en los procesos no pueda llevarse a cabo una intervención humana. Sin embargo, en este punto, lo que se está cuestionando es que **ORANGE** no tenía previsto ningún control para casos en que se pudiera (...).

De este modo, la contestación que ha dado **ORANGE** no puede ser estimada puesto que no se está exigiendo un proceso totalmente automatizado, sino que en la implantación del sistema no se previó el riesgo, al no tener implantado ningún mecanismo para evitar un uso incorrecto de sus protocolos manuales. Todo ello, si tenemos en cuenta que el procedimiento habitual para la emisión de duplicados de tarjeta SIM de **ORANGE** es automatizado, y ha manifestado en este mismo escrito de alegaciones que ha suspendido la posibilidad de validación manual de los documentos de identidad de los solicitantes de tarjeta SIM.

Además, como ya se ha señalado anteriormente, no se puede olvidar tampoco que **ORANGE** ha manifestado, a la hora de explicar este proceso que, *“no debe perderse en ningún momento de vista que ORANGE es una empresa de telecomunicaciones que da servicios a sus clientes, y que estos demandan agilidad en la realización de los trámites y gestiones que solicitan. La demora en estas gestiones es percibida de forma negativa, lo que obliga a que los protocolos establecidos sean compatibles con una experiencia de usuario adecuada y, por tanto, disponer de diferentes opciones para atender las necesidades de los clientes.”*

Por todo lo expuesto no puede ser tenida en cuenta esta alegación de **ORANGE**, en la medida en que no se trata de no poder automatizar los procedimientos, sino que se trata de que la agilidad en las gestiones no justifica ni puede ser impedimento para no cumplir con lo previsto en la normativa de protección de datos, de obligatorio cumplimiento en aquellos casos, como el presente, en que se están tratando datos de carácter personal de los interesados.

Sexto: Concurso de infracciones.

ORANGE entiende que en el acuerdo de inicio se hace referencia a un único hecho, sujeto y fundamento, que sería la adopción de medidas en el procedimiento de duplicado de la tarjeta SIM en los supuestos tasados de intervención manual, lo que constituiría un supuesto de concurso medial en la vía penal o una concurrencia de ofensas o delitos en vía administrativa, que aplica “siempre que la aplicación de una disposición impida o subsuma la aplicabilidad de la otra”, y que hace que resulte contrario al ordenamiento jurídico sancionar dos veces al infractor por el mismo ilícito.

ORANGE entiende que, del acuerdo de inicio se extrae que, en relación con los hechos analizados, existe una conexión directa entre las vulneraciones de los dos artículos.

De esta manera, la infracción del artículo 6.1 RGPD, o la existencia de un supuesto tratamiento de datos ilícito fue necesaria e inevitable para que tuviera lugar una vulneración del principio de privacidad desde el diseño y por defecto, derivada de no existir medidas de seguridad suficientes. de este modo, si **ORANGE** hubiera tenido medidas que permitiesen evitar el duplicado de la tarjeta SIM no se habría podido concluir la infracción del principio de privacidad por diseño y por defecto del artículo 25 del RGPD.

En consecuencia, se estaría dando un concurso de infracciones, ya que la comisión de una implicaría necesariamente la comisión de la otra.

No obstante, en relación con esta cuestión, hay que tener en cuenta que los artículos 6.1 y 25 se encuentran tipificados de manera diferenciada en el RGPD, se califican de manera diferenciada a efectos de prescripción por la LOPDGDD y cada uno de ellos goza de entidad propia.

Si la afirmación de **ORANGE** fuera cierta, no se tipificarían las infracciones a dichos artículos como infracciones diferentes.

De este modo, el artículo 6.1 del RGPD, establece los supuestos que permiten considerar lícito el tratamiento de datos personales.

En el presente supuesto, se imputaba a **ORANGE** la emisión de una tarjeta SIM a nombre de la parte reclamante, sin que ésta la hubiera solicitado y su entrega a un tercero no autorizado.

ORANGE así lo ha reconocido, tanto en su escrito de fecha 30 de enero de 2023, como en su escrito de fecha 30 de marzo de 2023, afirmando que dicho duplicado se habría producido, el día 15 de noviembre de 2022, sin que éste hubiera sido solicitado por la parte reclamante.

Por tanto, **ORANGE** expidió una tarjeta SIM a un tercero que no era el titular de la línea, y sin seguir el procedimiento implantado por ella misma, puesto que el duplicado de la tarjeta se ha expedido sin que hubiera sido solicitado por la titular de la línea. En definitiva, realizó estas operaciones de tratamiento de datos personales sin que concurriera ninguna de las bases de legitimación que contempla el art. 6 del RGPD.

En consecuencia, ha quedado en entredicho la diligencia empleada por **ORANGE** en la identificación de la persona que solicita el duplicado.

En ese sentido el Considerando 40 del RGPD señala:

“(40) Para que el tratamiento sea lícito, los datos personales deben ser tratados con el consentimiento del interesado o sobre alguna otra base legítima establecida conforme a Derecho, ya sea en el presente Reglamento o en virtud de otro Derecho de la Unión o de los Estados miembros a que se refiera el presente Reglamento, incluida la necesidad de cumplir la obligación legal aplicable al responsable del tratamiento o la necesidad de ejecutar un contrato en el que sea parte el interesado o con objeto de tomar medidas a instancia del interesado con anterioridad a la conclusión de un contrato.”

Por otro lado, con carácter general, **ORANGE** trata los datos de sus clientes al amparo de lo previsto en el artículo 6.1.b) del RGPD, cuando se considera un tratamiento necesario para la ejecución de un contrato en el que el interesado es parte o para la aplicación a petición de éste de medidas precontractuales. Para el resto de los casos, la licitud del tratamiento se fundamenta en las bases previstas en el artículo 6.1.a) c), e) y f) del RGPD.

Como ya se ha señalado anteriormente, el tratamiento realizado por **ORANGE**, en este caso, no se puede basar en lo previsto en el apartado b del artículo 6.1, ya que

este duplicado de tarjeta SIM no se basaba en la ejecución de ningún contrato, al no ser necesario para su ejecución ni haber sido solicitado por la parte reclamante, tampoco el tratamiento se basaba en alguna otra de las previstas en el artículo 6.

Por otro lado, el artículo 25 del RGPD dispone:

“1. Teniendo en cuenta el estado de la técnica, el coste de la aplicación y la naturaleza, ámbito, contexto y fines del tratamiento, así como los riesgos de diversa probabilidad y gravedad que entraña el tratamiento para los derechos y libertades de las personas físicas, el responsable del tratamiento aplicará, tanto en el momento de determinar los medios de tratamiento como en el momento del propio tratamiento, medidas técnicas y organizativas apropiadas, como la seudonimización, concebidas para aplicar de forma efectiva los principios de protección de datos, como la minimización de datos, e integrar las garantías necesarias en el tratamiento, a fin de cumplir los requisitos del presente Reglamento y proteger los derechos de los interesados.

2. El responsable del tratamiento aplicará las medidas técnicas y organizativas apropiadas con miras a garantizar que, por defecto, solo sean objeto de tratamiento los datos personales que sean necesarios para cada uno de los fines específicos del tratamiento. Esta obligación se aplicará a la cantidad de datos personales recogidos, a la extensión de su tratamiento, a su plazo de conservación y a su accesibilidad. Tales medidas garantizarán en particular que, por defecto, los datos personales no sean accesibles, sin la intervención de la persona, a un número indeterminado de personas físicas.

3. Podrá utilizarse un mecanismo de certificación aprobado con arreglo al artículo 42 como elemento que acredite el cumplimiento de las obligaciones establecidas en los apartados 1 y 2 del presente artículo.”

Como puede observarse, dicho artículo parte de la necesidad de tener en cuenta una serie de elementos:

- Estado de la técnica
- Coste de la aplicación
- Naturaleza, ámbito, contexto y fines del tratamiento
- Riesgos que entraña el tratamiento para los derechos y libertades de las personas físicas.

Además, impone una obligación al responsable, que es quien determina los fines y los medios del tratamiento, dándose especial relevancia a los medios.

Y debe aplicar, tanto al determinar los medios del tratamiento, como en el momento del propio tratamiento, medidas técnicas y organizativas apropiadas, concebidas para aplicar de forma efectiva los principios de protección de datos e integrar las garantías que sean necesarias en el tratamiento.

Con ello, se persigue un doble fin:

- cumplir los requisitos del RGPD
- proteger los derechos de los interesados.

En este punto, también es necesario tener en cuenta lo dispuesto en el considerando 78 del RGPD anteriormente reproducido.

De este modo, las medidas que prevé el artículo 25 del RGPD no son medidas de seguridad exclusivamente, sino que se pretende que la empresa u organización tenga integrada dentro de la misma, de su organización, de su funcionamiento ordinario, la protección de datos de carácter personal desde el diseño. Es decir, que sea parte integrante y relevante dentro de la misma, antes incluso de iniciarse materialmente el tratamiento de datos personales, desde la toma de decisiones o del momento de la planificación.

La obligación afecta a toda la organización e implica un proceso continuo de revisión y retroalimentación con el fin de verificar si todas las medidas técnicas y organizativas existentes, de todo tipo e implementadas por la organización resultan adecuadas con el fin de cumplir los requisitos del RGPD y proteger los derechos de los interesados. De esta forma, en caso de no resultar adecuadas, podrían ser modificadas, o en su caso, reforzadas, incorporando nuevas medidas que garanticen una más adecuada protección de los datos de carácter personal.

Por lo tanto, de conformidad con todo ello, se puede apreciar que la perspectiva o el ángulo a través del cual se contempla la realidad es diferente a lo previsto en el artículo 6 del RGPD.

En este sentido, el RGPD articula un sistema completo destinado a garantizar la protección de los datos de carácter personal de los ciudadanos, y para ello, va centrando su atención en distintos aspectos que deben ser examinados por los responsables o encargados del tratamiento.

Cada artículo constituye un ángulo desde el que observar la realidad con el fin de articular las medidas que garanticen una adecuada protección de los datos de carácter personal, y que deben ser tenidos en cuenta para articular una protección acorde con lo dispuesto en el RGPD.

En su escrito de alegaciones al acuerdo de inicio **ORANGE** pone de manifiesto que *“la infracción del artículo 6.1 RGPD, o la existencia de un supuesto tratamiento de datos ilícito fue necesaria e inevitable para que tuviera lugar una vulneración del principio de privacidad desde el diseño y por defecto, derivada de no existir medidas de seguridad suficientes. De este modo, si ORANGE hubiera tenido medidas que permitiesen evitar el duplicado de la tarjeta SIM no se habría podido concluir la infracción del principio de privacidad por diseño y por defecto del artículo 25 del RGPD”*.

Sin embargo, esta manifestación no puede ser acogida, pues como se ha indicado se trata de infracciones que requieren para su comisión la concurrencia de distintos elementos, así, por un lado, resulta necesario para la comisión de la infracción del artículo 6 del RGPD, la realización de un tratamiento de datos personales sin haber comprobado diligentemente que concurría una base de legitimación para ello. Y por otro, la infracción del artículo 25 requiere la falta o deficiente implantación desde el diseño de medidas apropiadas para cumplir con el RGPD, lo que puede suceder independientemente de que se produzca un tratamiento de datos sin base de

legitimación. Obviamente en ambas infracciones ha de concurrir falta de diligencia, pero respecto de conductas diferentes.

ORANGE cita la Sentencia de la Audiencia Nacional de 24 de abril de 2013, Rec. 69/2011 según la cual:

“Para enjuiciar esta según infracción deviene esencial, a juicio de la Sala, hacer referencia al concurso de infracciones cuya existencia se invoca igualmente en la demanda. A tal fin ha de traerse a colación lo dispuesto en el artículo 4.4 del Real Decreto 1398/1993, según el cual: en defecto de regulación específica establecida en la norma correspondiente, cuando de la comisión de una infracción derive necesariamente la comisión de otra u otras, se deberá imponer únicamente la sanción correspondiente a la infracción más grave cometida.

Precepto que ha sido interpretado por la STS de 8 de febrero de 1999 (Rec. 9/1996) en el sentido de que la aplicación del concurso medial exige una necesaria derivación de unas infracciones respecto de las demás y viceversa, por lo que es indispensable que las unas no puedan cometerse sin ejecutar las otras”

Entiende **ORANGE** que, en caso de apreciarse una infracción de los artículos 6.1 y 25 del RGPD se trataría de infracciones concurrentes, y que la sanción aplicable sería en todo caso la correspondiente al incumplimiento del artículo 6.1 RGPD, teniendo en cuenta lo dispuesto en el artículo 29.5 de la Ley 40/2015, de 1 de octubre, de Régimen Jurídico del Sector Público, según el cual:

“cuando de la comisión de una infracción derive necesariamente la comisión de otra u otras, se deberá imponer únicamente la sanción correspondiente a la infracción más grave cometida.”

No obstante, hay que tener en cuenta, además de lo anteriormente manifestado por esta Agencia, que, en primer lugar, el artículo 29 de la LRJSP no resulta de aplicación al régimen sancionador impuesto por el RGPD.

1. El RGPD es un sistema completo.

El RGPD es una norma comunitaria directamente aplicable en los Estados miembros, que contiene un sistema nuevo, cerrado, completo y global destinado a garantizar la protección de datos de carácter personal de manera uniforme en toda la Unión Europea.

En relación, específicamente y también, con el régimen sancionador dispuesto en el mismo, resultan de aplicación sus disposiciones de manera inmediata, directa e íntegra previendo un sistema completo y sin lagunas que ha de entenderse, interpretarse e integrarse de forma absoluta, completa, íntegra, dejando así indemne su finalidad última que es la garantía efectiva y real del derecho fundamental a la Protección de Datos de Carácter Personal. Lo contrario determina la merma de las garantías de los derechos y libertades de los ciudadanos.

De hecho, una muestra específica de la inexistencia de lagunas en el sistema del RGPD es el artículo 83 del RGPD que determina las circunstancias que pueden operar como agravantes o atenuantes respecto de una infracción (art. 83.2 del RGPD) o que

especifica la regla existente relativa a un posible concurso medial (art. 83.3 del RGPD).

A lo anterior hemos de sumar que el RGPD no permite el desarrollo o la concreción de sus previsiones por los legisladores de los Estados miembros, a salvo de aquello que el propio legislador europeo ha previsto específicamente, delimitándolo de forma muy concreta (por ejemplo, la previsión del art. 83.7 del RGPD). La LOPDGDD sólo desarrolla o concreta algunos aspectos del RGPD en lo que este le permite y con el alcance que éste le permite.

Ello es así porque la finalidad pretendida por el legislador europeo es implantar un sistema uniforme en toda la Unión Europea que garantice los derechos y libertades de las personas físicas, que corrija comportamientos contrarios al RGPD, que fomente el cumplimiento, que posibilite la libre circulación de estos datos.

En este sentido, el considerando 2 del RGPD determina que,

“(2) Los principios y normas relativos a la protección de las personas físicas en lo que respecta al tratamiento de sus datos de carácter personal deben, cualquiera que sea su nacionalidad o residencia, respetar sus libertades y derechos fundamentales, en particular el derecho a la protección de los datos de carácter personal. El presente Reglamento pretende contribuir a la plena realización de un espacio de libertad, seguridad y justicia y de una unión económica, al progreso económico y social, al refuerzo y la convergencia de las economías dentro del mercado interior, así como al bienestar de las personas físicas”. (el subrayado es nuestro)

Sigue indicando el considerando 13 del RGPD que,

“(13) Para garantizar un nivel coherente de protección de las personas físicas en toda la Unión y evitar divergencias que dificulten la libre circulación de datos personales dentro del mercado interior, es necesario un reglamento que proporcione seguridad jurídica y transparencia a los operadores económicos, incluidas las microempresas y las pequeñas y medianas empresas, y ofrezca a las personas físicas de todos los Estados miembros el mismo nivel de derechos y obligaciones exigibles y de responsabilidades para los responsables y encargados del tratamiento, con el fin de garantizar una supervisión coherente del tratamiento de datos personales y sanciones equivalentes en todos los Estados miembros, así como la cooperación efectiva entre las autoridades de control de los diferentes Estados miembros. El buen funcionamiento del mercado interior exige que la libre circulación de los datos personales en la Unión no sea restringida ni prohibida por motivos relacionados con la protección de las personas físicas en lo que respecta al tratamiento de datos personales”. (el subrayado es nuestro)

En este sistema, lo determinante del RGPD no son las multas. Los poderes correctivos de las autoridades de control previstos en el art. 58.2 del RGPD conjugado con las disposiciones del art. 83 del RGPD muestran la prevalencia de medidas correctivas frente a las multas.

Así, el art. 83.2 del RGPD dice que *“Las multas administrativas se impondrán, en función de las circunstancias de cada caso individual, a título adicional o sustitutivo de las medidas contempladas en el artículo 58, apartado 2, letras a) a h) y j).”*

De esta forma las medidas correctivas, que son todas las previstas en el art. 58.2 de RGPD salvo la multa, tienen prevalencia en este sistema, quedando relegada la multa económica a supuestos en los que las circunstancias del caso concreto determinen que se imponga una multa junto con las medidas correctiva o en sustitución de las mismas.

Y todo ello con la finalidad de forzar el cumplimiento del RGPD, evitar el incumplimiento, fomentar el cumplimiento y que la infracción no resulte más rentable que el incumplimiento.

Por ello, el art. 83.1 del RGPD previene que *“Cada autoridad de control garantizará que la imposición de las multas administrativas con arreglo al presente artículo por las infracciones del presente Reglamento indicadas en los apartados 4, 5 y 6 sean en cada caso individual efectivas, proporcionadas y disuasoria”*.

Las multas han de ser efectivas, proporcionadas y disuasorias para la consecución de la finalidad pretendida por el RGPD.

Para que dicho sistema funcione con todas sus garantías es necesario que varios elementos se desplieguen de forma íntegra y completa. La aplicación de reglas ajenas al RGPD respecto de la determinación de las multas en cada uno de los Estados miembros aplicando su derecho nacional, ya sea por circunstancias agravantes o atenuantes no previstas en el RGPD -o en la LOPDGDD en el caso español-, ya sea por la aplicación de un concurso medial distinto del dispuesto en el RGPD, restaría efectividad al sistema que perdería su sentido, su finalidad teleológica, resultando que las multas impuestas por distintas infracciones dejarían de ser efectivas, proporcionadas y disuasorias. Y de esta forma también se hurtaría a los interesados de la garantía efectiva de sus derechos y libertades, debilitando la aplicación uniforme del RGPD. Se disminuirían los mecanismos de protección de los derechos y las libertades de los ciudadanos y sería contrario con el espíritu del RGPD.

El RGPD está dotado de su propio principio de proporcionalidad que ha de ser aplicado en sus estrictos términos.

2. No hay laguna legal, no hay aplicación supletoria del art. 29 del RGPD.

Amén de lo expuesto, significar que no hay laguna legal respecto de la aplicación del concurso medial. Ni el RGPD permite ni la LOPDGDD dispone la aplicación supletoria de las previsiones del art. 29 de la LRJSP.

En el Título VIII de la LOPDGDD relativo a “Procedimientos en caso de posible vulneración de la normativa de protección de datos”, el artículo 63 que abre el Título se dispone que *“Los procedimientos tramitados por la Agencia Española de Protección de Datos se regirán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos.”* Si bien existe una remisión clara a la LPACAP, no se

establece en absoluto una aplicación subsidiaria respecto de la LRJSP que no contiene en su articulado disposición alguna relativa a procedimiento administrativo alguno.

De igual forma que la AEPD no está aplicando los agravantes y atenuantes dispuestos en el art. 29 de la LRJSP, puesto que el RGPD establece los suyos propios, por ende, no hay laguna legal ni aplicación subsidiaria del mismo, tampoco cabe la aplicación de apartado relativo al concurso medial y por idénticas razones.

En el supuesto concreto examinado, y sin perjuicio de lo antedicho, se debe destacar que no hay concurso medial.

El artículo 29.5 de la LRJSP establece que *“Cuando de la comisión de una infracción derive necesariamente la comisión de otra u otras, se deberá imponer únicamente la sanción correspondiente a la infracción más grave cometida”*.

Pues bien, el concurso medial tiene lugar cuando en un caso concreto la comisión de una infracción es un medio necesario para cometer otra distinta.

Los hechos constados determinan, como se ha dicho, la comisión de dos infracciones distintas, sin que la conculcación del artículo 6 del RGPD (falta de legitimación en la emisión del duplicado de la tarjeta SIM de la parte reclamante), tal y como asevera **ORANGE**, sea el medio necesario por el que se produce la infracción del artículo 25 del RGPD.

Por último, **ORANGE** hace referencia a las Directrices 4/2022 sobre el cálculo de multas administrativas bajo el RGPD, donde se estipulan los criterios que debe seguir la autoridad administrativa para evaluar, de forma previa a la imposición de la sanción, la posible concurrencia de éstas.

En relación con la cita de las Directrices 04/2022 del CEPD sobre el cálculo de multas administrativas conforme al RGPD, en su versión 2.1, adoptadas el 24 de mayo de 2023, en su apartado 22 se hace referencia a tres tipos de concurrencias, a saber, de infracción, unidad de acción y pluralidad de acciones:

“Al examinar el análisis de las tradiciones de los Estados miembros en materia de normas de concurrencia, tal como se indica en la jurisprudencia del TJUE5, y teniendo en cuenta los diferentes ámbitos de aplicación y las consecuencias jurídicas, estos principios pueden agruparse aproximadamente en las tres categorías siguientes: - Concurrencia de infracciones (capítulo 3.1.1), - Unidad de acción (capítulo 3.1.2), - Pluralidad de acciones (capítulo 3.2).

En los supuestos de concurrencia de infracciones la previsión establecida al respecto es la contenida en el artículo 83.3 del RGPD que establece un límite cuantitativo en estos supuestos de concurrencia:

“Si un responsable o un encargado del tratamiento incumpliera de forma intencionada o negligente, para las mismas operaciones de tratamiento u operaciones vinculadas, diversas disposiciones del presente Reglamento, la cuantía total de la multa

administrativa no será superior a la cuantía prevista para las infracciones más graves.”
(el subrayado es nuestro).

Si admitiéramos el argumento esgrimido por **ORANGE** podría extraerse que la “plena aplicabilidad del concurso medial” referido a la aplicación preferente del artículo 29 de la LRJSP, en su única pretensión de pagar una única multa en lugar de las dos impuestas, desplazan o anulan la vigencia del artículo 83.3 del RGPD, por lo que resulta contrario al ordenamiento jurídico.

Por último, y no menos importante, la AEPD no sanciona por una misma ofensa, como aduce **ORANGE**, sino que se han constatado a través de hechos probados la comisión de dos infracciones diferenciadas, tipificadas de forma diferenciada, no existiendo, además, en el caso concreto, concurso medial.

Por todo lo expuesto, se desestima la presente alegación.

Séptima: Sobre la inadmisibilidad de la responsabilidad objetiva.

En relación con esta cuestión, **ORANGE** pone de manifiesto que el acuerdo de inicio del presente expediente sancionador se basa en un análisis de resultado, en la medida en que consideraría que la emisión del duplicado de la tarjeta SIM conlleva automáticamente la consideración de que no se tomaron medidas adecuadas, surgiendo así automáticamente la responsabilidad directa por parte de **ORANGE**, estableciéndose una obligación de resultado.

ORANGE añade que esta AEPD limita la obligación al resultado, al señalar que la superación de las medidas por los agentes de **ORANGE** conlleva la consideración automática de que las medidas eran insuficientes, y que este hecho supone adoptar un principio de responsabilidad objetiva vetado por nuestro ordenamiento jurídico en numerosas ocasiones por el Tribunal Constitucional.

Contrariamente, esta Agencia considera que se han puesto de manifiesto las deficiencias observadas en las medidas desde el diseño adoptadas por **ORANGE** que evidencian el incumplimiento del art. 25 del RGPD.

En el presente procedimiento se está analizando el riesgo existente que se produce a partir de la aplicación llamada PSD2, que es cuando se empieza a realizar el tipo de fraude detallado en el presente expediente sancionador, mediante la utilización de un duplicado de tarjeta SIM obtenido indebidamente por persona distinta a su titular.

Así, la infracción devino no solo por la carencia de unas medidas para la expedición de los duplicados SIM, sino por la necesidad de su revisión y refuerzo. Así se determina en el artículo 25 del RGPD cuando establece: “...*el responsable del tratamiento aplicará, tanto en el momento de determinar los medios del tratamiento como en el momento del propio tratamiento, medidas técnicas y organizativas apropiadas...*”

No basta con implantar unas medidas técnicas y organizativas, sino que hay que adecuarlas y revisarlas para mitigar los riesgos. El continuo avance de la tecnología y la evolución de los tratamientos propician la aparición continua de nuevos riesgos que deben ser gestionados, como ocurre con el ataque SIM swapping, utilizado desde

hace tiempo por los ciberdelincuentes para llevar a cabo la estafa informática. No se trata de una operativa desconocida para **ORANGE** cuyo uso haya podido sorprenderla, por lo que al evaluar los riesgos debió tener en cuenta éste, que se traduce en una mayor utilización por los delincuentes de mecanismos para apoderarse del duplicado de las tarjetas SIM de los clientes, lo que no puede ser ignorado por **ORANGE**. En este contexto, el RGPD exige que los responsables del tratamiento revisen las medidas desde el diseño, estableciendo las adecuadas para demostrar que se garantizan los derechos y libertades de las personas, teniendo en cuenta entre otros, los “riesgos de diversa probabilidad y gravedad para los derechos y libertades de las personas físicas” (artículo 24.1) aplicando las medidas oportunas.

En el presente supuesto, las medidas técnicas y organizativas implementadas desde el diseño no han resultado eficaces, tal y como se ha constatado en el presente procedimiento sancionador.

Las medidas técnicas y organizativas deben garantizar un nivel el de protección adecuado al riesgo, lo que en este caso no se ha hecho.

Para seleccionar las medidas adecuadas, el responsable debe basarse en los riesgos para las personas físicas, así como en lo que es razonable y técnicamente posible. El artículo 28.2.a) de LOPDGD establece algunos supuestos en los que ya avisa que es necesario tratar mayores riesgos que los que el responsable pudiera estimar si sólo tuviera en cuenta sus propios intereses (usurpación de identidad, perjuicios económicos...).

Como ya se ha señalado anteriormente en este procedimiento sancionador, la tarjeta SIM constituye el soporte físico a través del cual se accede a los datos de carácter personal de la persona afectada. Si no se garantiza su disposición y control, el acceso a los datos personales del titular, así como el uso o usos posibles por terceros, se convierte en una amenaza que puede tener efectos devastadores en la vida de estas personas.

El Tribunal Constitucional señaló en su Sentencia 94/1998, de 4 de mayo, que nos encontramos ante un derecho fundamental a la protección de datos por el que se garantiza a la persona el control sobre sus datos, cualesquiera datos personales, y sobre su uso y destino, para evitar el tráfico ilícito de los mismos o lesivo para la dignidad y los derechos de los afectados; de esta forma, el derecho a la protección de datos se configura como una facultad del ciudadano para oponerse a que determinados datos personales sean usados para fines distintos a aquel que justificó su obtención.

El enfoque de riesgos y el modelo flexible al riesgo impuesto por el RGPD -partiendo de la doble configuración de la seguridad como un principio relativo al tratamiento y una obligación para el responsable o el encargado del tratamiento- no impone en ningún caso la infalibilidad de las medidas, sino su adecuación constante a un riesgo, que, como en el supuesto examinado es cierto, probable y no desdeñable, alto y con un impacto muy significativo en los derechos y libertades de los ciudadanos.

En la instrucción del procedimiento se ha constatado que no se habían adaptado las medidas técnicas y organizativas desde el diseño a los riesgos que supone la

evolución tecnológica, lo que pone en grave riesgo los derechos de los interesados, pues las medidas no eran eficaces para evitar o mitigar el mayor riesgo de fraude que podía generarse en la solicitud de duplicados de tarjetas SIM, con la finalidad de perpetrar un ataque de *SIM swapping*.

Además, **ORANGE** no puede negar el hecho de que trata datos de carácter personal a gran escala. De este modo, efectivamente, en materia sancionadora rige el principio de culpabilidad (STC 15/1999, de 4 de julio; 76/1990, de 26 de abril; y 246/1991, de 19 de diciembre), lo que significa que ha de concurrir alguna clase de dolo o culpa. Como dice la STS de 23 de enero de 1998 , *"...puede hablarse de una decidida línea jurisprudencial que rechaza en el ámbito sancionador de la Administración la responsabilidad objetiva, exigiéndose la concurrencia de dolo o culpa, en línea con la interpretación de la STC 76/1990, de 26 de abril , al señalar que el principio de culpabilidad puede inferirse de los principios de legalidad y prohibición de exceso (artículo 25 de la Constitución) o de las exigencias inherentes al Estado de Derecho"*.

La falta de diligencia a la hora de implementar en origen las medidas adecuadas para comprobar que la persona que solicita o activa el duplicado de una tarjeta SIM es el titular de esta es, precisamente, lo que constituye el elemento de la culpabilidad.

En cuanto a que **ORANGE** fue víctima de fraude, cabe señalar, además, que **ORANGE** debe estar en disposición de establecer mecanismos que impidan que se produzca la duplicación fraudulenta de las tarjetas SIM, medidas que respeten la integridad y confidencialidad de los datos y que impidan que un tercero acceda a datos que no son de su titularidad, pues precisamente compete a la operadora tratar datos de carácter personal conforme al RGPD (considerandos 76, 77, 78, 79, 81 y 83 RGPD; artículo 32 del RGPD y artículo 28 de la LOPDGGD).

Las pruebas periódicas, la medición y la evaluación de la efectividad de las medidas técnicas y organizativas aplicadas al tratamiento son responsabilidad de cada responsable y encargado del tratamiento conforme al RGPD.

Por lo tanto, **ORANGE** como responsable del tratamiento está obligada a verificar tanto la selección como el nivel de efectividad de los medios técnicos y organizativos utilizados. La exhaustividad de esta verificación debe evaluarse a través del prisma de adecuación a los riesgos y la proporcionalidad en relación con el estado del conocimiento técnico, los costos de implementación y la naturaleza, el alcance, el contexto y los propósitos del tratamiento.

Ciertamente, el principio de responsabilidad previsto en el artículo 28 de la LRJSP, dispone que: "Sólo podrán ser sancionadas por hechos constitutivos de infracción administrativa las personas físicas y jurídicas, así como, cuando una Ley les reconozca capacidad de obrar, los grupos de afectados, las uniones y entidades sin personalidad jurídica y los patrimonios independientes o autónomos, que resulten responsables de los mismos a título de dolo o culpa."

No obstante, el modo de atribución de responsabilidad a las personas jurídicas no se corresponde con las formas de culpabilidad dolosas o imprudentes que son imputables a la conducta humana. De modo que, en el caso de infracciones cometidas por personas jurídicas, aunque haya de concurrir el elemento de la culpabilidad, éste se

aplica necesariamente de forma distinta a como se hace respecto de las personas físicas.

Según la STC 246/1991 "(...) esta construcción distinta de la imputabilidad de la autoría de la infracción a la persona jurídica nace de la propia naturaleza de ficción jurídica a la que responden estos sujetos. Falta en ellos el elemento volitivo en sentido estricto, pero no la capacidad de infringir las normas a las que están sometidos.

Capacidad de infracción y, por ende, reprochabilidad directa que deriva del bien jurídico protegido por la norma que se infringe y la necesidad de que dicha protección sea realmente eficaz y por el riesgo que, en consecuencia, debe asumir la persona jurídica que está sujeta al cumplimiento de dicha norma" (en este sentido STS de 24 de noviembre de 2011, Rec 258/2009).

A lo expuesto debe añadirse, siguiendo la sentencia de 23 de enero de 1998, parcialmente trascrita en las SSTs de 9 de octubre de 2009, Rec 5285/2005, y de 23 de octubre de 2010, Rec 1067/2006, que "aunque la culpabilidad de la conducta debe también ser objeto de prueba, debe considerarse en orden a la asunción de la correspondiente carga, que ordinariamente los elementos volitivos y cognoscitivos necesarios para apreciar aquélla forman parte de la conducta típica probada, y que su exclusión requiere que se acredite la ausencia de tales elementos, o en su vertiente normativa, que se ha empleado la diligencia que era exigible por quien aduce su inexistencia; no basta, en suma, para la exculpación frente a un comportamiento típicamente antijurídico la invocación de la ausencia de culpa".

La responsabilidad última sobre el tratamiento sigue estando atribuida al responsable del tratamiento, que es quien determina la existencia del tratamiento y su finalidad. Recordemos que, las operadoras tratan los datos de sus clientes determinando fines y medios. Por tanto, es responsabilidad de las operadoras (**ORANGE**, en el presente caso) implementar las medidas apropiadas que garanticen el cumplimiento del RGPD, de modo que, si tal principio se ve comprometido debido a la falta de diligencia a la hora de implementar medidas suficientes para ello, se imputará la responsabilidad de tal infracción a la operadora en cuestión.

En este sentido, la Sentencia de la Audiencia Nacional de 9 de febrero de 2023 recoge:

"El principio de culpabilidad derivado del artículo 25CE, según señaló la STC 246/1991, de 19 de diciembre, constituye un principio estructural básico del Derecho administrativo sancionador, y aparece reconocido en el artículo 28.1 de la Ley 40/2015, de 1 de octubre, de Régimen Jurídico del Sector Público al disponer que: "Sólo podrán ser sancionadas por hechos constitutivos de infracción administrativa las personas físicas o jurídicas (...) que resulten responsables de los mismos a título de dolo o culpa".

Por eso, como señala la STS de 18 marzo 2005, Rec. 7707/2000, es evidente, «que no podría estimarse cometida una infracción administrativa, si no concurriera el elemento subjetivo de la culpabilidad o lo que es igual, si la conducta típicamente constitutiva de infracción administrativa, no fuera imputable a dolo o a culpa".

Respecto a que no se habían identificado los riesgos que se ceñían sobre el duplicado de las tarjetas SIM con anterioridad a la aplicación de la Directiva PSD2, cabe señalar que ya en la resolución recurrida se indica -página 872- “En el presente procedimiento, no se está analizando el riesgo existente antes de la aplicación de la llamada PSD2 sino el que se produce a partir de su aplicación, que es cuando se empieza a utilizar el fraude mediante la utilización de un duplicado de una tarjeta SIM obtenido indebidamente por persona distinta de su titular (...) en el presente caso las medidas de seguridad implementadas no resultan suficientes para garantizar la confidencialidad del dato personal en cuestión”

Ahora bien, a mayor abundamiento, resulta claro que el riesgo de suplantación de identidad está presente de manera permanente en la actividad empresarial de (...). Es un riesgo real con la finalidad última de hacerse pasar por otra persona y que procura, en supuestos como el examinado, la contratación de productos o la obtención de un duplicado de la tarjeta SIM por quien no es el auténtico titular de la misma, riesgo que la recurrente no puede alegar que le resultaba desconocido.

Sobre la supuesta responsabilidad objetiva, la resolución recurrida no considera responsable a (...) por el resultado, sino por una pérdida de confidencialidad vinculada a la insuficiencia de las medidas de seguridad implantadas y, en definitiva, debido a una falta de diligencia de dicha entidad.

(...)

Esa falta de diligencia de (...), como responsable del tratamiento, a la hora de implementar en origen las medidas de seguridad adecuadas para comprobar que la persona que solicita o activa el duplicado de la tarjeta SIM es el titular de ésta es lo que constituye el elemento de la culpabilidad.

En consecuencia, concurre el elemento subjetivo de la culpabilidad necesario para poder sancionar, incompatible con la existencia del error invencible alegado. Las medidas de seguridad implementadas con posterioridad, no afectan a la comisión de la infracción y contrariamente a lo pretendido por la actora no pueden amparar la aplicación de una eximente, sin perjuicio de que hayan sido tomada en consideración como atenuante del artículo 83.2.c) del RGPD a la hora de fijar la sanción.»

Por lo tanto, no puede ser tenida en cuenta la alegación presentada por **ORANGE**.

Octava: Acerca de las medidas adoptadas e implementadas por **ORANGE**.

ORANGE hace referencia a todas las medidas implantadas en relación con el procedimiento de emisión de duplicados de tarjeta Sim, tanto de manera previa como las implantadas a posterior.

En este sentido, hace referencia a:

1. Medidas implementadas para prevenir la comisión de fraudes derivados de la suplantación de identidad.

2. Medidas implementadas por **ORANGE** para prevenir la comisión de fraudes derivados de la suplantación de agentes y/o empleados de **ORANGE**.

3. Medidas adoptadas por **ORANGE** con relación al presente supuesto, no incardinado en los apartados anteriores.

Esta cuestión ya ha sido contestada en el apartado quinto de la contestación a estas alegaciones al que nos remitimos.

Novena: Falta de proporcionalidad de la sanción impuesta.

ORANGE realiza esta afirmación manifestando haber demostrado haber actuado con la diligencia debida en la implementación de medidas en los procesos de duplicados de tarjetas SIM, y que en este supuesto los agentes actuaron de manera individual y dolosa rompiendo los estándares y protocolos de la compañía.

En todo caso, entiende que la sanción incluida en el acuerdo de inicio es desproporcionada atendiendo a las circunstancias y contenido de la supuesta infracción, que **ORANGE** niega.

En relación con el incumplimiento del principio de proporcionalidad, el RGPD prevé expresamente la posibilidad de graduación, mediante la previsión de multas susceptibles de modulación, en atención a una serie de circunstancias de cada caso individual efectivas, proporcionadas y disuasorias (artículo 83.1 y 2 RGPD), condiciones generales para la imposición de las multas administrativas que sí han sido objeto de análisis por esta Agencia, a las que hay que sumar los criterios de graduación previstos en la LOPDGDD.

Hay que señalar que la multa administrativa acordada será efectiva porque conducirá a la compañía a aplicar las medidas técnicas y organizativas que garanticen los derechos y libertades de los interesados, habida cuenta del valor de la criticidad del tratamiento.

También es proporcional a la vulneración identificada, en particular a su gravedad, el círculo de personas físicas afectadas y los riesgos en los que se han incurrido y a la situación financiera de la compañía.

Y, por último, es disuasoria. Una multa disuasoria es aquella que tiene un efecto disuasorio genuino. A este respecto, la Sentencia del TJUE, de 13 de junio de 2013, Versalis Spa/Comisión, C-511/11, ECLI:EU:C:2013:386, dice:

“94. Respecto, en primer lugar, a la referencia a la sentencia Showa Denko/Comisión, antes citada, es preciso señalar que Versalis la interpreta incorrectamente. En efecto, el Tribunal de Justicia, al señalar en el apartado 23 de dicha sentencia que el factor disuasorio se valora tomando en consideración una multitud de elementos y no sólo la situación particular de la empresa de que se trata, se refería a los puntos 53 a 55 de las conclusiones presentadas en aquel asunto por el Abogado General Geelhoed, que había señalado, en esencia, que el coeficiente multiplicador de carácter disuasorio puede tener por objeto no sólo una «disuasión

general», definida como una acción para desincentivar a todas las empresas, en general, de que cometan la infracción de que se trate, sino también una «disuasión específica», consistente en disuadir al demandado concreto para que no vuelva a infringir las normas en el futuro. Por lo tanto, el Tribunal de Justicia sólo confirmó, en esa sentencia, que la Comisión no estaba obligada a limitar su valoración a los factores relacionados únicamente con la situación particular de la empresa en cuestión.”

“102. Según reiterada jurisprudencia, el objetivo del factor multiplicador disuasorio y de la consideración, en este contexto, del tamaño y de los recursos globales de la empresa en cuestión reside en el impacto deseado sobre la citada empresa, ya que la sanción no debe ser insignificante, especialmente en relación con la capacidad financiera de la empresa (en este sentido, véanse, en particular, la sentencia de 17 de junio de 2010, Lafarge/Comisión, C-413/08 P, Rec. p. I-5361, apartado 104, y el auto de 7 de febrero de 2012, Total y Elf Aquitaine/Comisión, C-421/11 P, apartado 82).”

La Sentencia de fecha 11 de mayo de 2006 dictada en el recurso de casación 7133/2003 establece que: *“Ha de tenerse en cuenta, además, que uno de los criterios rectores de la aplicación de dicho principio régimen sancionador administrativo (criterio recogido bajo la rúbrica de «principio de proporcionalidad» en el apartado 2 del artículo 131 de la citada Ley 30/1992) es que la imposición de sanciones pecuniarias no debe suponer que la comisión de las infracciones tipificadas resulte más beneficiosa para el infractor que el cumplimiento de las normas infringidas”.*

También es importante la jurisprudencia que resulta de la Sentencia de la Sala Tercera del Tribunal Supremo, dictada en fecha 27 de mayo de 2003 (rec. 3725/1999) que dice: *La proporcionalidad, perteneciente específicamente al ámbito de la sanción, constituye uno de los principios que rigen en el Derecho Administrativo sancionador, y representa un instrumento de control del ejercicio de la potestad sancionadora por la Administración dentro, incluso, de los márgenes que, en principio, señala la norma aplicable para tal ejercicio. Supone ciertamente un concepto difícilmente determinable a priori, pero que tiende a adecuar la sanción, al establecer su graduación concreta dentro de los indicados márgenes posibles, a la gravedad del hecho constitutivo de la infracción, tanto en su vertiente de la antijudicialidad como de la culpabilidad, ponderando en su conjunto las circunstancias objetivas y subjetivas que integran el presupuesto de hecho sancionable -y, en particular, como resulta del artículo 131.3 LRJ y PAC, la intencionalidad o reiteración, la naturaleza de los perjuicios causados y la reincidencia-. (SSTS 19 de julio de 1996, 2 de febrero de 1998 y 20 de diciembre de 1999, entre otras muchas).*

En este caso, **ORANGE** ponía de manifiesto que había demostrado haber actuado con diligencia en los procesos de duplicados de tarjeta SIM, y que, en este supuesto, los agentes actuaron de manera individual y dolosa rompiendo los protocolos de la compañía.

De este modo, desde esta AEPD se quiere señalar que, en este supuesto, no se está examinando la actuación de los agentes, sino que se está examinando la condición,

características y adecuación de las medidas adoptadas por **ORANGE**, y la actuación del responsable del tratamiento al respecto.

ORANGE quiere manifestar su disconformidad en la interpretación que realiza esta Agencia en relación con los agravantes:

a) la naturaleza, gravedad y duración de la infracción (artículo 83.2.a) RGPD.

ORANGE manifiesta que este agravante se apoya en la posible comisión de operaciones bancarias fraudulentas, y considera que no es aceptable jurídicamente utilizar como argumento el uso de las cuentas bancarias, los perjuicios monetarios de las víctimas de los fraudes o el modo en que se llevan a cabo estas operaciones por las entidades financieras para justificar la sanción impuesta, en la medida en que `las entidades bancarias son las únicas responsables de la seguridad de sus operaciones, tal y como afirma la Autoridad Bancaria Europea, en "Opinion on the implementation of the RTS on SCS anf CSC" puntos 37 y 38, y donde se determina que las credenciales de seguridad utilizadas para realizar la autenticación segura de los usuarios de los servicios de pago son responsabilidad de la entidad gestora de servicios de cuenta.

En este sentido, la Agencia considera que la naturaleza de la infracción es muy grave puesto que acarrea una pérdida de disposición y control sobre los datos personales. Ha permitido a los criminales robar la identidad mediante el secuestro del número de teléfono tras obtener un duplicado de su tarjeta SIM. Tras la entrada en vigor de la Directiva PSD2, como se ha indicado, el teléfono móvil ha pasado a desempeñar un rol muy importante en la realización de pagos online al ser necesario para la confirmación de transacciones, y convierte a este dispositivo -y por extensión a la tarjeta SIM-, en objetivo claro de los ciberdelincuentes.

Conviene señalar que la Directiva PSD2, se aplica a los servicios de pago prestados dentro de la Unión (artículo 2), y no a **ORANGE**, pero también es cierto que la expedición de un duplicado de tarjeta SIM a favor de un tercero que no es el titular de la línea, proporciona a los suplantadores el control de la línea telefónica, y por lo tanto, de los SMS dirigidos al teléfono vinculado a la tarjeta SIM inicial y de esta manera a poder acceder a conocer el código de autenticación de la transacción.

Es cierto que, previamente se han de conocer los datos de acceso a la banca online, pero también es necesario obtener el duplicado de la tarjeta SIM titularidad de la persona a defraudar con la finalidad de hacerse con los SMS de confirmación que el cliente recibirá en su terminal móvil como autenticación de doble factor, y es en esta acción (en la obtención del duplicado) lo que se ha tenido en cuenta en el presente procedimiento sancionador.

En relación con el agravante referido a la infracción del artículo 25 del RGPD **ORANGE** entiende que no habría que tener en cuenta a todos los clientes que tiene, ya que no todos son personas físicas, ni todos solicitan duplicado de la tarjeta SIM. Por ello, entiende que, en este supuesto, solo habría un único implicado que sería la persona que presentó la reclamación.

No obstante, esta Agencia ya ha determinado que la responsabilidad que se le imputa a **ORANGE** es por no contar con las medidas técnicas y organizativas adecuadas para garantizar desde el diseño la protección de datos de los clientes

La Agencia considera que el nivel de los posibles perjuicios es alto, ya que el acceso a los duplicados de dichas tarjetas SIM permite que se realicen operaciones bancarias fraudulentas en un corto espacio de tiempo. Mediante la duplicación de las tarjetas SIM, los supuestos suplantadores pueden conseguir el control de la línea del abonado y con ello la recepción de SMS dirigidos al legítimo abonado para confirmar operaciones on-line con entidades bancarias suplantando su personalidad. Estos SMS los envían las entidades bancarias como parte de la verificación en dos pasos de operaciones como transferencias monetarias o pagos por Internet, y el acceso a estos SMS suele ser el motivo de la duplicación fraudulenta de las tarjetas SIM.

Es cierto que **ORANGE** no es responsable de las políticas de identificación de clientes establecidas por las entidades bancarias ni se le puede atribuir la responsabilidad por fraude bancario. No obstante, también es cierto que, si **ORANGE** asegurase el procedimiento de identificación y entrega, ni siquiera podría activarse el sistema de verificación de las entidades bancarias. La persona estafadora tras conseguir la activación de la nueva SIM, toma el control de la línea telefónica, pudiendo así, a continuación, realizar operaciones bancarias fraudulentas accediendo a los SMS que las entidades bancarias envían a sus clientes. Esta secuencia de hechos genera una serie de daños y perjuicios graves que deberían haberse tenido en cuenta en una evaluación de impacto relativa a la protección de datos (considerando 89, 90, 91 y artículo 35 del RGPD) o en el análisis de riesgos correspondiente. En definitiva, desde el momento que se entrega un duplicado a una persona distinta a la titular de la línea o persona autorizada, el cliente pierde el control de la línea y los riesgos, daños y perjuicios, se multiplican. Además, los hechos acontecen con una inmediatez abrumadora.

En suma, la aplicación del artículo 83.2.a) del RGPD se refiere a la gravedad de los Hechos Probados, que se pone de manifiesto, entre otras cuestiones, en la alarma social generada por la realización de estas prácticas fraudulentas y por la altísima probabilidad de materialización del riesgo, sin que sea determinante el número de reclamaciones presentadas. Y ello, porque lo que se ha analizado en el presente procedimiento sancionador son las medidas técnicas y organizativas implantadas por el responsable del tratamiento a raíz de la reclamación presentada ante la AEPD.

En relación a la manifestación de **ORANGE** referida a que no todos los clientes tomados en consideración en el acuerdo de inicio para fijar el número de afectados son personas físicas, señalar que esta Agencia ha tomado el dato de su página web, y que puede aportar el dato del número de clientes que son personas físicas, aunque como ya se ha señalado, en la aplicación del artículo 83.2.a) se ha tenido en cuenta el número de clientes, pero también la alarma social generada por la realización de estas prácticas fraudulentas y por la altísima probabilidad de materialización del riesgo, y sin que sea determinante el número de reclamaciones presentadas

b) toda infracción anterior cometida por el responsable o encargado del tratamiento (artículo 83.2.e RGPD)

ORANGE pone de manifiesto que no deberían tenerse en cuenta las infracciones previas cometidas y sancionadas, ya que no guardan relación con el presente supuesto. No obstante, el apartado e) del artículo 83.2 del RGPD recoge expresamente “toda infracción anterior cometida por el responsable”, por lo que dentro de la misma entrarían todos los supuestos que se han reflejado en el acuerdo de inicio, teniendo en cuenta que en ningún momento se indica que tales infracciones deban ser la misma que el caso en cuestión.

c) la vinculación entre la actividad empresarial de la reclamada y el tratamiento de datos personales de clientes o de terceros (artículo 83.2.k RGPD en relación con el artículo 76.2.b) LOPDGDD.)

ORANGE manifiesta que este factor es ambiguo en su valoración para incluirlo como agravante, ya que dicha vinculación no supone una relación directa con la supuesta infracción, y, además, exige que dicho agravante sea puesto en relación con el supuesto de hecho concreto, y por tanto que el tratamiento de datos no nace de una intención de la entidad, sino que tiene lugar la comisión de un delito.

Sin embargo, desde esta Agencia se tiene en cuenta que el desarrollo de la actividad empresarial que desempeña **ORANGE** requiere un tratamiento continuo y a gran escala de los datos personales de los clientes, entre el que se incluye la emisión de duplicados de tarjeta SIM, **ORANGE** se configura como una de las grandes operadoras de telecomunicaciones de nuestro país.

Además, no puede olvidarse que este supuesto de hecho concreto se produce por una falta de medidas técnicas y organizativas adecuadas por parte de **ORANGE**.

Por último, añadir que el legislador es quien previó la posibilidad de utilizar este agravante y que la Agencia se limita a aplicarla.

d) intencionalidad o negligencia en la infracción.

ORANGE manifiesta que esta Agencia no relaciona este agravante, ni señala su aplicación al presente supuesto de hecho.

De este modo, entiende que, según ha manifestado el TJUE cuando manifestaba que la imposición de sanciones coercitivas por la autoridad administrativa solo es admisible en los casos en los que se aprecie una conducta culpable por el responsable o encargado del tratamiento, la imposición de este agravante debe estar reservado a los casos en los que la intencionalidad o negligencia sea evidente o grave.

Por ello, en este caso, en el que el supuesto viene causado por un acto delictivo no imputable a **ORANGE**, entiende que no debería imputarse este agravante sin razonamiento alguno al respecto.

En lo que respecta a que el supuesto de hecho que ha motivado la apertura de este expediente sancionador viene causado por un hecho delictivo no imputable a **ORANGE**, se reitera lo ya manifestado en esta propuesta de resolución en lo referente a que lo que se imputa a **ORANGE** es el hecho de no tener implementadas las

medidas necesarias para que no se produzca el duplicado de la tarjeta SIM en los términos en los que se ha producido. En este sentido, si **ORANGE** hubiera sido diligente a la hora de implementar las medidas adecuadas para la emisión de los duplicados de tarjetas SIM no se habría producido un supuesto como el que comunicaba la parte reclamante.

Además, se considera que la conducta de **ORANGE** responde al tipo infractor y al título de culpa, considerándose que ha actuado con negligencia grave en la infracción del artículo 25. Como depositaria de datos de carácter personal a gran escala, por lo tanto, habituada o dedicada específicamente a la gestión de los datos de carácter personal de los clientes, debe ser especialmente diligente y cuidadosa en su tratamiento. Es decir, desde la óptica de la culpabilidad, estamos ante un error vencible, ya que, con la aplicación de las medidas técnicas y organizativas adecuadas, estas suplantaciones de identidad se hubieran podido evitar.

Si bien la Agencia considera que no hubo intencionalidad por parte de **ORANGE**, concluye que fue negligente al no asegurar un procedimiento que garantizase la protección de los datos personales de los clientes. De manera que se produce un resultado socialmente dañoso que impone la desaprobación de las medidas implantadas que resultaban ineficaces, independientemente del nivel de compromiso demostrado, que resulta incuestionable.

Negar la concurrencia de una actuación negligente por parte de **ORANGE** equivaldría a reconocer que su conducta -por acción u omisión- ha sido diligente. Obviamente, no compartimos esta perspectiva de los hechos, puesto que ha quedado acreditada la falta de diligencia debida. Una gran empresa que realiza tratamientos de datos personales de sus clientes a gran escala, de manera sistemática y continua, debe extremar el cuidado en el cumplimiento de sus obligaciones en materia de protección de datos, tal y como establece la jurisprudencia.

Resulta muy ilustrativa, la SAN de 17 de octubre de 2007 (rec. 63/2006), partiendo de que se trata de entidades cuya actividad lleva aparejado en continuo tratamiento de datos de clientes, indica que *"...el Tribunal Supremo viene entendiendo que existe imprudencia siempre que se desatiende un deber legal de cuidado, es decir, cuando el infractor no se comporta con la diligencia exigible. Y en la valoración del grado de diligencia ha de ponderarse especialmente la profesionalidad o no del sujeto, y no cabe duda de que, en el caso ahora examinado, cuando la actividad de la recurrente es de constante y abundante manejo de datos de carácter personal ha de insistirse en el rigor y el exquisito cuidado por ajustarse a las prevenciones legales al respecto".*

En este sentido, es de vital importancia establecer e implantar los procedimientos y medidas necesarios, en función de las características y entidad de la operadora, que permitan demostrar que se ha tenido una debida diligencia a la hora de intentar evitar que se produjese una suplantación de identidad. Además, se ha de poder demostrar que se han adoptado las necesarias precauciones durante el desarrollo de la actividad empresarial, exigidas por la normativa, para evitar un daño que fuera previsible. Se trata de tener un nivel de cuidado objetivo atendiendo a las concretas circunstancias del caso que posibilite hacer patente que se estaba al tanto de la posibilidad de sufrir una suplantación de identidad, y que, con ello, se aplicaron las medidas oportunas para reducir la concreción de tal riesgo al mínimo posible.

Por otro lado, **ORANGE** manifiesta que se deberían haber tenido en cuenta las siguientes atenuantes:

-la parte reclamada procedió a bloquear la línea en cuanto tuvo conocimiento de los hechos. (art. 83.2.c).

No se puede tener en cuenta este atenuante, cuando, como consecuencia de la infracción imputada, la parte reclamante ha sufrido pérdidas que ascienden a los 9.000 euros.

-no se han tratado categorías especiales de datos (art. 83.2.g).

No se puede tener en cuenta esta alegación en la medida en que tratar datos personales incluidos dentro de la categoría de datos especiales se puede tener en cuenta como agravante para el cálculo de la sanción, pero nunca tratar datos de carácter personal que no estén incluidos dentro de esta categoría puede ser considerada como atenuante, a la hora de imponer una sanción.

Además, se tiene en cuenta que la tarjeta SIM es un dato personal que tiene una naturaleza especialmente sensible, ya que posibilita la suplantación de identidad.

-el grado de cooperación de **ORANGE** con la AEPD. De este modo, **ORANGE** quiere manifestar que ha quedado acreditado que se ha contestado en tiempo y forma a todos los requerimientos de información solicitados, con el fin de poner remedio a una supuesta infracción y mitigar sus posibles efectos adversos (art. 83.2.f).

No se puede tener en cuenta esta alegación en la medida en que contestar a los requerimientos de información enviados desde esta Agencia son una obligación del responsable, tal y como se recoge en la LOPDGDD.

-la adhesión a códigos de conducta en virtud del artículo 40 o mecanismos de certificación aprobados con arreglo al artículo 42 (art. 83.2.j)

ORANGE aporta como documento nº 15 un certificado emitido por AENOR, por el que se acredita que **ORANGE** tiene aprobado desde el 4 de septiembre de 2023 un sistema de cumplimiento normativo que cumple con los requisitos del artículo 31 bis del Código Penal, así como el resto de estándares de cumplimiento e materia de prevención de delitos, como la Circular 1/2016, de 22 de enero, de la Fiscalía General del Estado, destinado a la mitigación de cualquier riesgo de comisión de delitos en el marco de la actuación de **ORANGE**.

Esta certificación no puede ser tenida en cuenta a la hora de fijar los poderes correctivos, pues no se trata, en este caso, de acreditar que se han adoptado medidas de cumplimiento normativo en materia penal, sino de acreditar que se cumplen estándares en materia de protección de datos.

-el inexistente beneficio obtenido por **ORANGE** en el tratamiento de los datos que ocupa este procedimiento sancionador, añadiendo que, en todo caso, sería

perjudicada, como ya se ha señalado, siendo parte perjudicada en el procedimiento penal en el que se denuncia la comisión del delito que nos ocupa (83.2.k).

Esta alegación presentada por **ORANGE** no puede ser tenida en cuenta, en la medida en que, el hecho de que no se hayan obtenido beneficios no puede ser considerado como un atenuante, de acuerdo con la sentencia de la Audiencia Nacional, de 05/05/2021, rec. 1437/2020, que indica: *“Considera, por otro lado, que debe apreciarse como atenuante la no comisión de una infracción anterior. Pues bien, el artículo 83.2 del RGPD establece que debe tenerse en cuenta para la imposición de la multa administrativa, entre otras, la circunstancia “e) toda infracción anterior cometida por el responsable o el encargado del tratamiento”. Se trata de una circunstancia agravante, el hecho de que no concurra el presupuesto para su aplicación conlleva que no pueda ser tomada en consideración, pero no implica ni permite, como pretende la actora, su aplicación como atenuante”; aplicado al supuesto enjuiciado, la falta del presupuesto para su aplicación respecto del art. 76.2.c) de la LOPDGDD, esto es, obtener beneficios consecuencia de la infracción, no permite su aplicación como atenuante.”*

De este modo, conforme a lo previsto en el artículo 83.1 del RGPD, admitir la ausencia de beneficios como una atenuante, no solo es contrario a los presupuestos de hechos contemplados en el artículo 76.2.c), sino también contrario a lo establecido en el artículo 83.2.k) del RGPD y a los principios señalados.

Así, valorar la ausencia de beneficios como una atenuante anularía el efecto disuasorio de la multa, en la medida en que minora el efecto de las circunstancias que inciden efectivamente en su cuantificación, reportando al responsable un beneficio al que no se ha hecho merecedor. Sería una rebaja artificial de la sanción que puede llevar a entender que infringir la norma sin obtener beneficios, financieros o del tipo que fuere, no le producirá un efecto negativo proporcional a la gravedad del hecho infractor.

En todo caso, las multas administrativas establecidas en el RGPD, conforme a lo establecido en su artículo 83.2, se imponen en función de las circunstancias de cada caso individual y no se estima que la ausencia de beneficios sea un factor de graduación adecuado y determinante para valorar la gravedad de la conducta infractora. Solo en el caso de que esta ausencia de beneficios sea relevante para determinar el grado de antijuricidad y de culpabilidad presentes en la concreta actuación infractora podrá considerarse como una atenuante, en aplicación del artículo 83.2.k) del RGPD, que se refiere a “cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso”.

IV

Respuesta a las alegaciones a la propuesta de resolución del procedimiento sancionador

En relación con las alegaciones aducidas a la propuesta de resolución del presente procedimiento sancionador, se procede a dar respuesta a las mismas según el orden expuesto por **ORANGE**:

Primero. De la existencia de prejudicialidad penal.

ORANGE insiste en su alegación referida a que existiría prejudicialidad penal basándose en el hecho de que el sujeto que ha cometido la infracción ha sido los Agentes contratados por la distribuidora.

Añade que esto es especialmente relevante, porque dependiendo de lo que se determine con respecto a la actuación de los agentes y el tipo delictivo que se les aplique se condicionará la potencial imputabilidad de responsabilidad a **ORANGE**.

Con respecto al hecho, manifiesta que es evidente la coincidencia.

Y con respecto al fundamento, manifiesta que existe una incompatibilidad entre la imposición de una multa administrativa a **ORANGE** derivada de una actuación delictiva de la que es víctima.

Añade que la AEPD pretende que **ORANGE** responda administrativamente de un ilícito penal cometido por Agentes de sus distribuidoras, por el mero hecho de que el delito se lleva a cabo manipulando dolosamente el funcionamiento de su sistema. De este modo, señala que la distribuidora es una empresa franquiciada, perteneciente al canal de distribución, ajena a **ORANGE**, que actúa como encargada del tratamiento y el ilícito cometido se realiza por personal laboral de dicha franquicia, en contra de las instrucciones documentadas por mi representada.

ORANGE añade que esta AEPD debe asumir que la conducta de los agentes es constitutiva de infracción penal.

En relación con la manifestación referida a la existencia de prejudicialidad penal, esta Agencia quiere manifestar que esta cuestión ya ha sido resuelta en el fundamento anterior al dar respuesta a las alegaciones presentadas al acuerdo de inicio, y se remite a lo recogido en ese punto, y, por tanto, se desestima la presente alegación.

Por otro lado, **ORANGE** cuestiona tener que responder por la infracción cometida por los Agentes de sus distribuidoras. En este sentido, según la STJUE de 5 de diciembre de 2023 dictada en el asunto C-683/21:

“83-Por lo que respecta, en segundo lugar, a la cuestión de si puede imponerse una multa administrativa con arreglo al artículo 83 del RGPD a un responsable del tratamiento en relación con las operaciones de tratamiento efectuadas por un encargado, es preciso recordar que, según la definición que figura en el artículo 4, punto 8, del RGPD, se entiende por encargado del tratamiento «la persona física o jurídica, autoridad pública, servicio u otro organismo que trate datos personales por cuenta del responsable del tratamiento».

84- Dado que, como se ha indicado en el apartado 36 de la presente sentencia, un responsable del tratamiento es responsable no solo por todo tratamiento de datos personales que efectúe él mismo, sino también por los tratamientos realizados por su cuenta, puede imponerse a ese responsable una multa administrativa con arreglo al artículo 83 del RGPD en una situación en la que los datos personales son objeto de un

tratamiento ilícito y en la que no es él, sino un encargado al que ha recurrido, quien ha efectuado el tratamiento por cuenta suya.

Asimismo, la sentencia SAN de 8 de febrero de 2024, rec.0002250/2021 también recoge:

“Pues bien, no ha que quedado acreditado que las citadas empresas, como encargadas del tratamiento de la parte actora, hayan determinado fines y medios del tratamiento, ni hayan utilizado los datos de los clientes de aquella para sus propias finalidades, ni han interactuado frente a los interesados ajenos a la estructura y nombre comercial de la sociedad recurrente, sino que han actuado bajo el nombre de la parte actora para el cumplimiento de los fines de estos, utilizando los sistemas de ésta para realizar las operaciones con los clientes.

Por lo que, no cabe invocar el art. 28.10 del RGPD para una presunta atribución de responsabilidad a los encargados que, además, implique la exoneración del responsable del tratamiento, es decir, de la sociedad aquí recurrente (...)”

En el presente supuesto, tal y como se ha constatado en los Hechos probados, el encargado del tratamiento actuaba en régimen de franquicia, siendo **ORANGE** quien proporciona todo “el soporte técnico, el saber hacer, las licencias de uso para sus signos distintivos y las colaboraciones necesarias para la consecución de los objetivos y fines del presente contrato”. Es más, el tratamiento de los datos personales era realizado sobre el propio sistema de información de ORANGE.

A todo esto, hay que añadir que el duplicado de tarjeta SIM se emite bajo la marca de la operadora **ORANGE**, y el cliente contrata con **ORANGE**, que es quien presta el servicio de telecomunicaciones. Sin todo ello, el duplicado de la tarjeta SIM no tendría utilidad.

Por lo tanto, de conformidad con lo anteriormente expuesto, esta alegación de **ORANGE** no puede ser tenida en cuenta.

Segunda. Sobre el supuesto de hecho.

2.1. Sobre la consideración de la tarjeta SIM como dato personal.

ORANGE manifiesta que esta Agencia interpreta que la tarjeta SIM no solo contiene, sino que es un dato personal en sí misma.

Asimismo, insiste en que no consta que se haya tratado información alguna que pudiera estar contenida en la tarjeta SIM.

Añade que un duplicado de tarjeta SIM implica la emisión de una tarjeta SIM vacía, que no permitiría per se el acceso a información bancaria o financiera.

Respecto al IMSI, se trataría de un código contenido dentro de la tarjeta SIM con una finalidad técnica, y que no está directamente accesible. Además, no consta evidencia de que este dato haya sido accedido por los Agentes en la comisión del delito.

A este respecto, **ORANGE** añade que, aunque pudiera considerarse que esta información hace potencialmente identificable al titular de la línea, la posibilidad de identificación por parte de terceros distintos de la operadora requeriría información adicional a la que no tienen acceso.

En relación con esta cuestión hay que señalar que, como ya se recogió en las contestaciones a las alegaciones presentadas al acuerdo de inicio, en el apartado “Segunda: sobre el supuesto de hecho”, la interpretación del concepto de dato personal de modo amplio ha sido recogido tanto en la Sentencia del TJUE en el asunto C -101/2001(Lindqvist) de 6.11.2003, apartado 24, Rec. 2003 p. I-12971, como en numerosas sentencias de la Audiencia Nacional que también se recogen en dichas contestaciones, a las que desde aquí hay que remitirse.

No cabe duda de que para **ORANGE** el titular de una tarjeta SIM está plenamente identificado y que también está identificado para las personas que solicitan el duplicado de la tarjeta SIM del número de teléfono de una persona determinada. Por tanto, esta alegación no puede ser tenida en cuenta.

2.2. Sobre la realización de operaciones bancarias.

ORANGE considera que esta Agencia utiliza estas asociaciones para agravar el supuesto de hecho origen de este procedimiento sancionador, otorgando al duplicado de tarjeta SIM la facultad de permitir la comisión de operaciones bancarias, obviando un paso previo donde los criminales deberán obtener y utilizar las credenciales bancarias, para identificarse y realizar la suplantación de identidad ante la entidad financiera.

Insiste en que esta Agencia no entra a analizar la responsabilidad de las entidades bancarias afectadas por la suplantación de identidad.

Además, entiende **ORANGE** que, desde esta Agencia se realiza una transferencia de responsabilidad de una operación bancaria hacia **ORANGE**, calificando como idénticas las obligaciones de las operadoras y las de las entidades bancarias.

ORANGE en su escrito de alegaciones a la propuesta de resolución aporta manifestaciones en las que quiere mostrar su disconformidad con el hecho de que no se haya iniciado ninguna acción para que las entidades bancarias informen acerca del funcionamiento de sus sistemas.

Prosigue manifestando que cabe preguntarse por qué los bancos implementaron en el año 2019 un sistema de autenticación reforzado considerado como inseguro, contraviniendo el artículo 32 del RGPD y porque aún no se ha solicitado información al respecto.

Insiste en que esta Agencia realiza una transferencia de responsabilidad de una operación bancaria hacia **ORANGE**, calificando como idénticas las obligaciones de modo injustificado. Menciona en este punto pronunciamientos de la Autoridad Bancaria Europea, que harían referencia a que las entidades bancarias son las únicas responsables de la seguridad de sus operaciones.

Añade que no se puede responsabilizar a **ORANGE** de la configuración del envío de SMS como segundo factor de autenticación empleado por los responsables de otros servicios como son los operadores bancarios. En este sentido, menciona la Sentencia 142/2024, de 21 de marzo de 2024 de la Audiencia Provincial de Oviedo, en el que la víctima había clicado en un enlace remitido a través de un SMS, produciéndose un acceso no autorizado a su área de cliente, y realizándose una transferencia de 6.000 euros desde la cuenta bancaria, y en el que la Audiencia Provincial reiteraba la culpabilidad de la entidad bancaria.

Esta cuestión, en contraposición a lo alegado por **ORANGE**, sí está ampliamente contestada en el fundamento anterior en la respuesta a sus alegaciones al acuerdo de inicio, en el apartado “Segundo” referido también al “supuesto de hecho”, al que desde aquí hay que remitirse, rechazando por tanto esta alegación.

2.3. Sobre la relación de los autores del hecho delictivo con **ORANGE**.

ORANGE manifiesta que los agentes son empleados de un distribuidor de la marca **ORANGE**, que ostenta el rol de Encargado del Tratamiento según lo dispuesto en el artículo 28 del RGPD. Añade que es el encargado del tratamiento quien debe, al actuar por cuenta de **ORANGE**, disponer de los medios correspondientes que permitan detectar y prevenir actuaciones dolosas de sus empleados. En este punto se remiten a la legislación laboral, manifestando que, en virtud del artículo 20, apartados 2 y 3 del Estatuto de los Trabajadores, la potestad de control recae sobre el empresario del que depende el empleado, y por tanto, en este caso, dependería de la distribuidora de la marca **ORANGE**.

Pone de manifiesto que no puede aducirse que se haya producido un incumplimiento del artículo 6 por parte de **ORANGE** ya que, la conducta dolosa corresponde a los empleados del tratamiento, quienes, contrariamente a lo dispuesto en el artículo 28 del RGPD no han seguido las instrucciones del responsable del tratamiento, y que, por tanto, la responsabilidad por la comisión de la infracción del artículo 6 del RGPD debería recaer en el encargado del tratamiento.

En lo que respecta a la cuestión del responsable y el encargado del tratamiento, **ORANGE** ya había mencionado la posible responsabilidad del encargado del tratamiento en el apartado 1 de sus alegaciones a la propuesta de resolución, y desde aquí nos remitimos a lo señalado por esta AEPD en ese punto.

No obstante, con relación a las manifestaciones referidas a que los agentes del encargado del tratamiento no habrían seguido las instrucciones de **ORANGE** en cuanto responsable del tratamiento, hay que tener en cuenta las Directrices 7/2020 del CEPD, que determinan que:

“30 Siguiendo la línea del enfoque basado en los hechos, la palabra «determine» significa que el ente que realmente ejerce una influencia decisiva sobre los fines y medios del tratamiento es el responsable. Por lo general, el contrato de tratamiento establece quién es la parte determinante (el responsable del tratamiento) y quién, la parte que sigue las instrucciones (el encargado del tratamiento). Incluso cuando el encargado del tratamiento ofrezca un servicio que se defina previamente de un modo concreto, deberá presentar al responsable del tratamiento una descripción detallada

del servicio, y este deberá adoptar la decisión final sobre la aprobación del modo en que se efectuará el tratamiento y solicitar los cambios que considere necesarios. Además, el encargado del tratamiento no puede modificar, en un momento posterior, los elementos esenciales del tratamiento sin la aprobación del responsable.

39. La cuestión es dónde se debe trazar la línea entre las decisiones reservadas al responsable del tratamiento y aquellas que pueden dejarse a la discreción del encargado. Es evidente que las decisiones sobre el fin del tratamiento siempre deben corresponder al responsable.

40. Por lo que respecta a la determinación de los medios, cabe distinguir entre los medios esenciales y los no esenciales. Los medios esenciales se reservan tradicionalmente y de forma inherente al responsable del tratamiento. Estos deben ser determinados obligatoriamente por el responsable del tratamiento, aunque la determinación de los medios no esenciales también puede dejarse en manos de él. Los medios esenciales son medios estrechamente ligados al fin y el alcance del tratamiento, como el tipo de datos personales tratados («¿qué datos se tratarán?»), la duración del tratamiento («¿cuánto tiempo se tratarán?»), las categorías de destinatarios («¿quién tendrá acceso a los datos?») y las categorías de interesados («¿a quién pertenecen los datos personales tratados?»). Además de estar relacionados con el fin del tratamiento, los medios esenciales se encuentran estrechamente vinculados a la cuestión de si el tratamiento es lícito, necesario y proporcionado. Los medios no esenciales están relacionados con aspectos más prácticos del tratamiento en sí, como la elección de un tipo particular de hardware o software o la decisión sobre los pormenores de las medidas de seguridad, que pueden dejarse en manos del encargado del tratamiento.

41. Pese a que las decisiones sobre los medios no esenciales pueden dejarse en manos del encargado del tratamiento, el responsable aún deberá estipular ciertos elementos en el contrato con el encargado: por ejemplo, en relación con el requisito de seguridad, podrá ordenarse la adopción de todas las medidas exigidas en virtud del artículo 32 del RGPD. El contrato también debe establecer que el encargado del tratamiento ayudará al responsable a garantizar el cumplimiento de, por ejemplo, lo dispuesto en el artículo 32. En cualquier caso, el responsable del tratamiento sigue siendo responsable de la aplicación de las medidas técnicas y organizativas apropiadas a fin de garantizar y poder demostrar que el tratamiento es conforme con el Reglamento (artículo 24). Para ello, el responsable debe tener en cuenta la naturaleza, el alcance, el contexto y los fines del tratamiento, además de los riesgos para los derechos y las libertades de las personas físicas. Por este motivo, el responsable del tratamiento debe contar con una información completa sobre los medios utilizados, ya que, así, podrá adoptar una decisión informada al respecto. Para que el responsable pueda demostrar la legalidad del tratamiento, se aconseja documentar, en el contrato u otro instrumento jurídicamente vinculante entre el responsable y el encargado, al menos las medidas técnicas y organizativas necesarias.

(...)

80. En segundo lugar, el tratamiento debe llevarse a cabo por cuenta de un responsable del tratamiento, pero no bajo su autoridad ni control directos. Actuar «por

cuenta de» alguien significa servir los intereses de otro y remite al concepto jurídico de «delegación». En el caso de la normativa de protección de datos, el cometido del encargado del tratamiento es aplicar las instrucciones dadas por el responsable del tratamiento, cuando menos en lo relativo a los fines del tratamiento y a los elementos esenciales de los medios. La legitimidad del tratamiento en virtud del artículo 6 y, si procede, del artículo 9 del Reglamento deriva de la actividad del responsable, y el encargado únicamente debe tratar los datos siguiendo las instrucciones dadas por este. Aun así, tal como se ha indicado previamente, las instrucciones del responsable del tratamiento pueden dejar cierto margen de discrecionalidad sobre el modo de servir mejor a los intereses de este, de modo que permitan al encargado elegir los medios técnicos y organizativos más adecuados.³²

81. Actuar «por cuenta de» alguien también significa que el encargado no puede llevar a cabo el tratamiento para sus propios fines. Tal como se estipula en el artículo 28, apartado 10, el encargado del tratamiento infringirá el RGPD cuando no se ciña a las instrucciones del responsable y comience a determinar sus propios fines y medios del tratamiento. En estos casos, el encargado del tratamiento se considerará responsable en relación con dicho tratamiento y podrá ser sancionado por no haberse adherido a las instrucciones del responsable”.

Como ya se ha señalado anteriormente, la STJUE precitada “un responsable del tratamiento es responsable no solo por todo tratamiento de datos personales que efectúe él mismo, sino también por los tratamientos realizados por su cuenta, puede imponerse a ese responsable una multa administrativa con arreglo al artículo 83 del RGPD en una situación en la que los datos personales son objeto de un tratamiento ilícito y en la que no es él, sino un encargado al que ha recurrido, quien ha efectuado el tratamiento por cuenta suya”.

En el presente supuesto, y tal y como se encuentra recogido en los Hechos Probados de esta Resolución, el duplicado de la tarjeta SIM se produce en un establecimiento **ORANGE** propiedad de la empresa “TOWER PHONE, S.L.,” que actúa como encargada del tratamiento de **ORANGE**.

También se hace referencia al contrato de franquicia de las dos entidades, de fecha 1 de abril de 2022, en la que se podía comprobar que:

“II. (...)”

V. (...).

(...).

(...)

“(...).

(...)

(...)”

A todo esto, hay que añadir, como ya se ha señalado anteriormente, que el cliente, en todo momento, está contratando los servicios de telefonía con **ORANGE**, puesto que, de conformidad con todo lo señalado anteriormente y que figura en el contrato de franquicia, es **ORANGE** como responsable del tratamiento la que determina la finalidad y los medios de los tratamientos realizados para el ejercicio de la actividad, y quien realmente presta el servicio de telefonía.

Por lo tanto, en base a lo expuesto, procede desestimar esta alegación de **ORANGE**.

Tercera. Sobre la actuación delictiva de los agentes.

Con esta alegación, **ORANGE** está intentado que este supuesto sea tratado de manera diferente al resto de supuestos de SIM SWAPPING, dado que el supuesto que ha motivado la apertura de este procedimiento sancionador consistiría en una variante delictiva de nuevo cuño

Sin embargo, esta cuestión ya se contestó en las alegaciones al acuerdo de inicio a la que desde aquí nos remitimos, en el apartado Tercera: del rol de víctima de **ORANGE**.

ORANGE manifiesta que disponía de las medidas y procedimientos de seguridad diligente, y como consecuencia han sido los delincuentes los que han evolucionado, y que esto probaría que si disponía de un adecuado diseño de la privacidad.

Añade que la aparición de estas prácticas se habría puesto de manifiesto en el “Comité AntifraudeTeleco” celebrado en el mes de marzo de 2023, y que como consecuencia de que los Agentes sean corrompidos y puedan ejercer actividades delictivas se ha realizado una nueva evaluación del riesgo atribuido a esta amenaza, aportando una matriz de riesgo como documento nº 1, en la que se puede observar un elemento referido al SIM SWAPPING, pero que está relacionado con el Phising. Y no figura nada referido a fraude por empleados.

También figura como elemento “fraudulent Use of Data by 3rd Parties/ Payment Fraud”.

ORANGE manifiesta que se puede comparar esta matriz con la aportada como documento nº 12 en las alegaciones al acuerdo de inicio. Este documento 12 se titula “2023 Non Telco Fraud Risk map. Key risk” y en él también figura un apartado referido a “Fraudulent use of Data-3rd Parties” y en este punto “(…)”

Sin embargo, el riesgo derivado de que los empleados puedan utilizar sus credenciales para cometer hechos delictivos no se encuentra recogido tampoco en ninguna de estas tablas. El riesgo referido a “Fraudulent use of Data-3rd parties” está redactado de manera genérica, y ello no implica que el riesgo a que hace referencia **ORANGE** se encontrara analizado y evaluado en atención a las medidas implantadas por ORANGE.

En este punto, **ORANGE** insiste en que no puede interpretarse que permitir a un agente de tienda tomar decisiones sobre algunas cuestiones pueda asimilarse al incumplimiento del RGPD, porque choca con la propia regulación recogida en el mismo, donde se consideraría que el riesgo reside en la adopción de decisiones

automatizadas sin intervención humana. Y añadía que la finalidad de la intervención del agente era evitar que, en supuestos específicos y tasados, (...) impida al interesado el acceso a un servicio contratado.

ORANGE prosigue manifestando que la Agencia categoriza la parametrización de (...) como una vulneración del artículo 25.

En relación con esta cuestión, es necesario señalar que esta cuestión también ha sido contestada en la propuesta de resolución, en el sentido de que **ORANGE** tiene implementado un sistema para la emisión de tarjetas SIM en las que si (...), pero ya no solo, como manifiesta **ORANGE**, cuando el (...).

(...).

Así las cosas, **ORANGE** manifiesta que, (...). Tal y como señala **ORANGE** “(...)”

Sin embargo, tal y como se ha demostrado, (...).

Por todo lo expuesto, esta alegación debe ser rechazada.

Cuarta. De la inexistencia de falta de legitimación en el tratamiento de datos personales de ORANGE.

ORANGE, con esta alegación, quiere insistir en que los hechos que han motivado la apertura del expediente sancionador han sido realizados por empleados de uno de sus encargados de tratamiento, y entiende que esta Agencia pretende responsabilizar a **ORANGE** del proceder de estos agentes, sin importar que este proceder pueda constituir un ilícito penal.

Esta cuestión, sin embargo, ya ha sido contestada en la alegación segunda apartado 3 del Fundamento III.

Hay que recordar que lo que se está enjuiciando en este procedimiento sancionador respecto de la infracción del art. 6 del RGPD es el hecho de que se hayan tratado los datos de la parte reclamante mediante la emisión de un duplicado de su tarjeta SIM, sin que concurriera ninguna base de legitimación. Para emitir el duplicado (...) , lo que demuestra que ORANGE no contaba con su consentimiento. La tarjeta SIM ha sido emitida en nombre de **ORANGE**, lo que supone que **ORANGE** sea la responsable del tratamiento y como tal la responsable de que los tratamientos que se realizan por su cuenta se basen en alguna de las circunstancias que legitiman el tratamiento de datos personales.

Es **ORANGE** la que debe responder del incumplimiento en materia de protección de datos, sin perjuicio de las actuaciones posteriores que pueda llevar a cabo.

Por tanto, en virtud de todo lo expuesto, procede rechazar esta alegación.

Quinto. De la correcta implementación de la privacidad desde el diseño y por defecto.

ORANGE quiere manifestar que, en base a las manifestaciones recogidas en la propuesta de resolución, sí se habría tenido en cuenta la privacidad desde el diseño, en función de la documentación remitida, el diseño de protocolos y el establecimiento de medidas en aras a garantizar el cumplimiento de los principios de protección de datos.

En este sentido, el proceso para la emisión de duplicados de tarjeta SIM lleva aparejados unos controles y medidas de seguridad destinadas a garantizar que las SIM sean emitidas a solicitud de los clientes y una vez verificada su identidad, habiéndose tenido en cuenta la protección de la privacidad de los interesados, y cree que esta Agencia trata de descalificar la prueba documental bajo la única premisa de que se ha producido un supuesto concreto en la que ha mediado un delito.

Añade que **ORANGE** sí dispone de políticas encaminadas a garantizar la aplicación de los principios de protección de datos en sus procesos de negocio, independientemente de que no se identifique en cada uno de ellos la referencia específica a las garantías en materia de privacidad, ya que, si bien abordan los riesgos asociados en esta materia, no es la única que se tiene en cuenta, del mismo modo que no se especifican en cada uno de ellos los riesgos penales analizados, o los riesgos económicos o los reputacionales.

En este sentido, como ya se recogía en la propuesta de resolución, el principio de protección de datos desde el diseño impone que, desde los estadios más iniciales de planificación de un tratamiento debe de ser considerado este principio: el responsable del tratamiento desde el momento en que se diseña y planifica un eventual tratamiento de datos personales deberá determinar todos los elementos que conforman el tratamiento, a los efectos de aplicar de forma efectiva los principios de protección de datos, integrando las garantías necesarias en el tratamiento con la finalidad última de, cumpliendo con las previsiones del RGPD, proteger los derechos de los interesados.

Por tanto, desde el diseño del tratamiento ya no existían medidas del artículo 25 del RGPD (...). La ausencia de medidas para garantizar que la solicitud de duplicado de tarjeta se realizaba por el titular de la línea, unido a que tampoco se comprobaba que se realizaba la entrega al titular, es lo que constituye un incumplimiento del principio de protección de datos desde el diseño.

Esto supone que **ORANGE** no habría identificado y analizado de forma adecuada los riesgos que (...), ni previsto ni aplicado desde el diseño las medidas técnicas y organizativas apropiadas, para aplicar de forma efectiva los principios de protección de datos, que exige el artículo 25 RGPD.

ORANGE se limita a decir que cumplía con los requisitos previstos, y aporta una documentación en la que se dice que tiene en cuenta este artículo, pero en ninguna de ellas se indica precisamente que se había implementado el principio de protección de datos desde el diseño y (...).

Para solventar esta cuestión, manifiesta que la documentación inicial que ya ha proporcionado es la información inicial que se facilita para cualquier proyecto en el que se traten datos personales en aras a comenzar a regular las distintas actividades desde una perspectiva que vele por la privacidad y la protección de datos personales,

y que, para cada caso particular se aplican las medidas que se consideran correspondientes, como puede ser la formación de personal encargado de los procesos. Sin embargo, sigue sin presentar dicha documentación. Manifiesta que aportó el documento nº 12, en las alegaciones al acuerdo de inicio, que junto con el documento 1 presentado en el escrito de alegaciones a la propuesta de resolución, acreditarían que sí se tenía identificado el riesgo.

Sin embargo, desde esta Agencia se entiende que dichos documentos no acreditan el cumplimiento del principio de protección de datos desde el diseño. El citado documento nº 12 a que hace referencia está fechado en el año 2023 y se titula (...).

En el documento denominado 1 de las alegaciones a la propuesta de resolución, se aporta una matriz de riesgos en la que se identifica el riesgo “Fraudulent use of data-3rd parties”, sin más desarrollo y se evalúa como riesgo bajo pero no se indica si el riesgo es para los derechos y libertades de los interesados o para la continuidad en el negocio.

ORANGE aporta como documento 2 de sus alegaciones a la propuesta el acta del comité de Riesgos Local del año 2022 en la que se aprueba la política de gestión de riesgos OSP y la matriz de riesgo OSP, entre otras cuestiones, pero de su contenido parece desprenderse que en ellas se evalúa el riesgo para la continuidad del negocio.

También aporta el documento nº 3 el mapa de riesgos residuales desde la óptica de los derechos y libertades de los interesados referido al año 2022 donde se identificaba al riesgo de fraude como bajo, y que según ORANGE fue tratado en el Comité de riesgos Local del año 2022 cuya acta se adjuntaba como documento nº 2.

En este sentido, la citada acta del Comité de Riesgos Local, de fecha 3/10/2022 recoge en el apartado 6. Riesgos: Integración Mapas de riesgos:

“(…).

(…).

(…).”

A su vez, en el apartado 8 del acta: Fraude Telco se recoge:

“(…).

(…).

(…).

(…).

(…).

(…).”

En el apartado 9 referido a Fraude non Telco se añade:

“(…).”

En cuanto al mapa de riesgos aportado como documento nº 3, titulado 2022 Non Telco Fraud risk map: Fraudulent use of Data-3rd parties contiene “(…)”

Y recoge lo siguiente:

(…).

Pues bien, según las alegaciones de **ORANGE** este documento se habría presentado al Comité cuya acta ha aportado como documento nº 2, y se habría tratado en el mismo, y sin embargo no hay ninguna referencia al mismo en la referida acta del comité.

Además, hay que tener en cuenta que, a pesar de las manifestaciones de **ORANGE**, desde esta Agencia se sigue manteniendo que no se han previsto los riesgos para los derechos y libertades derivados (...). No se ha tenido en cuenta el riesgo interno de que los empleados puedan cometer algún tipo de infracción, pero es que además se entiende que el impacto no puede ser calificado como limitado basado en que las entidades bancarias deban devolver cualquier cargo realizado por conculcación de sus sistemas.

A la vista está este supuesto en el que la parte reclamante había sufrido pérdidas económicas que ascienden a 9.000 euros, sin olvidar que en la denuncia ante el Juzgado que **ORANGE** ha presentado en su escrito de alegaciones al acuerdo de inicio, son más las personas las que se podrían haber visto afectadas, aunque no hayan presentado reclamación en la AEPD. De este modo, el impacto que este riesgo tiene en los derechos y libertades de las personas es elevado, por ello el riesgo residual no puede ser calificado como bajo sin la implantación de medidas adecuadas.

Por todo ello, desde esta Agencia se ha considerado que, a pesar de haber presentado un documento que tendría como fecha 2022, se entiende que con ello no se puede determinar el cumplimiento del artículo 25 del RGPD.

En relación con el resto de las cuestiones planteadas por **ORANGE**, hay que señalar que ya han sido contestadas en las contestaciones a las alegaciones al acuerdo de inicio, apartado Quinto, por lo que, esta alegación debe ser rechazada.

Sexta. Sobre la existencia de un concurso de infracciones.

ORANGE manifiesta que las dos infracciones tienen como base la conducta delictiva de los agentes, lo cual constituye un supuesto de concurrencia de infracciones en vía administrativa.

En este sentido, **ORANGE** entiende que lo decisivo para determinar si efectivamente se ha producido este incumplimiento es la adecuación o no de las medidas implementadas. Manifiesta que, según lo argumentado por esta Agencia, se extraería que existe una conexión directa entre las vulneraciones de ambos artículos. Considera

que, la infracción del artículo 6 del RGPD, esto es, la existencia de un (supuesto) tratamiento de datos ilícito fue necesaria e inevitable para que tuviera lugar una vulneración del principio de privacidad desde el diseño y por defecto, derivada de no existir (indicado en términos de defensa, supuestamente) medidas de seguridad suficientes.

En relación con esta alegación hay que señalar que esta AEPD se reitera en la respuesta dada a las alegaciones al acuerdo de inicio, apartado Sexto.

No es cierto que el incumplimiento del artículo 25 del RGPD requiera un tratamiento de datos sin base de legitimación. El artículo 25 impone una obligación al responsable de adoptar las medidas necesarias para cumplir con el principio de protección de datos desde el diseño, sin que sea necesario que la falta de medidas o su deficiente implantación ocasione cualquier otro resultado contrario al RGPD. Es el incumplimiento de lo dispuesto en el artículo 25 lo que se sanciona, lo que puede suceder independientemente de que se produzca un tratamiento de datos sin base de legitimación, por lo que procede rechazar dicha alegación.

Séptima. Sobre la inadmisibilidad de la responsabilidad objetiva.

ORANGE insiste en que la propuesta de resolución se basa exclusivamente en el resultado, sin tener en cuenta que el hecho se produce por la actuación delictiva y dolosa de los agentes de **ORANGE**, que actuaba en calidad de encargado del tratamiento, corrompiendo el proceso y las medidas estipuladas por ésta.

ORANGE entiende que la actuación delictiva de los agentes ha determinado de manera automática que no se adoptaron medidas adecuadas, surgiendo automáticamente la responsabilidad directa de **ORANGE**.

Además, entiende que esta Agencia ha determinado que se ha producido una tipología genérica de fraude sin entrar a valorar las circunstancias específicas de este caso.

Entiende **ORANGE** que esta Agencia ha errado al tener en cuenta las siguientes consideraciones:

-en primer lugar, los delincuentes eran agentes comerciales de un punto de venta de un distribuidor, y no ciberdelincuentes.

-en segundo lugar, esta Agencia no tienen en cuenta la evolución del fraude SIM SWAPPING, considerando que, ante la producción de un supuesto fraude, la entidad resulta responsable, con independencia de la actuación de los agentes del punto de venta.

Insiste en que tenían identificado el riesgo, pero estaba considerado como de bajo riesgo, puesto que no se había producido con anterioridad.

ORANGE considera que, respecto a la normativa de servicios de pagos, se estaría calificando como idénticas las obligaciones tanto para las operadoras como para las entidades bancarias de un modo injustificado, ya que **ORANGE** no puede responder de las deficiencias y decisiones tomadas por los bancos.

ORANGE manifiesta que, según esta Agencia, los riesgos deben basarse en aquello que es razonable y técnicamente posible, y considera que, en este caso, **ORANGE** había depositado su confianza en sus distribuidores. Considera además que la intervención humana resulta inevitable.

Añade que esta Agencia pretende que **ORANGE** prevea todas y cada una de las amenazas que puedan tener lugar, esperando un resultado en que las medidas sean infectibles, pasando por alto amenazas que difícilmente pueden ser previstas, como sería este caso.

Es por ello por lo que entiende que esta Agencia establece una obligación de resultado, al señalar que la comisión de un acto delictivo en el entorno de **ORANGE** conlleva automáticamente su responsabilidad, con independencia del dolo empleado por el autor, y el nivel de diligencia empleado por **ORANGE**.

ORANGE manifiesta que esta Agencia no ha entrado a valorar la jurisprudencia expuesta con relación a la inadmisión de la responsabilidad objetiva en el ámbito del procedimiento administrativo sancionador.

Por ello, entiende que, al no haberse acreditado la concurrencia de una actuación culpable, intencionada o negligente por parte de **ORANGE**, no procede determinar que ha cometido una infracción de la normativa de protección de datos.

En lo que respecta a esta alegación, esta cuestión ya ha sido contestada en la contestación a las alegaciones al acuerdo de inicio, en el apartado séptimo: sobre la inadmisibilidad de la responsabilidad objetiva.

A pesar de ello, esta Agencia quiere manifestar que, en contra de las alegaciones de **ORANGE**, en las que insiste en que esta Agencia pretende que **ORANGE** prevea todas y cada una de las amenazas que puedan tener lugar, esperando un resultado en que las medidas sean infectibles, pasando por alto amenazas que difícilmente pueden ser previstas, como sería este caso, el artículo 25 del RGPD determina : “...el responsable del tratamiento aplicará, tanto en el momento de determinar los medios del tratamiento como en el momento del propio tratamiento, medidas técnicas y organizativas apropiadas...”

Las Directrices 4/2019 del Comité Europeo de Protección de Datos (CEPD) relativas al artículo 25 Protección de datos desde el diseño y por defecto, Versión 2.0, Adoptadas el 20 de octubre de 2020, indican:

“29 El RGPD adopta un enfoque coherente basado en el riesgo en muchas de sus disposiciones, en los artículos 24, 25, 32 y 35, con el fin de determinar las medidas técnicas y organizativas adecuadas para proteger a las personas y sus datos personales y cumplir los requisitos del RGPD. Los bienes protegidos son siempre los mismos (las personas, a través de la protección de sus datos personales), frente a los mismos riesgos (para los derechos de las personas), y teniendo en cuenta las mismas circunstancias (la naturaleza, el ámbito, el contexto y los fines del tratamiento).

30. Al realizar el análisis de riesgos para el cumplimiento del artículo 25, el responsable del tratamiento ha de determinar los riesgos que entraña una violación de los principios para los derechos de los interesados, así como su probabilidad y gravedad a fin de aplicar medidas que mitiguen de forma efectiva los riesgos detectados. En las evaluaciones de riesgos es crucial realizar una evaluación sistemática y minuciosa del tratamiento. Por ejemplo, un responsable evalúa los riesgos concretos asociados a la ausencia de un consentimiento libremente otorgado, que constituye una violación del principio de licitud, en el curso del tratamiento de los datos personales de niños y jóvenes menores de 18 años como grupo vulnerable, en un caso en que no existe ningún otro fundamento jurídico, y aplica medidas adecuadas para abordar y mitigar de forma efectiva los riesgos detectados asociados a este grupo de interesados” (el subrayado es nuestros)

En definitiva, el cumplimiento del principio de protección de datos desde el diseño requiere identificar los concretos riesgos para los derechos y libertades de las personas que conlleva el tratamiento, analizarlos y evaluarlos de forma que se permita determinar y aplicar de modo efectivo desde el inicio del tratamiento las medidas técnicas y organizativas específicas para garantizar cada uno de los principios de protección de datos, como los de licitud, exactitud y confidencialidad, lo que en este caso no se ha hecho.

Como ya se señalaba en la contestación a las alegaciones al acuerdo de inicio, se entiende que **ORANGE**, al evaluar los riesgos de la utilización de la aplicación que tiene implantada para emitir duplicados de tarjeta SIM, no ha tenido en cuenta los riesgos, así como su impacto en los derechos y libertades de las personas. Ya ha quedado demostrado que el impacto que este posible riesgo tenía en los derechos y libertades de las personas es alto, y esto tampoco se había tenido en cuenta. Ha sido la falta de diligencia a la hora de implementar en origen las medidas adecuadas para comprobar (...) es, precisamente, lo que constituye el elemento de la culpabilidad.

Es por ello que procede rechazar esta alegación de **ORANGE**.

Octava. Sobre las medidas adoptadas e implementadas por ORANGE.

ORANGE pone de manifiesto que ya habría enumerado las medidas que había desplegado, tanto de manera previa como a posteriori, para que desde esta Agencia se pueda apreciar la constante evolución y análisis de riesgos, así como las medidas aplicadas, teniendo en cuenta la evolución de los supuestos de fraude SIM Swapping.

ORANGE insiste en que tenía establecidas las siguientes medidas:

1. medidas implementadas por **ORANGE** para prevenir la comisión de fraudes derivados de la suplantación de identidad de su cliente.

-documentación ya aportada que se pone a disposición de los agentes y demás personal con capacidad para llevar a cabo actuaciones en **ORANGE**.

-comunicaciones adicionales que reiteran los protocolos de actuación para la emisión de duplicados de tarjeta SIM.

-(...).

-**ORANGE** forma parte de la Asociación Española para la Digitalización y participa en el proyecto “Identidad Digital Segura”, que tiene por objeto, entre otros, proteger frente al fraude y los ciberataques y la defensa de la privacidad de los datos.

-(...).

2. Medidas implementadas por **ORANGE** para prevenir la comisión de fraudes derivados de la suplantación de agentes y/o empleados de **ORANGE**.

-implantación de un doble factor de identificación, que se encontraría en fase de testeo con ciertos usuarios.

-proyecto (...).

-herramientas de control de tráfico, que es utilizada por el Grupo de Análisis de Riesgos de **ORANGE**, y que puede generar alertas en caso de posibles detecciones de contrataciones irregulares, y que funciona de la siguiente manera en el caso de duplicados de tarjeta SIM:

- (...).

-(...).

3. medidas adoptadas con relación al presente supuesto, no recogidas en los apartados anteriores.

-se ha modificado el riesgo asociado a este tipo de supuestos, ostentando un impacto mayor en los protocolos y actuaciones de la compañía.

-se ha suspendido cautelarmente el (...) que tiene lugar en los supuestos como el caso que ha motivado la apertura de este procedimiento sancionador, para poder determinar las medidas adecuadas para mitigar los riesgos identificados.

En cualquier caso, **ORANGE** quiere manifestar que lleva a cabo un constante control y revisión de los riesgos existentes en materia de duplicados de tarjeta SIM, que los protocolos se actualizan y que se adoptan medidas acordes a los riesgos identificados, sin que ello permita imponer a las mismas la garantía o exigencia de infalibilidad.

ORANGE manifiesta que desde esta Agencia no se ha revisado este desglose, y entiende que es necesario para comprender la amenaza y poder prevenir y mitigar su comisión, y añade que con ello habría quedado acreditada su voluntad de protección de los derechos de los particulares, en el que la existencia de un riesgo cero es actualizado y revisado.

Esta Agencia entiende que **ORANGE** sigue manifestando que cumple con las disposiciones del artículo 25 del RGPD. En este caso vuelve a enumerar las medidas que tenía implementadas, y manifiesta que esta Agencia no las ha tenido en cuenta,

Algunas de las medidas puestas de manifiesto por **ORANGE** no resultan de aplicación a supuestos en los que la solicitud de tarjetas SIM se realiza de modo presencial. El tratamiento de los datos no sólo requiere el establecimiento de medidas de ciberseguridad, sino que se hacen necesarias otras medidas para mitigar los riesgos que se derivan (...).

Alega **ORANGE** que se ha eliminado la posibilidad de realizar duplicados de tarjeta SIM desde el área de clientes, y desde quioscos; se ha puesto en marcha (...); se ha modificado el riesgo asociado a este tipo de supuestos, ostentando un impacto mayor en los protocolos y actuaciones de la compañía y se ha suspendido cautelarmente el (...) que tiene lugar en los supuestos como el caso que ha motivado la apertura de este procedimiento sancionador, para poder determinar las medidas adecuadas para mitigar los riesgos identificados.

Pues bien, todas estas medidas no se encontraban implementadas por **ORANGE** de forma previa, sino que han sido aplicadas con posterioridad a los hechos, por lo que no se tuvieron en cuenta desde el diseño del tratamiento, por ello no pueden ser tenidas tampoco en cuenta en el presente caso.

En el apartado quinto de la contestación a las alegaciones al acuerdo de inicio se dice, respecto de los documentos aportados por **ORANGE**, lo siguiente:

Se trata de una documentación en la que se hace referencia a la posibilidad de la existencia de riesgos, pero no se identifican de manera concreta, y no se prevén actuaciones en concreto con respecto a la posibilidad de que se produzcan situaciones como la que se ha producido en el presente expediente sancionador, en la medida en que no se hace mención alguna de forma concreta a la posibilidad de que (...).

No hay ningún documento en el que se prevea cuáles son los riesgos (...). Ya se ha mencionado en la contestación a estas alegaciones que, desde esta Agencia no se puede considerar que la posibilidad de que los empleados puedan realizar un duplicado de tarjeta SIM no puede ser calificado como bajo, pero esto no implicaría que todos los empleados sean potenciales delincuentes, únicamente que hay que valorar esta posibilidad y tener medidas al respecto, sobre todo teniendo en cuenta cual es el impacto en los derechos y libertades de las personas.

ORANGE manifiesta que, (...).

Por todo ello, procede rechazar la alegación presentada por **ORANGE**.

9. Sobre la falta de proporcionalidad de la sanción propuesta.

ORANGE manifiesta haber actuado con la diligencia debida en la implementación de medidas en los procesos de duplicados de tarjeta SIM, pero, para el caso de que esta Agencia considere que existe dicho incumplimiento, entiende que la sanción es desproporcionada, atendiendo a las circunstancias y contenido de la infracción, en la medida en que ha sido cometida de manera dolosa por agentes de la distribuidora.

En este sentido, entiende que los siguientes agravantes utilizados por esta Agencia, se ha realizado sin que concurran las circunstancias para su consideración:

-Naturaleza, gravedad y duración de la infracción (art. 83.2.a) RGPD)

Esta alegación ya ha sido contestada en las alegaciones al acuerdo de inicio de este procedimiento sancionador, y por lo tanto, no puede ser tenida en cuenta.

-toda infracción cometida por el responsable o encargado del tratamiento (art. 83.2.e) RGPD)

ORANGE reitera su disconformidad con el hecho de que se utilice este agravante, ya que los hechos que motivaron dichos procedimientos no tienen nada que ver con el presente supuesto de hecho.

Esta alegación ya ha sido contestada en las alegaciones al acuerdo de inicio de este procedimiento sancionador, y por lo tanto, no puede ser tenida en cuenta.

-la vinculación entre la actividad empresarial de la reclamada y el tratamiento de datos personales de clientes o de terceros (art. 83.2.k del RGPD en relación con el artículo 76.2.b) de la LOPDGDD).

Esta alegación ya ha sido contestada en las alegaciones al acuerdo de inicio de este procedimiento sancionador y cabe añadir que la actividad empresarial de **ORANGE** sí se encuentra relacionada con el tratamiento de datos personales, pues resulta obvio que la actividad de **ORANGE** implica necesariamente la realización de un alto número de operaciones de tratamiento de datos personales de las personas físicas clientes de dicha entidad, lo que repercute en la diligencia que debe desplegar en el cumplimiento de las obligaciones derivadas de este tratamiento de datos.

-intencionalidad o negligencia en la infracción.

Esta alegación ya ha sido contestada en las alegaciones al acuerdo de inicio de este procedimiento sancionador.

Sobre la aplicación de esta circunstancia como agravante se ha pronunciado la Audiencia Nacional en su SAN de uno de marzo de dos mil veinticuatro (Núm. de Recurso: 0001757 /2021) en la que considera que procede la aplicación de la circunstancia contemplada en el artículo 83.2.b) del RGPD en el caso de falta de diligencia de entidades que realizan tratamientos de datos a gran escala, así se especifica que *"(...) Y en este sentido se debe señalar que una empresa como la demandante que realiza tratamientos de datos personales de sus clientes a gran escala, de manera sistemática y continúa debe extremar el cuidado en el cumplimiento de sus obligaciones en materia de protección de datos. La actora pone el acento en la ausencia de intencionalidad cuando el precepto habla también de negligencia y es en esa falta de diligencia en la que pone el acento la resolución recurrida en relación con ambas infracciones (...)"*

Por tal motivo, se considera justificada la aplicación de la circunstancia contemplada en el artículo 83.2.b) del RGPD.

Asimismo, considera que esta Agencia no ha tenido en cuenta las siguientes circunstancias atenuantes:

-**ORANGE** procedió a bloquear la línea cuando tuvo conocimiento de los hechos. (art. 83.2.c) RGPD)

-no se han tratado categorías especiales de datos (art. 83.2.g)

- el grado de cooperación de **ORANGE** con esta Agencia. (art. 83.2.f)
- la adhesión a códigos de conducta en virtud del artículo 40 o mecanismos de certificación aprobados con arreglo al artículo 42 (art. 83.2.j)
- el inexistente beneficio obtenido por **ORANGE**. (art. 83.2.k), manifestando que, en todo caso, ha resultado perjudicada.

Todas estas cuestiones ya fueron contestadas en las contestaciones a las alegaciones al acuerdo de inicio, y procede rechazarlas.

V

Obligación incumplida

El artículo 6.1 del RGPD, establece los supuestos que permiten considerar lícito el tratamiento de datos personales.

“1. El tratamiento solo será lícito si se cumple al menos una de las siguientes condiciones:

- a) el interesado dio su consentimiento para el tratamiento de sus datos personales para uno o varios fines específicos;*
- b) el tratamiento es necesario para la ejecución de un contrato en el que el interesado es parte o para la aplicación a petición de este de medidas precontractuales;*
- c) el tratamiento es necesario para el cumplimiento de una obligación legal aplicable al responsable del tratamiento;*
- d) el tratamiento es necesario para proteger intereses vitales del interesado o de otra persona física;*
- e) el tratamiento es necesario para el cumplimiento de una misión realizada en interés público o en el ejercicio de poderes públicos conferidos al responsable del tratamiento;*
- f) el tratamiento es necesario para la satisfacción de intereses legítimos perseguidos por el responsable del tratamiento o por un tercero, siempre que sobre dichos intereses no prevalezcan los intereses o los derechos y libertades fundamentales del interesado que requieran la protección de datos personales, en particular cuando el interesado sea un niño.*

Lo dispuesto en la letra f) del párrafo primero no será de aplicación al tratamiento realizado por las autoridades públicas en el ejercicio de sus funciones.”

En el presente caso, consta acreditado que se ha producido un duplicado de la tarjeta SIM de la parte reclamante a un tercero, sin su consentimiento, (...).

De este modo, **ORANGE** reconoce este hecho en su escrito de fecha 30 de enero de 2023, al poner de manifiesto: *“Habiéndose, pues, constatado la irregularidad en la solicitud del duplicado, el equipo de Análisis de Riesgos confirmó que dos agentes del Punto de Venta de la tienda de ORANGE MADRID ***DIRECCIÓN.1 habían actuado irregularmente, usando sus credenciales de los sistemas internos de esta mercantil para activar el duplicado de tarjeta SIM.*

ORANGE prosigue manifestando que *“se pudo comprobar que, en el momento de la contratación se siguió el protocolo establecido por esta mercantil pasando un documento de identidad por el sistema de verificación de la identidad [...]. Este sistema permite identificar que los documentos de identidad son válidos. No obstante, a pesar de que se siguieron las instrucciones indicadas a los distribuidores, debido a que fueron los agentes los que actuaron irregularmente, para realizar el duplicado aportaron un documento de identidad válido pero que no se correspondía con el de la parte reclamante, motivo por el cual, al pasarlo por el sistema [...], fue identificado como correcto y se continuó con el proceso de duplicado.”*

ORANGE ha comunicado que el procedimiento a seguir, cuando se solicita un duplicado de la tarjeta SIM es el siguiente: (...).

(...).

Por regla general, **ORANGE** añade que (...).

Fue esta circunstancia, en el caso que nos ocupa, (...).

Por lo tanto, **ORANGE** facilitó un duplicado de la tarjeta SIM de la parte reclamante a un tercero, sin el consentimiento de aquella, (...).

Asimismo, (...).

En ese sentido el Considerando 40 del RGPD señala: *“(40) Para que el tratamiento sea lícito, los datos personales deben ser tratados con el consentimiento del interesado o sobre alguna otra base legítima establecida conforme a Derecho, ya sea en el presente Reglamento o en virtud de otro Derecho de la Unión o de los Estados miembros a que se refiera el presente Reglamento, incluida la necesidad de cumplir la obligación legal aplicable al responsable del tratamiento o la necesidad de ejecutar un contrato en el que sea parte el interesado o con objeto de tomar medidas a instancia del interesado con anterioridad a la conclusión de un contrato.”*

Por tanto, de conformidad con las evidencias de las que se dispone en este momento de resolución de procedimiento sancionador, se considera que los hechos conocidos, esto es la expedición de un duplicado de la tarjeta SIM sin el consentimiento del titular de la línea en este caso concreto, son constitutivos de una infracción, imputable a **ORANGE**, por vulneración del artículo 6.1 del RGPD.

VI

Tipificación y calificación de la infracción

La citada infracción del artículo 6.1 del RGPD supone la comisión de las infracciones tipificadas en el artículo 83.5 del RGPD que bajo la rúbrica “*Condiciones generales para la imposición de multas administrativas*” dispone:

“Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 20 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 4 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

a) los principios básicos para el tratamiento, incluidas las condiciones para el consentimiento a tenor de los artículos 5, 6, 7 y 9.”

A efectos del plazo de prescripción de las infracciones, la infracción imputada prescribe a los tres años, conforme al artículo 72.1.b) de la LOPDGDD, que califica de muy grave la siguiente conducta:

“1. En función de lo que establece el artículo 83.5 del Reglamento (UE) 2016/679 se consideran muy graves y prescribirán a los tres años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

b) El tratamiento de datos personales sin que concurra alguna de las condiciones de licitud del tratamiento establecidas en el artículo 6 del Reglamento (UE) 2016/679”

VII

Sanción por la infracción del artículo 6.1 del RGPD

A efectos de decidir sobre la imposición de una multa administrativa y su cuantía, de conformidad con las evidencias de que se dispone en el presente momento de resolución de procedimiento sancionador, se considera que procede graduar la sanción a imponer de acuerdo con los siguientes criterios que establece el artículo 83.2 del RGPD:

- La naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido (apartado a): la actuación imputada a **ORANGE** supone una pérdida de disposición y control de los datos personales de la parte reclamante, que ha tenido como consecuencia una suplantación de identidad, y la realización de actividades bancarias fraudulentas. Es importante tener en cuenta que el tratamiento de datos personales con objeto de obtener un duplicado de tarjeta SIM puede ser la puerta para acceder a otros datos que permiten la producción de una sensible pérdida patrimonial para su titular, como sucedió en este caso.
- Toda infracción anterior cometida por el responsable o el encargado del tratamiento (apartado e): consta que, con fecha 31 de enero de 2023, se dictó

resolución en el procedimiento nº EXP202204288, en la que se impuso una multa de 70.000 euros.

Consta que, con fecha 30 de enero de 2023, se dictó resolución en el procedimiento nº EXP202203638, en la que también se impuso una multa de 70.000 euros. Consta que, con fecha 10 de noviembre de 2021, se dictó resolución en el expediente PS/00022/2021, en la que se impuso una multa de 700.000 euros.

Asimismo, se considera que procede graduar la sanción a imponer de acuerdo con los siguientes criterios que establece el apartado 2 del artículo 76 “*Sanciones y medidas correctivas*” de la LOPDGDD:

Como agravantes:

- Vinculación de la actividad del infractor con la realización de tratamientos de datos de carácter personal (apartado b): el desarrollo de la actividad empresarial que desempeña la entidad requiere un tratamiento continuo de datos personales.

El balance de las circunstancias contempladas en el artículo 83.2 del RGPD y 76.2 de la LOPDGDD, con respecto a la infracción cometida al vulnerar lo establecido en el artículo 6.1 del RGPD, permite fijar una sanción de 200.000 € (doscientos mil euros).

VIII

Protección de datos desde el diseño y por defecto

El Artículo 25 “Protección de datos desde el diseño y por defecto” del RGPD establece:

“1.Teniendo en cuenta el estado de la técnica, el coste de la aplicación y la naturaleza, ámbito, contexto y fines del tratamiento, así como los riesgos de diversa probabilidad y gravedad que entraña el tratamiento para los derechos y libertades de las personas físicas, el responsable del tratamiento aplicará, tanto en el momento de determinar los medios de tratamiento como en el momento del propio tratamiento, medidas técnicas y organizativas apropiadas, como la seudonimización, concebidas para aplicar de forma efectiva los principios de protección de datos, como la minimización de datos, e integrar las garantías necesarias en el tratamiento, a fin de cumplir los requisitos del presente Reglamento y proteger los derechos de los interesados.

2.El responsable del tratamiento aplicará las medidas técnicas y organizativas apropiadas con miras a garantizar que, por defecto, solo sean objeto de tratamiento los datos personales que sean necesarios para cada uno de los fines específicos del tratamiento. Esta obligación se aplicará a la cantidad de datos personales recogidos, a la extensión de su tratamiento, a su plazo de conservación y a su accesibilidad. Tales medidas garantizarán en particular que, por defecto, los datos personales no sean accesibles, sin la intervención de la persona, a un número indeterminado de personas físicas.

3.Podrá utilizarse un mecanismo de certificación aprobado con arreglo al artículo 42 como elemento que acredite el cumplimiento de las obligaciones establecidas en los apartados 1 y 2 del presente artículo.”

Este artículo se encuadra dentro de las obligaciones generales que el Capítulo IV del RGPD establece al responsable del tratamiento, imponiendo una obligación de diseño de procedimientos internos en el momento de determinar los medios de tratamiento y, de aplicar esos procedimientos en el momento del tratamiento, para garantizar de forma efectiva el cumplimiento de los requisitos de protección de datos, recogidos en la normativa general de Protección de Datos.

Asimismo, el considerando 78 del RGPD establece:

“La protección de los derechos y libertades de las personas físicas con respecto al tratamiento de datos personales exige la adopción de medidas técnicas y organizativas apropiadas con el fin de garantizar el cumplimiento de los requisitos del presente Reglamento.

A fin de poder demostrar la conformidad con el presente Reglamento, el responsable del tratamiento debe adoptar políticas internas y aplicar medidas que cumplan en particular los principios de protección de datos desde el diseño y por defecto.

Dichas medidas podrían consistir, entre otras, en reducir al máximo el tratamiento de datos personales, seudonimizar lo antes posible los datos personales, dar transparencia a las funciones y el tratamiento de datos personales, permitiendo a los interesados supervisar el tratamiento de datos y al responsable del tratamiento crear y mejorar elementos de seguridad.

Al desarrollar, diseñar, seleccionar y usar aplicaciones, servicios y productos que están basados en el tratamiento de datos personales o que tratan datos personales para cumplir su función, ha de alentarse a los productores de los productos, servicios y aplicaciones a que tengan en cuenta el derecho a la protección de datos cuando desarrollan y diseñen estos productos, servicios y aplicaciones, y que se aseguren, con la debida atención al estado de la técnica, de que los responsables y los encargados del tratamiento están en condiciones de cumplir sus obligaciones en materia de protección de datos.

Los principios de la protección de datos desde el diseño y por defecto también deben tenerse en cuenta en el contexto de los contratos públicos.”

En el presente caso, hay que tener en cuenta que **ORANGE** es el responsable, al establecer los medios y los fines para el tratamiento de los datos personales.

De este modo, para los supuestos de expedición de duplicados de tarjetas SIM en tienda, **ORANGE** ha comunicado que el procedimiento a seguir, cuando se solicita un duplicado de la tarjeta SIM, (...).

No obstante, **ORANGE** ha informado que (...).

(...).

(...).

El principio de protección de datos desde el diseño impone que, desde los estadios más iniciales de planificación de un tratamiento debe de ser considerado este

principio: el responsable del tratamiento desde el momento en que se diseña y planifica un eventual tratamiento de datos personales deberá determinar todos los elementos que conforman el tratamiento, a los efectos de aplicar de forma efectiva los principios de protección de datos, integrando las garantías necesarias en el tratamiento con la finalidad última de, cumpliendo con las previsiones del RGPD, proteger los derechos de los interesados.

Así, y respecto de los riesgos que pueden estar presentes en el tratamiento, el responsable del tratamiento llevará a cabo un ejercicio de análisis y detección de los riesgos durante todo el ciclo de tratamiento de los datos, con la finalidad primera y última de proteger los derechos y libertades de los interesados, y no sólo cuando efectivamente se produce el tratamiento. Así se expresa en las Directrices 4/2019 del CEPD relativas al artículo 25 Protección de datos desde el diseño y por defecto, adoptadas el 20 de octubre de 2020.

En las citadas Directrices se indica al respecto que:

“35. El «momento de determinar los medios de tratamiento» hace referencia al período de tiempo en que el responsable está decidiendo de qué forma llevará a cabo el tratamiento y cómo se producirá este, así como los mecanismos que se utilizarán para llevar a cabo dicho tratamiento. En el proceso de adopción de tales decisiones, el responsable del tratamiento debe evaluar las medidas y garantías adecuadas para aplicar de forma efectiva los principios y derechos de los interesados en el tratamiento, y tener en cuenta elementos como los riesgos, el estado de la técnica y el coste de aplicación, así como la naturaleza, el ámbito, el contexto y los fines. Esto incluye el momento de la adquisición y la implementación del software y hardware y los servicios de tratamiento de datos.

36. Tomar en consideración la PDDD desde un principio es crucial para la correcta aplicación de los principios y para la protección de los derechos de los interesados. Además, desde el punto de vista de la rentabilidad, también interesa a los responsables del tratamiento tomar la PDDD en consideración cuanto antes, ya que más tarde podría resultar difícil y costoso introducir cambios en planes ya formulados y operaciones de tratamiento ya diseñadas”.

Para ello debe recurrir al diseñar el tratamiento a los principios recogidos en el artículo 5 del RGPD, que servirán para aquilatar el efectivo cumplimiento del RGPD.

Así, las citadas Directrices 4/2019 del CEPD disponen que:

“61. Para hacer efectiva la PDDD, los responsables del tratamiento han de aplicar los principios de transparencia, licitud, lealtad, limitación de la finalidad, minimización de datos, exactitud, limitación del plazo de conservación, integridad y confidencialidad, y responsabilidad proactiva. Estos principios están recogidos en el artículo 5 y el considerando 39 del RGPD”.

La Guía de Privacidad desde el Diseño de la AEPD afirma que *“La privacidad desde el diseño (en adelante, PbD) implica utilizar un enfoque orientado a la gestión del riesgo y de responsabilidad proactiva para establecer estrategias que incorporen la protección de la privacidad a lo largo de todo el ciclo de vida del objeto (ya sea éste un sistema, un producto hardware o software, un servicio o un proceso). Por ciclo de vida*

del objeto se entiende todas las etapas por las que atraviesa éste, desde su concepción hasta su retirada, pasando por las fases de desarrollo, puesta en producción, operación, mantenimiento y retirada”.

La Guía dispone que “La privacidad debe formar parte integral e indisoluble de los sistemas, aplicaciones, productos y servicios, así como de las prácticas de negocio y procesos de la organización. No es una capa adicional o módulo que se añade a algo preexistente, sino que debe estar integrada en el conjunto de requisitos no funcionales desde el mismo momento en el que se concibe y diseña (...) La privacidad nace en el diseño, antes de que el sistema esté en funcionamiento y debe garantizarse a lo largo de todo el ciclo de vida de los datos”

Por ello, la privacidad desde el diseño, obligación del responsable del tratamiento que nace antes de que el sistema esté en funcionamiento, no son meros añadidos que se van asentando sobre un sistema construido de espaldas al RGPD. Ligado a la edificación de una verdadera cultura de protección de datos en la organización, implica también por mor de la responsabilidad proactiva la capacidad de documentar todas las decisiones que se adopten con un enfoque “privacy design thinking”, demostrando el cumplimiento del RGPD también en este aspecto.

El enfoque de riesgos hace referencia directa e inmediata a un sistema preventivo tendente a visualizar, respecto de un tratamiento de datos personales, los riesgos en los derechos y libertades de las personas físicas. En relación con los riesgos en esos derechos y libertades, han de identificarse los riesgos, evaluar su impacto y valorar la probabilidad de que aquellos se materialicen. Se protegen pues, no los datos, sino a las personas que están detrás de ellos.

Los riesgos para los derechos y libertades de las personas físicas, derivados del tratamiento de datos personales, pueden ser de gravedad y probabilidad variables y provocar daños y perjuicios físicos, materiales o inmateriales, consecuencias tangibles o intangibles, en los derechos y las libertades de las personas físicas. El considerando 75 del RGPD y el artículo 28.2 de la LOPDGDD recopilan ejemplificativamente algunos de los considerados por el legislador, mas no son los únicos. Dependerá del tratamiento y el contexto en el que este se realiza, de los fines, de los datos personales tratados, de las personas involucradas, de los medios utilizados, etc.

De la documentación que obra en el expediente, se ha constatado que el procedimiento que utiliza **ORANGE** para la expedición de duplicados de tarjetas SIM (...).

En la ya mencionada Guía de Privacidad desde el diseño de la AEPD se establecen diversas orientaciones, que no se cumplen en el supuesto que nos ocupa:

“Cualquier sistema, proceso o infraestructura que vaya a utilizar datos personales debe ser concebida y diseñada desde cero identificando, a priori, los posibles riesgos a los derechos y libertades de los interesados y minimizarlos para que no lleguen a concretarse en daños. Una política de PbD se caracteriza por la adopción de medidas proactivas que se anticipan a las amenazas, identificando las debilidades de los sistemas para neutralizar o minimizar los riesgos en lugar de aplicar medidas correctivas para resolver los incidentes de seguridad una vez sucedidos. Es decir, la

PbD huye de la “política de subsanar” y se adelanta a la materialización del evento de riesgo”.

La privacidad como configuración predeterminada:

“La PbD persigue proporcionar al usuario el máximo nivel de privacidad dado el estado del arte y, en particular, que los datos personales estén automáticamente protegidos en cualquier sistema, aplicación, producto o servicio. La configuración por defecto deberá quedar establecida desde el diseño a aquel nivel que resulte lo más respetuoso posible en términos de privacidad. En el caso de que el sujeto no tome ninguna acción de configuración, su privacidad debe estar garantizada y mantenerse intacta, pues está integrada en el sistema y configurada por defecto.”

Privacidad incorporada en la fase de diseño:

“La privacidad debe formar parte integral e indisoluble de los sistemas, aplicaciones, productos y servicios, así como de las prácticas de negocio y procesos de la organización. No es una capa adicional o módulo que se añade a algo preexistente, sino que debe estar integrada en el conjunto de requisitos no funcionales desde el mismo momento en el que se concibe y diseña. Para garantizar que la privacidad se tiene en cuenta desde las primeras etapas del diseño se debe:

- *Considerar como un requisito necesario en el ciclo de vida de sistemas y servicios, así como en el diseño de los procesos de la organización.*
- *Ejecutar un análisis de los riesgos para los derechos y libertades de las personas y, en su caso, evaluaciones de impacto relativas a la protección de datos, como parte integral del diseño de cualquier nueva iniciativa de tratamiento.*
- *Documentar todas las decisiones que se adopten en el seno de la organización con un enfoque “privacy design thinking”*

En este caso, ha quedado constatado que **ORANGE** no ha establecido medidas desde el diseño del tratamiento para dar cumplimiento a los principios de protección de datos, como los principios de licitud, exactitud y confidencialidad, en los procesos manuales, ya que no existen medidas para verificar que la información introducida por el empleado no es errónea y que la solicitud de duplicado de tarjeta SIM se presenta por el titular de la línea.

Esto supone que no habría identificado y analizado de forma adecuada los riesgos que un proceso manual de duplicados de tarjeta SIM entraña para los derechos y libertades de las personas físicas, ni previsto ni aplicado desde el diseño las medidas técnicas y organizativas apropiadas, para aplicar de forma efectiva los principios de protección de datos, que exige el artículo 25 RGPD.

A este respecto, debe recordarse que conforme al artículo 25 del RGPD:

“Teniendo en cuenta el estado de la técnica, el coste de la aplicación y la naturaleza, ámbito, contexto y fines del tratamiento, así como los riesgos de diversa probabilidad y gravedad que entraña el tratamiento para los derechos y libertades de las personas

físicas, el responsable del tratamiento aplicará, tanto en el momento de determinar los medios de tratamiento como en el momento del propio tratamiento, medidas técnicas y organizativas apropiadas, como la seudonimización, concebidas para aplicar de forma efectiva los principios de protección de datos, como la minimización de datos, e integrar las garantías necesarias en el tratamiento, a fin de cumplir los requisitos del presente Reglamento y proteger los derechos de los interesados.”

Es decir, la protección del derecho fundamental a la protección de datos no consiste en una mera espera “reactiva” a que pueda producirse un problema que lo lesione, sino que los responsables del tratamiento deben diseñar (“protección de datos desde el diseño”) con carácter previo al inicio del tratamiento, las políticas adecuadas para la protección de dicho derecho fundamental. Y ello incluye todos los aspectos regulados en el RGPD, comenzando por las obligaciones de transparencia, el respeto al ejercicio de los derechos establecidos en el Reglamento, y el establecimiento de todas medidas técnicas y organizativas necesarias para garantizar el cumplimiento de dicha norma. Y todo ello debe estar planificado e implementado con carácter previo al inicio del tratamiento por el responsable.

En este caso concreto, no haber previsto estas medidas desde el diseño del procedimiento analizado podría determinar que **ORANGE** no disponía de las medidas adecuadas para evitar que se produzca una situación como la que ha ocurrido en el presente caso, (...).

Por todo lo anterior, se pone de manifiesto que **ORANGE** ha incumplido la obligación de adoptar desde el inicio del tratamiento de medidas técnicas y organizativas, que garanticen los derechos y libertades de las personas teniendo en cuenta los riesgos que entraña este tratamiento, entre ellos el riesgo de suplantación o fraude y pérdida financiera, (...), como ha sido el caso que ha motivado la apertura de este expediente sancionador.

Por ello, de conformidad con las evidencias de las que se dispone en este momento de resolución del procedimiento sancionador, se considera que los hechos conocidos son constitutivos de una infracción, imputable a **ORANGE**, por vulneración del artículo 25 del RGPD.

IX

Tipificación de la infracción del artículo 25

La citada infracción del artículo 25 del RGPD supone la comisión de la infracción tipificada en el artículo 83.4 del RGPD que bajo la rúbrica “*Condiciones generales para la imposición de multas administrativas*” dispone:

“Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 10 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 2 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

a) las obligaciones del responsable y del encargado a tenor de los artículos 8, 11, 25 a 39, 42 y 43; (...)”

A efectos del plazo de prescripción, el artículo 73 “*Infracciones consideradas graves*” de la LOPDGDD indica:

“En función de lo que establece el artículo 83.4 del Reglamento (UE) 2016/679 se consideran graves y prescribirán a los dos años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

(...)

d) La falta de adopción de aquellas medidas técnicas y organizativas que resulten apropiadas para aplicar de forma efectiva los principios de protección de datos desde el diseño, así como la no integración de las garantías necesarias en el tratamiento, en los términos exigidos por el artículo 25 del Reglamento (UE) 2016/679. (...)”

X

Sanción por la infracción del artículo 25 del RGPD

A efectos de decidir sobre la imposición de una multa administrativa y su cuantía, de conformidad con las evidencias de que se dispone en el presente momento de resolución de procedimiento sancionador, se considera que procede graduar la sanción a imponer de acuerdo con los siguientes criterios que establece el artículo 83.2 del RGPD:

- La naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate, así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido (apartado a): Al menos desde que se constató la falta de medidas adecuadas para garantizar la confidencialidad de los datos de los interesados, con fecha 15 de noviembre de 2022, hasta la fecha del acuerdo de inicio del presente procedimiento sancionador, dado que no consta que se hubiera adoptado medidas apropiadas desde el inicio.

Además, según consta en su página web, actualmente **ORANGE** supera los 21 millones de clientes. En este sentido, hay que tener en cuenta que se trata de una infracción que afecta al procedimiento de emisión de las tarjetas SIM, y con ello, todos los clientes de **ORANGE** son potencialmente afectados.

El apartado 54.b.iv de las Directrices 04/2022 del CEPD recoge, como una de las circunstancias a valorar en la graduación de la sanción: “El número de interesados concretamente, pero también potencialmente afectados”, y, aclara con relación a ese criterio: “Cuanto más alto es el número de interesados implicados, mayor ponderación podrá tener la autoridad de control atributo a este factor. En muchos casos también puede considerarse que la infracción asume connotaciones «sistemáticas» y, por lo tanto, puede afectar, incluso en diferentes momentos, sujetos de datos adicionales que no han presentado quejas o informes a la autoridad supervisora. La autoridad de control podrá, en función de las circunstancias del caso, considere la relación entre el número de interesados afectados y el número total de interesados en ese contexto (por ejemplo, el número de ciudadanos, clientes o empleados) con el fin de evaluar si la infracción es de carácter sistémico”.

- Intencionalidad/ Negligencia en la infracción (apartado b). En este sentido, el Tribunal Supremo viene entendiendo que existe imprudencia siempre que se desatiende un deber legal de cuidado, es decir, cuando el infractor no se comporta con la diligencia exigible. Y en la valoración del grado de diligencia ha de ponderarse especialmente la profesionalidad o no del sujeto, y no cabe duda de que, en el caso ahora examinado, cuando la actividad de la recurrente es de constante y abundante manejo de datos de carácter personal ha de insistirse en el rigor y el exquisito cuidado por ajustarse a las prevenciones legales al respecto. [Sentencia de la Audiencia Nacional de 17/10/2007 (rec. 63/2006)]

- Toda infracción anterior cometida por el responsable o el encargado del tratamiento (apartado e): consta que, con fecha 31 de enero de 2023, se dictó resolución en el procedimiento nº EXP202204288, en la que se impuso una multa de 70.000 euros. Consta que, con fecha 30 de enero de 2023, se dictó resolución en el procedimiento nº EXP202203638, en la que también se impuso una multa de 70.000 euros. Consta que, con fecha 10 de noviembre de 2021, se dictó resolución en el expediente PS/00022/2021, en la que se impuso una multa de 700.000 euros.

Asimismo, se considera que procede graduar la sanción a imponer de acuerdo con los siguientes criterios que establece el apartado 2 del artículo 76 “*Sanciones y medidas correctivas*” de la LOPDGDD:

- Vinculación de la actividad del infractor con la realización de tratamientos de datos de carácter personal (apartado b): el desarrollo de la actividad empresarial que desempeña la entidad requiere un tratamiento continuo de datos personales.

El balance de las circunstancias contempladas en el artículo 83.2 del RGPD y 76.2 de la LOPDGDD, con respecto a la infracción cometida al vulnerar lo establecido en el artículo 25 del RGPD, permite fijar una sanción de multa administrativa de 1.000.000 euros.

XI

Adopción de medidas

De acuerdo con lo establecido en el citado artículo 58.2 d) del RGPD, según el cual cada autoridad de control podrá “*ordenar al responsable o encargado del tratamiento que las operaciones de tratamiento se ajusten a las disposiciones del presente Reglamento, cuando proceda, de una determinada manera y dentro de un plazo especificado...*”, se requiere a **ORANGE** para que en el plazo de 6 meses notifique a esta Agencia las medidas que ha adoptado para garantizar que la solicitud de duplicado se presenta por el titular del número de teléfono, sea cual sea el procedimiento utilizado para su emisión.

La imposición de esta medida es compatible con la sanción consistente en multa administrativa, según lo dispuesto en el art. 83.2 del RGPD.

Se advierte que no atender la posible orden de adopción de medidas impuestas por este organismo en la resolución sancionadora podrá ser considerado como una infracción administrativa conforme a lo dispuesto en el RGPD, tipificada como

infracción en su artículo 83.5 y 83.6, pudiendo motivar tal conducta la apertura de un ulterior procedimiento administrativo sancionador.

Por lo tanto, de acuerdo con la legislación aplicable y valorados los criterios de graduación de las sanciones cuya existencia ha quedado acreditada,

la Directora de la Agencia Española de Protección de Datos RESUELVE:

PRIMERO: IMPONER a **ORANGE ESPAGNE, S.A.U.**, con NIF **A82009812**:

-por una infracción del artículo 6 del RGPD, tipificada en el artículo 83.5.a) de dicha norma, multa administrativa de cuantía 200.000 euros (doscientos mil euros).

- por una infracción del artículo 25 del RGPD, tipificada en el artículo 83.4 de dicha norma, multa administrativa de cuantía 1.000.000 euros (un millón de euros).

Que por la Directora de la Agencia Española de Protección de Datos se ordene a **ORANGE ESPAGNE, S.A.U.**, con NIF **A82009812**, que en virtud del artículo 58.2.d) del RGPD, en el plazo de 6 meses, notifique a esta Agencia las medidas que ha adoptado para garantizar que la solicitud de duplicado se presenta por el titular de la línea, sea cual sea el procedimiento utilizado para su emisión.

SEGUNDO: ORDENAR a **ORANGE ESPAGNE, S.A.U.**, con NIF **A82009812**, que en virtud del artículo 58.2.d) del RGPD, en el plazo de 6 meses, notifique a esta Agencia las medidas que ha adoptado para garantizar que la solicitud de duplicado se presenta por el titular del número de teléfono, sea cual sea el procedimiento utilizado para su emisión.

TERCERO: NOTIFICAR la presente resolución a **ORANGE ESPAGNE, S.A.U.**

CUARTO: Esta resolución será ejecutiva una vez finalice el plazo para interponer el recurso potestativo de reposición (un mes a contar desde el día siguiente a la notificación de esta resolución) sin que el interesado haya hecho uso de esta facultad. Se advierte al sancionado que deberá hacer efectiva la sanción impuesta una vez que la presente resolución sea ejecutiva, de conformidad con lo dispuesto en el art. 98.1.b) de la LPACAP, en el plazo de pago voluntario establecido en el art. 68 del Reglamento General de Recaudación, aprobado por Real Decreto 939/2005, de 29 de julio, en relación con el art. 62 de la Ley 58/2003, de 17 de diciembre, mediante su ingreso, indicando el NIF del sancionado y el número de procedimiento que figura en el encabezamiento de este documento, en la cuenta restringida nº **IBAN: ES00-0000-0000-0000-0000-0000**, abierta a nombre de la Agencia Española de Protección de Datos en la entidad bancaria CAIXABANK, S.A.. En caso contrario, se procederá a su recaudación en período ejecutivo.

Recibida la notificación y una vez ejecutiva, si la fecha de ejecutividad se encuentra entre los días 1 y 15 de cada mes, ambos inclusive, el plazo para efectuar el pago voluntario será hasta el día 20 del mes siguiente o inmediato hábil posterior, y si se encuentra entre los días 16 y último de cada mes, ambos inclusive, el plazo del pago será hasta el 5 del segundo mes siguiente o inmediato hábil posterior.

De conformidad con lo establecido en el artículo 76.4 de la LOPDGDD y dado que el importe de la sanción impuesta es superior a un millón de euros, será objeto de publicación en el Boletín Oficial del Estado la información que identifique al infractor, la infracción cometida y el importe de la sanción.

De conformidad con lo establecido en el artículo 50 de la LOPDGDD, la presente Resolución se hará pública una vez haya sido notificada a los interesados.

Contra esta resolución, que pone fin a la vía administrativa conforme al art. 48.6 de la LOPDGDD, y de acuerdo con lo establecido en el artículo 123 de la LPACAP, los interesados podrán interponer, potestativamente, recurso de reposición ante la Directora de la Agencia Española de Protección de Datos en el plazo de un mes a contar desde el día siguiente a la notificación de esta resolución o directamente recurso contencioso administrativo ante la Sala de lo Contencioso-administrativo de la Audiencia Nacional, con arreglo a lo dispuesto en el artículo 25 y en el apartado 5 de la disposición adicional cuarta de la Ley 29/1998, de 13 de julio, reguladora de la Jurisdicción Contencioso-administrativa, en el plazo de dos meses a contar desde el día siguiente a la notificación de este acto, según lo previsto en el artículo 46.1 de la referida Ley.

Finalmente, se señala que conforme a lo previsto en el art. 90.3 a) de la LPACAP, se podrá suspender cautelarmente la resolución firme en vía administrativa si el interesado manifiesta su intención de interponer recurso contencioso-administrativo. De ser éste el caso, el interesado deberá comunicar formalmente este hecho mediante escrito dirigido a la Agencia Española de Protección de Datos, presentándolo a través del Registro Electrónico de la Agencia [<https://sedeagpd.gob.es/sede-electronica-web/>], o a través de alguno de los restantes registros previstos en el art. 16.4 de la citada Ley 39/2015, de 1 de octubre. También deberá trasladar a la Agencia la documentación que acredite la interposición efectiva del recurso contencioso-administrativo. Si la Agencia no tuviese conocimiento de la interposición del recurso contencioso-administrativo en el plazo de dos meses desde el día siguiente a la notificación de la presente resolución, daría por finalizada la suspensión cautelar.

938-16012024

Mar España Martí
Directora de la Agencia Española de Protección de Datos